

SIEMENS

Information Security Baseline

Security Measure Plan for Microsoft Internet Information Services 10

Current release

Authors	Kai Markl
Owner	Siemens CYS GOV POL
Version Number	1.0
Approved By	Jose Antonio Rubio Tora
Status	Release
Document Release Date	2020-10-30
Classification	Restricted
Document ID	BL115
Reference Source	https://sfera.siemens.com

Document History

Version	Author	Date	Description
1.0	Kai Markl	2020-10-30	Initial version

Change Log in the Current Version

Following changes have been submitted during review:

- Created [BL115-0660](#) (Enable only Required Web Service Extensions): Rule based on IIS 8.x measure M383660. Changed during review: Added to the description .NET Core and .NET Framework.
- Created [BL115-0725](#) (Configure a Unique Binding): Rule based on IIS 8.x measure M383725; specified rule more precisely; removed host header requirement as this is covered by BL115-0725. Changed during review: Corrected and added additional script in *Implementation 02*.
- Created [BL115-2921](#) (Ensure Host Headers are Used): Import from CIS. Changed during review: Added missing '>' in the Implementation script 01.
- Created [BL115-5216](#) (Configure 'Application Pool Identity' for all Application Pools): Import from CIS and also partially IIS 8.x measure M383319; strengthened the rule that each application pool must run under a unique identity. Changed during review: Rewrote the *Rule*, and *Exemption* section, aligning better with the CIS rule. Added a Note to the *Description* section which better explains the advantage of the ApplicationPoolIdentity. Added a Note to *Implementation 01* that this procedure only configures the DefaultAppPool.
- Created [BL115-3161](#) (Ensure 'passwordFormat' is set to 'SHA256' or Higher): Import from CIS; changed the rule such that `SHA256` and higher is requested; added an exemption. Changed during review: Removed html tags in the listing of *Check 01*.
- Created [BL115-0846](#) (Set NTFS File System Permissions on Web Content Folders): Rule based on IIS 8.x measure M383846. Changed during review: Divided rule in two rules BL115-0846 and BL115-0847.

- Created [BL115-0847](#) (Restrict Access to Built-In Executables): Rule based on IIS 8.x measure M383846. Changed during review: Created this rule (which was former part of BL115-0846).
- Created [BL115-3216](#) (Ensure 'MachineKey Validation Method - .NET 3.5' is Configured for SHA1): Import from CIS; requested in the rule specifically SHA1. Change during review: Rephrased the Rationale such that the usage of .NET 3.5 should be avoided.
- Created [BL115-2731](#) (Ensure Global .NET Trust Level is Configured): Import from CIS; aligned with M383190 from previous IIS 8.x Measure Plan. Changed during review: Removed the note in the rule which states that this setting applies only to .NET version 2.0 as this is not confirmed yet. The settings are still available in the IIS Manager.
- Created [BL115-8201](#) (Ensure Server Header is removed): Import from CIS. Specified *Rationale* section more precisely; added *Implementation* I01. Changed during review: Added the information to the *Rationale* section that *removeServerHeader* is a new feature in IIS 10.
- Created [BL115-4971](#) (Deny Directory Traversal): Created by Siemens CYS PRO. Changed during review: Reworded parts of the Description for better understanding.
- Created [BL115-4973](#) (Deny Backslashes in URLs): Created by Siemens CYS PRO. Changed during review: Reworded parts of the Description for better understanding.
- Created [BL115-5441](#) (Ensure Default IIS web log location is moved): Import from CIS; specified the rule more precisely; added an exemption. Changed during review: Removed the comment regarding Advanced Logging as Microsoft included this functionality in IIS 8.5.
- Created [BL115-4386](#) (Configure Enhanced Logging for IIS): Import from CIS; added fields to be logged from IIS 8.x measure M383919, but removed the field 'Cookie' as this could impose a security risk. Also removed the field 'Client Port' as this is only relevant for the FTP module. Added PowerShell scripts to ease implementation. Rewrote *Check C01* (from CIS) as it does not make sense this way. Changed during review: Renamed the feature *Advanced Logging* to *Enhanced Logging*; removed the comment to enable this feature as Microsoft integrated this functionality already in IIS 8.5.
- Created [BL115-1957](#) (Ensure Default FTP log location is moved): Import from CIS, but adapted it for 'default FTP log location'; specified the rule more precisely; added an exemption. Changed during review: Removed the comment regarding Advanced Logging as Microsoft integrated this functionality already in IIS 8.5.
- Created [BL115-1956](#) (Ensure 'FTP Logging' is enabled): Created by Siemens CYS PRO. Changed during review: Removed the comment regarding Advanced Logging as Microsoft integrated this functionality already in IIS 8.5.
- Created [BL115-4471](#) (Configure HSTS Header): Import from CIS; modified the value to 31536000 seconds as requested in IIS 8.x measure M383734; added a note to the *Rule* section. Changed during review: Corrected script 03 and 04 in the *Implementation* section.
- Created [BL115-5956](#) (Disable 'SSL 2.0' Protocol): Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- Created [BL115-2561](#) (Disable 'SSL 3.0' Protocol): Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section. Changed

during review: Aligned the rule with the Windows Server Security Measure Plan.

- **Created [BL115-2691](#) (Disable 'TLS 1.0' Protocol):** Import from CIS; formerly part of IIS 8.x measure M383524. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-3386](#) (Disable 'TLS 1.1' Protocol):** Import from CIS; formerly part of IIS 8.x measure M383524. Added an exemption. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-1156](#) (Enable 'TLS 1.2' Protocol):** Import from CIS; added client part of TLS 1.2 as well. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-4921](#) (Disable 'NULL' Cipher Suites):** Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-5881](#) (Disable 'DES' Cipher Suites):** Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-4837](#) (Disable 'RC2' Cipher Suites):** Adapted RC4 rule from CIS benchmark for the RC2 cipher suites; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-4836](#) (Disable 'RC4' Cipher Suites):** Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; removed obsolete information. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-1386](#) (Disable 'Triple DES' Cipher Suites):** Rule based on IIS 8.x measure M383360. Changed during review: Corrected the registry key from 'Triple DES 168/168' to 'Triple DES 168'. Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-2886](#) (Enable 'AES 128/128' Cipher Suites):** Import from CIS; modified *Rationale* and *Description* section; added an exemption. Changed during review: Encryption-Mode AES128 is also allowed, only CBC-Mode must be disabled. Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-4481](#) (Enable 'AES 256/256' Cipher Suites):** Import from CIS; modified *Description* section. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-2563](#) (Disable 'MD5' Hashing Algorithm):** Rule based on IIS 8.x measure M383360. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-2544](#) (Disable 'SHA-1' Hashing Algorithm):** Rule based on IIS 8.x measure M383360. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.
- **Created [BL115-2386](#) (Ensure sufficient 'Modulus Size in the DHE Key Exchange'):** Rule based on IIS 8.x measure M383386. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

- **Created [BL115-4906](#) (Configure TLS Cipher Suite Ordering):** Import from CIS; specified the rule more precisely; added an exemption. Added reboot note to the *Implementation* section. Added GPO implementation example. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

Compared to the *Security Measure Plan for Internet Information Services 8.x, version 2.4* the following rules have been removed:

- **M383633 Installation of the operating system**
The secure configuration of the Operating System is already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383402 Implement Relevant Security Updates**
The installation of relevant security updates is already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383319 Web Application Pools**
The important parts of this rule are more precisely covered by [BL115-5216](#), and [BL115-3321](#). The remaining parts were too generic as that it would make sense to have a separate rule for it.
- **M383580 Request handler mappings**
The important parts of this rule are more precisely covered by [BL115-3691](#), [BL115-1951](#), [BL115-1952](#), and [BL115-1953](#). The remaining parts were too generic as that it would make sense to have a separate rule for it.
- **M383351 User Accounts and Anonymous Authentication**
The important parts of this rule are more precisely covered by [BL115-1891](#), and [BL115-3081](#). The remaining parts were too generic as that it would make sense to have a separate rule for it.
- **M383842 User authentication**
The user authentication is covered in various other rules. The remaining parts were too generic as that it would make sense to have a separate rule for it.
- **M383360 Configure Protocols and Ciphers**
The protocol and cipher settings were divided in multiple rules.
- **M383524 Disable TLS 1.0 and TLS 1.1 in Schannel (ACP 3)**
The TLS 1.0 and 1.1 settings were divided in two rules and are now relevant for all ACP levels.
- **M383842 Configure TLS/SSL settings**
The configuration of TLS/SSL settings is covered in various other rules. The remaining parts were either too generic or became obsolete as that it would make sense to have a separate rule for it.
- **M383617 Configure WebDAV**

This rule has been removed as we request the disabling of WebDAV (see [BL115-0784](#)).

- **M383195 Secure Web server administration and feature delegation**
The *Least Privilege Principle* as well as the *Segregation of Duties* are already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383114 Monitor the log files**
The monitoring of log files is already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383999 Perform Web server vulnerability scans**
The scanning for vulnerabilities is already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383708 Backup the Web server**
The backup of servers is already demanded by the *Siemens Information Security Policy Framework* so there is no need to add a separate rule for it.
- **M383982 Configure IP or domain based access restriction**
The measure was too generic as it would make sense to add a separate rule for it.
- **M383349 Set X-XSS-Protection**
No browser except Internet Explorer 8 (and Safari) supports this feature anymore. As IE 8 is not supported by Microsoft as well; it does not make sense to keep this rule. If you want to be secured against XSS you should **not** use the directives `unsafe-eval` or `unsafe-inline` in your *Content Security Policy* (see [BL115-0514](#)).

Table of Contents

Current release	2
Document History	2
Change Log in the Current Version	2
Table of Contents	7
Introduction	10
Objectives	10
Scope and Applicability	10
Roles and Responsibilities	10
Information Security Policy Framework	11
Readability	11
Basic Configurations	13
BL115-0521 - Enable only Required IIS Features	13
BL115-0660 - Enable only Required Web Service Extensions	15
BL115-0172 - Subscribe to the Cybersecurity Governance Announcement Service	17
BL115-0304 - Disable File and Printer Sharing	18
BL115-5716 - Ensure Web Content is on a Non-System Partition	20
BL115-0725 - Configure a Unique Binding	23
BL115-2921 - Ensure Host Headers are Used	25
BL115-3481 - Ensure Directory Browsing is set to Disabled	27
BL115-5216 - Configure 'Application Pool Identity' for all Application Pools	29
BL115-3321 - Ensure 'Unique Application Pools' is set	33
BL115-3081 - Configure 'Application Pool Identity' for Anonymous User Identity	35
BL115-0784 - Disable WebDav Feature	37
Configure Authentication and Authorization	38
BL115-5251 - Ensure 'Global Authorization Rule' is set	38
BL115-1891 - Restrict Access to Sensitive Site Features	41
BL115-1426 - Ensure 'Forms Authentication' is set to Require SSL	44
BL115-3491 - Ensure 'Forms Authentication' is set to use Cookies	46
BL115-5401 - Ensure 'Cookie Protection Mode' is Configured for Forms Authentication	48
BL115-2711 - Ensure Transport Layer Security for 'Basic Authentication' is Configured	50
BL115-3161 - Ensure 'passwordFormat' is set to 'SHA256' or Higher	52
BL115-3661 - Ensure 'Credentials' are not Stored in Configuration Files	54
BL115-0846 - Set NTFS File System Permissions on Web Content Folders	56
BL115-0847 - Restrict Access to Built-In Executables	58
ASP.NET Configuration	59
BL115-5046 - Ensure 'Deployment Method Retail' is set	59
BL115-4166 - Ensure 'Debug' is Turned off	61

BL115-5726 - Ensure Custom Error Messages are set to On	63
BL115-4476 - Ensure IIS HTTP Detailed Errors are set to Custom	65
BL115-1801 - Ensure ASP.NET Stack Tracing is not Enabled	67
BL115-1271 - Ensure 'httpcookie' Mode is Configured for Session State	70
BL115-3336 - Ensure 'Cookies' are set with HttpOnly Attribute	72
BL115-9971 - Ensure 'Cookies' are set with RequireSSL to True	74
BL115-3216 - Ensure 'MachineKey Validation Method - .NET 3.5' is Configured for SHA1	76
BL115-4876 - Ensure 'MachineKey Validation Method - .NET 4.5' is configured for SHA-2 Methods	78
BL115-2731 - Ensure Global .NET Trust Level is Configured	80
BL115-4911 - Ensure X-Powered-By Header is removed	83
BL115-8201 - Ensure Server Header is removed	85
BL115-2596 - Remove the Unwanted X-AspNet-Version Header	87
BL115-1295 - Set the Maximum Execution Time for File Uploads	89
BL115-5223 - Set the Maximum Request Size for File Uploads	91
Request Filtering and Other Restriction Modules	93
BL115-4236 - Ensure 'maxAllowedContentLength' is Configured	93
BL115-3256 - Ensure 'maxURL Request Filter' is Configured	96
BL115-3496 - Ensure 'MaxQueryString Request Filter' is Configured	98
BL115-4416 - Ensure Non-ASCII Characters in URLs are not Allowed	100
BL115-1391 - Ensure Double-Encoded Requests will be Rejected	102
BL115-1951 - Ensure 'HTTP Trace Method' is Disabled	104
BL115-1952 - Ensure 'HTTP Options Method' is Disabled	106
BL115-1953 - Ensure 'HTTP Connect Method' is Disabled	108
BL115-5851 - Ensure Unlisted File Extensions are not allowed	110
BL115-3691 - Ensure Handler is not Granted Write and Script/Execute	113
BL115-1046 - Ensure 'notListedIsapisAllowed' is set to False.	115
BL115-5466 - Ensure 'notListedCgisAllowed' is set to False	117
BL115-4641 - Ensure 'Dynamic IP Address Restrictions' is Enabled	119
BL115-3243 - Block SQL Injections	121
BL115-4971 - Deny Directory Traversal	127
BL115-4972 - Deny Alternate Data Streams	129
BL115-4973 - Deny Backslashes in URLs	131
IIS Logging	133
BL115-5441 - Ensure Default IIS web log location is moved	133
BL115-4386 - Configure Enhanced Logging for IIS	135
BL115-3441 - Ensure 'ETW Logging' is Enabled	138
BL115-0987 - Ensure 'IIS-Configuration' Logging is Enabled	140
BL115-1957 - Ensure Default FTP log location is moved	142
BL115-1956 - Ensure 'FTP Logging' is enabled	144
BL115-0192 - Ensure 'NTFS Auditing' is Enabled	147
FTP Requests	149
BL115-0356 - Configure FTP Securely	149

BL115-4651 - Ensure FTP Requests are Encrypted	151
BL115-1256 - Configure FTP Logon Attempt Restrictions	153
Transport Encryption	156
BL115-0621 - Ensure the Usage of HTTPS	157
BL115-0371 - Ensure Secure Certificate Handling	158
BL115-4471 - Configure HSTS Header	161
BL115-5956 - Disable 'SSL 2.0' Protocol	164
BL115-2561 - Disable 'SSL 3.0' Protocol	167
BL115-2691 - Disable 'TLS 1.0' Protocol	170
BL115-3386 - Disable 'TLS 1.1' Protocol	173
BL115-1156 - Enable 'TLS 1.2' Protocol	176
BL115-4921 - Disable 'NULL' Cipher Suites	179
BL115-5881 - Disable 'DES' Cipher Suites	181
BL115-4837 - Disable 'RC2' Cipher Suites	183
BL115-4836 - Disable 'RC4' Cipher Suites	185
BL115-1386 - Disable 'Triple DES' Cipher Suites	188
BL115-2886 - Enable 'AES 128/128' Cipher Suites	190
BL115-4481 - Enable 'AES 256/256' Cipher Suites	192
BL115-2563 - Disable 'MD5' Hashing Algorithm	194
BL115-2544 - Disable 'SHA-1' Hashing Algorithm	196
BL115-2386 - Ensure sufficient 'Modulus Size in the DHE Key Exchange'	198
BL115-4906 - Configure TLS Cipher Suite Ordering	201
HTTP Headers	205
BL115-0514 - Configure Content Security Policy	205
BL115-8551 - Configure Frame-ancestors	209
BL115-0928 - Configure X-Frame-Options	212
BL115-0800 - Configure MIME-Handling Security	215
Definitions	217
Glossary	218
References	219

Introduction

Objectives

The objective of this document is to define the rules which provide a secure configuration, increase the overall security level, and reduce the attack surface and vulnerability exposure of platforms, systems and applications.

The Security Measure Plan for Internet Information Services 10 (IIS 10) is an *Information Security Baseline* that is part of the *Siemens Information Security Policy Framework* [1].

Scope and Applicability

This Security Measure Plan sets the mandatory hardening rules for Microsoft Internet Information Services 10 (IIS 10) on Windows Server 2016 as well as on Windows Server 2019.

The *Security Measure Plan* is binding for all units of Siemens AG and applies to Siemens' Affiliated Companies in accordance with Siemens Circular No. 105 "Implementation of Siemens-internal regulations in Affiliated Companies" [2], whereas separate agreements apply to listed Equity Investments.

This *Security Measure Plan* is based on the Center of Internet Security (CIS) benchmark *CIS Microsoft IIS 10 Benchmark, version 1.1.1.*, as well as it contains security rules from the Siemens *Security Measure Plan for Microsoft Internet Information Services 8.x, version 2.4*, which are not covered by the CIS benchmark. Divergent rules from the CIS benchmark have been adapted to the needs of Siemens. You can find the source of the information in the *Cross-references* section as well as in the *Version History* which additionally lists substantial changes to the source.

Although the CIS benchmark uses the term *Recommendation* in some rules, the rule itself remains mandatory.

Listings in this Security Measure Plan

Listings using the following format

```
<sample code>
```

Listing: BL115-9999_[C|I]99_99.ps1

are extracted into separate files (having the *Listing* title as file name). The filename uses the following syntax

RuleNumber_Implementation|CheckSection_AscendingNumber.FileExtension

All scripts are stored into a single ZIP archive file and can be used as a starting point for your own implementation. You can download the ZIP archive file at

https://siemens.sharepoint.com/teams/CybersecurityGovernance/Policies/Scripts_Microsoft_IIS_10.zip

Roles and Responsibilities

Throughout this document, the following roles are used to assign responsibilities for the implementation of the rules:

- [Asset Manager](#).

Information Security Policy Framework

All Information Security rules and regulations at Siemens are documented and further detailed in the Information Security Policy Framework. It lays down the roles and responsibilities, and the set of rules and practices that regulate how Siemens and its affiliated companies protect the company information and business processes.

Details regarding the Policy Framework can be found on the [Cybersecurity Governance Website](#).

Readability

The rules in this document are structured as follows:

- **Header** Each rule starts with a header containing the following information:
 - **Rule ID:** The left-hand side of the header displays the unique identifier of the rule to be used for referencing the rule from other documents. The identifier *BLxxx-yyyy* is divided in two parts, of which the first part *BLxxx* represents the document identifier, and the second part *yyyy* constitutes a unique rule identifier within the document.
 - **Target Audience:** Directly under the Rule ID, one or more roles (as defined in the Siemens Information Security Framework) are displayed. These roles are responsible for implementing the rule.
 - **EVAL flag and date:** If a rule is under evaluation, an EVAL flag and the end date of the evaluation period is displayed to the right of the Rule ID. The evaluation period shall be used to:
 - Communicate the new version of the Security Measure Plan to the relevant teams,
 - Identify the rules applicable to your area of responsibility,
 - Evaluate and plan all necessary changes to the contractual agreements with involved Service providers (e.g., SLAs, contract changes),
 - Plan and define a strategy to implement the rules (e.g., identify possible issues, allocate proper resources),
 - Update all related existing documents, processes, and procedures,
 - Deploy all necessary changes to all affected systems within your area of responsibility.The rule will become binding after the end of the evaluation period. An expired EVAL flag will only be removed from the rule once an update to the document is available.
 - **ACP Level:** The **ACP** level is indicated on the right-hand side of the header; the rule is applicable to those systems whose **ACP** rating falls into levels as displayed in the rule header. The semantics is as follows: if at least one of the **ACP** levels *Confidentiality* (C), *Integrity* (I), or *Availability* (A) of a system match with the **ACP** level displayed in the rule's header, then the rule must be implemented for the system in question. In case of conflicting rules, the rule with the higher **ACP** rating shall be implemented.
 - **Rule:** This Section describes the essence of the rule and is to be considered as normative *binding part of the rule*.
- **Additional normative sections (apart from 'Rule' Section of the header) :**
 - **Exemption (if applicable):** This Section indicates under which circumstances a rule may not apply. If the conditions of the exemption are met, no Information Security exception for this rule deviation is required. Each exemption has a relative id, e.g. E01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:E01.

- **Informative Sections:**

- **Description:** The description provides information which helps the readers to understand the rule.
- **Rationale:** This Section provides information about the rationale behind the rule. It should, for example, help Asset Managers to evaluate requests for rule exceptions.
- **Implementation Example:** This Section provides descriptions and examples on how to implement the rule. Please note that this is only an example on how to implement, the demand stated in the Rule Section may also be implemented by other means. Each implementation has a relative id, e.g. I01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:I01.
- **Check Example (optional):** This Section provides descriptions and examples on how to check the rule implementation. Please note that this is only an example on how to check the implementation. Each check has a relative id, e.g., C01, so that it can be referenced in conjunction with the Rule ID as, e.g., BL123-1234:C01.
- **Cross references (optional):** This Section provides cross references to other rules (inside or outside the Siemens Information Security Framework). Cross references may, for example, inform about the rules the rule in question is based upon.

- **Additional Metadata**

- **Version History:** This Section provides version history information of the rule: In a PDF export, only the latest entry is shown, contrary to the [SFeRA](#) website which holds the complete version history.

Basic Configurations

This section contains basic Web server-level recommendations.

BL115-0521

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Enable only Required IIS Features

Rule Enable only those IIS features which are required to provide the desired service.

Note: The default configuration can but does not need to be reduced any further. For any other modules make sure to only install them, if required.

Description

IIS 10.x bases on a modular architecture with approximately 50 modules. Some are installed by default, others might be installed additionally.

By default the following features are installed on each IIS 10.x installation (Windows Server 2016):

- Default Document (Common HTTP Features)
- Directory Browsing (Common HTTP Features)
- HTTP Errors (Common HTTP Features)
- Static Content (Common HTTP Features)
- HTTP Logging (Health and Diagnostics)
- Static Content Compression (Performance)
- Request Filtering (Security)
- IIS Management Console (Management Tools)

Rationale

To run the Web server as secure as possible the attack surface of the system has to be kept small. Therefore, it is important to install only features that are necessary for a particular system or application.

I01 - GUI Implementation Example

1. Open the Server Manager.
2. Select `Add roles and features` to start the wizard.
3. When asked for the server roles, scroll down and select `Web Server (IIS)`.
4. The installation of IIS 10.x requires an additional feature called `(Tools) IIS Management Console` to be installed, but not necessarily on the same server. If you want to manage IIS on the same server, confirm it by clicking `Add features` and proceed with the next steps in the wizard.
5. Select the role services to install for the Web Server (IIS). Install only the required components on

the machine.

6. Confirm the installation of the Web server with all selected components by clicking `Install`.

I02 - PowerShell Implementation Example

To see all available features, open an administrative PowerShell window:

```
Get-WindowsOptionalFeature -Online | where FeatureName -like 'IIS-*
```

Listing: BL115-0521_I02_01.ps1

To enable a needed feature:

```
Enable-WindowsOptionalFeature -Online -FeatureName 'IIS-<Feature>'
```

Listing: BL115-0521_I02_02.ps1

To disable an installed feature:

```
Disable-WindowsOptionalFeature -Online -FeatureName 'IIS-<Feature>'
```

Listing: BL115-0521_I02_03.ps1

Note:

- The `-online` parameter indicates that the actions will run on the current device.

C01 - PowerShell Check Example

To list all installed IIS features, open an administrative PowerShell window:

```
Get-WindowsOptionalFeature -Online -FeatureName *IIS* | where {$_.state -eq "Enabled"} | ft
```

Listing: BL115-0521_C01_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383521

BL115-0660

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Enable only Required Web Service Extensions

Rule Enable only those Web service extensions which are required to provide the desired service.

Description

The default installation of IIS 10.x is configured to serve static content only. By default, dynamic content is not permitted. Therefore, Web service extensions like Active Server Pages, ASP.NET, CGI, Server Side Includes or ISAPI extensions have to be enabled additionally. These technologies typically provide a way to perform dynamic operations that result in the creation of HTML output, which IIS then sends to fulfill client requests.

Various IIS features are added to the server by enabling the corresponding features. The Server Manager on Windows Server 2016 groups the available Web service extensions under the collective term `Application Development`. Technologies available are:

- Application Initialization
- ASP
- ASP.NET (.NET Core, .NET Framework, .NET Extensibility)
- CGI
- ISAPI Extensions
- ISAPI Filters
- Server Side Includes
- WebSocket Protocol

Rationale

Unnecessarily enabled Web service extensions raise the attack surface of a system and therefore increases the security risk for the Web server.

I01 - GUI Implementation Example

1. Open the Server Manager.
2. Click on `Manage` (in the upper right corner) and select `Add Roles and Features`.
3. In the Wizard window select on the left side `Server Selection`, and then `Server Roles`.
4. Scroll down to the entry `Web Server (IIS)` and expand it by clicking the arrow shown left to the entry.
5. Expand `Web Server` in the list, and then `Application Development` to enable only the required Web service extensions.

I02 - PowerShell Implementation Example

Open an administrative PowerShell window:

Enable Application Development

```
Enable-WindowsOptionalFeature -Online -FeatureName IIS-ApplicationDevelopment
```

Listing: BL115-0660_I02_01.ps1

List all SubFeatures for Application Development

```
$features = Get-WindowsFeature Web-App-Dev  
$subFeatures = $features.SubFeatures -split " "  
$subFeatures
```

Listing: BL115-0660_I02_02.ps1

Enable the necessary SubFeatures

```
Install-WindowsFeature <NameofSubFeature>
```

Listing: BL115-0660_I02_03.ps1

Disable SubFeatures

```
Remove-WindowsFeature <NameofSubFeature>
```

Listing: BL115-0660_I02_04.ps1

C01 - PowerShell Check Example

Open an administrative PowerShell window:

List of installed Features

```
Get-WindowsFeature | Where Installed
```

Listing: BL115-0660_C01_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383660. Changed during review: Added to the description .NET Core and .NET Framework.

BL115-0172

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Subscribe to the Cybersecurity Governance Announcement Service

Rule

Subscribe to the *Cybersecurity Governance Announcement Service*.

Description

The *Cybersecurity Governance Announcement Service* is being used to notify subscribers about

- Changes in the Information Security policy framework which require mandatory actions (e.g., update of Information Security regulations),
- Specific Software vulnerabilities which require mandatory actions contrary to the standard process (e.g., a vulnerability is being exploited within Siemens and requires immediate remediation),
- Any other topics related to Cybersecurity Governance.

Rationale

A system responsible who does not subscribe to this service will not be informed about important security relevant notifications which require mandatory actions. This may end up in an insecure system being misused by attackers.

I01 - Implementation Example

Siemens *Cybersecurity Governance* offers an Intranet page which lists all valid *Cybersecurity Governance Announcements* at

<https://intranet.siemens.com/seg-announcement/>.

On that webpage you also find the possibility to subscribe to the announcement service with a valid email address and Siemens GID.

C01 - Checking your subscription to the Cybersecurity Governance Announcement Service

Visit the Intranet page at <https://intranet.siemens.com/seg-announcement/> and select under *Quick Links* the topic *Manage Subscription*. The upcoming webpage will let you know if you are subscribed to this service or not.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383172

BL115-0304

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Disable File and Printer Sharing

Rule

Disable the *File and Printer Sharing for Microsoft Networks* component.

E01 - Web servers in a demilitarized zone

There are server applications (like Exchange Server, SharePoint Server, SCOM) which may require this component for correct operation (e.g., clustered IIS system).

For web servers in a **demilitarized zone** (DMZ), use a second physical interface, disable the *File and Printer Sharing for Microsoft Networks* component on the Internet facing interface and secure the other interface by setting correct folder/sharing permissions and/or firewall rules.

Note: Ensure that you have a valid business reason for the exemption and appropriate security measures are taken and documented.

E02 - Web servers in the Intranet

There are server applications (like Exchange Server, SharePoint Server, SCOM) which may require this component for correct operation (e.g., clustered IIS system).

For web servers in the **Intranet**, set at the minimum restrictive folder and sharing permissions as outlined in the *Security Measure Plan for Microsoft Windows Servers*. Consider to set firewall rules in addition to restrict access to the interfaces.

Note: Ensure that you have a valid business reason for the exemption and appropriate security measures are taken and documented.

Description

A computer which has the *File and Printer Sharing for Microsoft Networks* component installed allows other computers on the network to access its local resources by using protocols such as SMB (Server Message Block).

If this feature is used in terms of content management, check for alternative solutions. Shares or content can also be provided on dedicated file servers. Disabling this component still allows mounting other shares.

Rationale

Disabling this component effectively reduces the attack surface since related services are often used for host enumeration and several other attacks.

I01 - GUI Implementation Example

1. Open the *Network and Sharing Center*.

2. Select Change adapter settings, right-click on the network interface and choose Properties.
3. Uncheck the File and Printer Sharing for Microsoft Networks check box and confirm with OK.

I02 - PowerShell Implementation Example

Open an administrative PowerShell window:

```
# Please enter the name of your network interface
# Hint: Use the PowerShell command Get-NetAdapter to list the name
$NetAdapter = "<Name of your network interface>"
Disable-NetAdapterBinding -Name $NetAdapter -DisplayName "File and Printer Sharing for Microsoft Networks"
```

Listing: BL115-0304_I02_01.ps1

C01 - GUI Check Example

1. Open the *Network and Sharing Center*.
2. Select Change adapter settings, right-click on the network interface and choose Properties.
3. Verify that the File and Printer Sharing for Microsoft Networks check box is not selected.
4. Close the dialog box by clicking on Cancel.

C02 - PowerShell Check Example

Open an administrative PowerShell window:

```
# Please enter the name of your network interface
# Hint: Use the PowerShell command Get-NetAdapter to list the name
$NetAdapter = "<Name of your network interface>"
Get-NetAdapterBinding -Name $NetAdapter -DisplayName "File and Printer Sharing for Microsoft Networks"
| fl DisplayName, Enabled
```

Listing: BL115-0304_C02_01.ps1

The output should list the status of the net adapter binding Enabled: False.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383304; removed the hint about WebDAV as there are security concerns with WebDAV (see BL115-0784).

BL115-5716

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Web Content is on a Non-System Partition

Rule

Ensure web content is not stored on the system-partition.

E01 - Exemption

The rule can be omitted, if a server application requires having the web content stored on the system volume (e.g., Exchange and SharePoint Server which use IIS as a core service component).

Description

IIS creates the default directory for website content on the same volume as the operating system (%SystemDrive%\inetpub\wwwroot). This default directory is well known and might therefore be a target of an attack. Web resources published through IIS are mapped, via Virtual Directories, to physical locations on disk.

Rationale

Isolating web content from system files may reduce the probability of:

- Web sites/applications exhausting system disk space regarding availability (DoS)
- File I/O vulnerability in the website/application from affecting the confidentiality and/or integrity of system files
- Directory traversal attack (aka dot dot slash attack or directory climbing). Directory traversal attacks occur when an attacker sends a request for a file that is located in different directory structure on the Web server. If attackers might, for example, be able to make a request to %systemroot%\System32\cmd.exe, they could possibly invoke the command prompt - assuming that appropriate security settings are missing.

I01 - Implementation Example

1. Create a disk volume or designate an existing disk volume using NTFS where the Web content will be stored. Configure the NTFS permissions on the root of this disk volume so that the groups "Administrators" and "System" have Full Control. All other permissions should be removed.
2. Copy the default folder from the system volume to the designated volume by issuing following command in an administrative shell:

```
xcopy %SystemDrive%\inetpub\wwwroot <new drive letter>:\inetpub\wwwroot /E /O /I
```

Listing: BL115-5716_I01_01.cmd

3. Change mapping for the Default Web Site to reflect the new location. Run the following script in an administrative PowerShell window:

```
Import-Module WebAdministration
# Please enter your <new drive letter> and
# your <destination path> without trailing \
$DestPath = "<new drive letter>:\<destination path>"
# Please enter your application or virtual directory with a leading \
# If no application or virtual directory is required leave $DestApp empty
$DestApp = ""
$DestPathFull = $DestPath + $DestApp
Set-ItemProperty 'IIS:\Sites\Default Web Site' -name physicalPath -value $DestPathFull
```

Listing: BL115-5716_I01_02.ps1

Alternatively, open IIS Manager:

1. Expand the server node.
 2. Expand Sites.
 3. Expand Default Web Site.
 4. In the Actions pane, select Basic Settings.
 5. In the Physical path text box, put the new location of the root web folder, e.g.,
D:\Newlocation\inetpub\wwwroot.
4. As there exist application(s) which read the default path of the Web content root folder from the registry, following settings need to be adjusted as well.

```
# Please enter your <new drive letter> and
# your <destination path> without trailing
# Hint: Use the setting from above script
$DestPath = "<new drive letter>:\<destination path>"
New-ItemProperty -path 'HKLM:\Software\Microsoft\inetstp' -name 'PathWWWRoot' -value $DestPath -
PropertyType 'String' -Force | Out-Null
New-Item 'HKLM\Software\Wow6432Node\Microsoft\inetstp' -Force | Out-Null
New-ItemProperty -path 'HKLM:\Software\Wow6432Node\Microsoft\inetstp' -name 'PathWWWRoot' -value
$DestPath -PropertyType 'String' -Force | Out-Null
```

Listing: BL115-5716_I01_03.ps1

Note: After you have changed the settings in the registry, you need to restart the operating system.

C01 - Command Line Check Example

Execute the following command to ensure no virtual directories are mapped to the system drive: To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list vdir
```

Listing: BL115-5716_C01_01.cmd

C02 - PowerShell Check Example

Execute the following command to ensure no virtual directories are mapped to the system drive: To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-Website | Format-List Name, PhysicalPath
```

Listing: BL115-5716_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

CIS rule merged with IIS 8.x measure M383337

BL115-0725

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure a Unique Binding

Rule Configure a unique binding by providing

- A unique IP address,
- A unique port number,

for the protocols http, https, and ftp (if they are enabled).

E01 - Protocols which are not bound to specific IP addresses

The *Site Bindings* dialog box may list additional protocols which are used by applications for their specific communication which are not bound to any IP address (e.g., net.tcp). For these protocols you do not need to apply this rule.

E02 - Exchange Server installations

For Exchange Server installations, the implementation of this rule is not possible for *Client Access Servers* and *Mailbox Servers*.

E03 - SharePoint installations

For SharePoint installations, the implementation of this rule is not possible for the website that hosts SharePoint's service applications (by default: *SharePoint Web Services*).

Description

When creating a new website, IIS listens on all available interfaces and configured IP addresses of the web server for connections by default. Furthermore, IIS serves all requests for all enabled protocols, regardless of the host header specified. The combination of protocol, IP address, port number and optionally host header is called binding and can be configured per website.

Rationale

For servers with multiple interfaces or with multiple assigned IP addresses, it makes sense to have IIS binding to specific IP addresses only. This helps separating websites (such as administrative web applications) from certain networks and makes firewall configuration easier (since IIS listens on certain IP addresses only). Binding specifies the allowed hostnames served by IIS and therefore reduces the attack surface.

I01 - GUI Implementation Example

Perform these steps for all enabled protocols (http, https, and ftp):

1. Open the IIS Manager.
2. Select the corresponding website in the `Connections` pane.
3. Select `Bindings` in the `Actions` pane.
4. In the `Site Bindings` dialog box, select the corresponding protocol in the `Type` column, and then click `Edit`.
5. Enter the required `IP` address for the server's website.

Note: The field `Host name` in the dialog box is covered by rule [BL115-2921](#).

I02 - PowerShell Implementation Example

Enter the following command in PowerShell to set a unique binding:

```
Import-Module WebAdministration
Set-WebBinding -Name '<Name of the Web Site>' -BindingInformation '<old IP Address>:<old Port number>:'
<Host Header>' -PropertyName IPAddress -Value <new IP Address>
```

Listing: BL115-0725_I02_01.ps1

Enter the following command in PowerShell to set a unique unique Port:

```
Import-Module WebAdministration
Set-WebBinding -Name '<Name of the Web Site>' -BindingInformation '<old IP Address>:<old Port number>:'
<Host Header>' -PropertyName Port -Value <new Port>
```

Listing: BL115-0725_I02_02.ps1

C01 - PowerShell Check Example

Enter the following command in PowerShell to see the unique bindings:

```
Import-Module WebAdministration
Get-WebBinding -Name '<Name of the Web Site>'
```

Listing: BL115-0725_C01_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383725; specified rule more precisely; removed host header requirement as this is covered by BL115-0725. Changed during review: Corrected and added additional script in *Implementation 02*.

BL115-2921

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Host Headers are Used

Rule

Ensure 'host headers' are used on all sites.

Description

Host headers provide the ability to host multiple websites on the same IP address and port. It is recommended that host headers be configured for all sites. Wildcard host headers are now supported.

Rationale

Requiring a 'host header' for all sites may reduce the probability of:

- DNS rebinding attacks compromising or abusing site data or functionality
- IP-based scans identifying or interacting with a target application hosted on IIS

Note: If a wildcard DNS entry exists and a wildcard host header is used, you may be serving data to more domains than intended.

I01 - Command Line Implementation Example

Enter the following command in AppCmd.exe to configure the host header:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.applicationHost/sites /"[name='<website name>'].bindings.[protocol='http',bindingInformation='*:80:<host header>'].bindingInformation='*:80:<host header>'" /commit:apphost
```

Listing: BL115-2921_I01_01.cmd

I02 - GUI Implementation Example

Perform the following in IIS Manager to configure host headers for the Default Web Site:

1. Open IIS Manager
2. In the Connections pane expand the Sites node and select Default Web Site
3. In the Actions pane click Bindings
4. In the Site Bindings dialog box, select the binding for which host headers are going to be configured, Port 80 in this example
5. Click Edit
6. Under Host name, enter the site's FQDN, such as <www.examplesite.com>
7. Click OK, then Close

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure the host header:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
'system.applicationHost/sites/site[@name='<website name>']/bindings/binding[@protocol='http' and
@bindingInformation='*:80:']' -name 'bindingInformation' -value '*:80:<host header value>'
```

Listing: BL115-2921_I03_01.ps1

C01 - Command Line Check Example

Execute the following command to identify sites that are not configured to require host headers: To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list sites
```

Listing: BL115-2921_C01_01.cmd

Note: All sites will be listed as such:

```
SITE "Default Web Site" (id:1,bindings:http/*:80:test.com,state:Started)
SITE "badsite" (id:3,bindings:http/*:80:,state:Started)
```

For all non-SSL sites, ensure that the *IP:port:host* binding triplet contains a host name. In the example above, the first site is configured as recommended given the Default Web Site has a host header of test.com. badsite, however, does not have a host header configured - it shows *:80: which means all IPs over port 80, with no host header.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebBinding -Port * | Format-List bindingInformation
```

Listing: BL115-2921_C02_01.ps1

Note: All sites will be listed as such:

```
SITE "Default Web Site" (id:1,bindings:http/*:80:test.com,state:Started)
SITE "badsite" (id:3,bindings:http/*:80:,state:Started)
```

For all non-SSL sites, ensure that the *IP:port:host* binding triplet contains a host name. In the example above, the first site is configured as recommended given the Default Web Site has a host header of test.com. badsite, however, does not have a host header configured - it shows *:80: which means all IPs over port 80, with no host header.

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Changed during review: Added missing '>' in the Implementation script 01.

BL115-3481

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Directory Browsing is set to Disabled

Rule

Ensure 'directory browsing' is set to disabled.

Description

Directory browsing allows the contents of a directory to be displayed upon request from a web client. If directory browsing is enabled for a directory in Internet Information Services, users receive a page that lists the contents of the directory when the following two conditions are met:

1. No specific file is requested in the URL
2. The Default Documents feature is disabled in IIS, or if it is enabled, IIS is unable to locate a file in the directory that matches a name specified in the IIS default document list

Rationale

Ensuring that directory browsing is disabled reduces the probability of disclosing sensitive content that is inadvertently accessible via IIS.

I01 - Command Line Implementation Example

Directory Browsing can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To disable directory browsing at the server level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:directoryBrowse /enabled:false
```

Listing: BL115-3481_I01_01.cmd

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -Filter system.webserver/directorybrowse -PSPath iis:\ -Name Enabled -  
Value False
```

Listing: BL115-3481_I02_01.ps1

C01 - Command Line Check Example

Perform the following to verify that Directory Browsing has been disabled at the server level:

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:directoryBrowse
```

Listing: BL115-3481_C01_01.cmd

If the server is configured as recommended, the following will be displayed:

```
<system.webServer>
  <directoryBrowse enabled="false" />
</system.webServer>
```

Listing: BL115-3481_C01_02.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -Filter system.webserver/directorybrowse -PSPath iis:\ -Name Enabled |
select Value
```

Listing: BL115-3481_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.3

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS and former IIS 8.x measure M383683.

BL115-5216

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Application Pool Identity' for all Application Pools

Rule

Ensure 'Application Pool Identity' is configured for all application pools.

E01 - Exemption

If there is an application pool that needs to run as a specified end user account (e.g., web farms using Kerberos authentication) then this allowed. However, if technically possible, you must ensure that for every affected application pool a different end user account will be used. Also, it needs to be ensured that the end user account has only the minimal required access rights, following the least privilege principle.

In this case the reasons for the change have to be documented accordingly.

Description

Application Pool Identities are the actual users/authorities that will run the worker process `w3wp.exe`. Assigning the correct user authority will help ensure that applications can function properly, while not giving overly permissive permissions on the system. These identities can further be used in ACLs to protect system content. It is recommended that each Application Pool run under a unique identity.

IIS has additional built-in least privilege identities intended for use by Application Pools. It is recommended that the default *Application Pool Identity* be changed to a least privilege principal other than *Network Service*. Furthermore, it is recommended that all *Application Pool Identities* be assigned a unique least privilege principal.

To achieve isolation in IIS, application pools can be run as separate identities. IIS can be configured to automatically use the *Application Pool Identity* if no anonymous user account is configured for a Web site. This can greatly reduce the number of accounts needed for Web sites and make management of the accounts easier. It is recommended the *Application Pool Identity* be set as the Anonymous User Identity.

Note: In IIS 7, worker processes run as *Network Service* by default. This has been changed by Microsoft in Windows Server 2008 SP2 with IIS 7.5 as other services also run under this account risking that these services could interfere with others. The newly created identity `ApplicationPoolIdentity` has the big advantage that for every newly created application pool the *IIS Admin Process* will create a virtual account. This virtual account has the name of the new application pool and the worker process of this application pool will run under this account.

Rationale

Setting Application Pools to use unique least privilege identities such as `ApplicationPoolIdentity` reduces the potential harm the identity could cause, should the application ever become compromised.

Additionally, it will simplify application pools configuration and account management.

I01 - GUI Implementation Example

The default *Application Pool Identity* may be set for an application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to change the default identity to the built-in `ApplicationPoolIdentity` in the IIS Manager GUI:

1. Open the IIS Manager GUI
2. In the connections pane, expand the server node and click Application Pools
3. On the Application Pools page, select the `DefaultAppPool`, and then click Advanced Settings in the Actions pane
4. For the Identity property, click the '...' button to open the *Application Pool Identity* dialog box
5. Select the Built-in account option choose `ApplicationPoolIdentity` from the list or input a unique application user created for this purpose
6. Restart IIS

The example procedure above will set just the `DefaultAppPool`. Run this procedure for each configured Application Pool.

If using a custom defined Windows user such as a dedicated service account, that user will need to be a member of the `IIS_IUSRS` group. The `IIS_IUSRS` group has access to all the necessary file and system resources so that an account, when added to this group, can seamlessly act as an *Application Pool Identity*.

I02 - Command Line Implementation Example

To change the `ApplicationPool` identity to the built-in `ApplicationPoolIdentity` using `AppCmd.exe`, run the following from a command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:applicationPools /[name='<your apppool>'].processModel.identityType:ApplicationPoolIdentity
```

Listing: BL115-5216_I02_01.cmd

The example code above will set just the `DefaultAppPool`. Run this command for each configured Application Pool. Additionally, `ApplicationPoolIdentity` can be made the default for all Application Pools by using the Set Application Pool Defaults action on the Application Pools node.

If using a custom defined Windows user such as a dedicated service account, that user will need to be a member of the `IIS_IUSRS` group. The `IIS_IUSRS` group has access to all the necessary file and system resources so that an account, when added to this group, can seamlessly act as an *Application Pool Identity*.

I03 - PowerShell Implementation Example

To change the `ApplicationPool` identity to the built-in `ApplicationPoolIdentity` using PowerShell:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
'system.applicationHost/applicationPools/add[@name='<apppool name>']/processModel' -name 'identityType'
-value 'ApplicationPoolIdentity'
```

Listing: BL115-5216_I03_01.ps1

The example code above will set just the `DefaultAppPool`. Run this command for each configured Application Pool. Additionally, `ApplicationPoolIdentity` can be made the default for all Application Pools by using the Set Application Pool Defaults action on the Application Pools node.

If using a custom defined Windows user such as a dedicated service account, that user will need to be a member of the `IIS_IUSRS` group. The `IIS_IUSRS` group has access to all the necessary file and system resources so that an account, when added to this group, can seamlessly act as an *Application Pool Identity*.

C01 - GUI Check Example

To verify the Application Pools have been set to run under the `ApplicationPoolIdentity` using IIS Manager:

1. Open IIS Manager
2. Open the Application Pools node underneath the machine node; select Application Pool to be verified
3. Right-click the Application Pool and select Advanced Settings...
4. Under the Process Model section, locate the Identity option and ensure that `ApplicationPoolIdentity` is set

This configuration is stored in the same `applicationHost.config` file for websites and application/virtual directories, at the bottom of the file, surrounded by `<location path="path/to/resource">` tags.

C02 - Command Line Implementation Example

To verify that any new Application Pools use the `ApplicationPoolIdentity`, execute the following command to determine if the Application Pool default has been changed to `ApplicationPoolIdentity`:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:applicationPools
```

Listing: BL115-5216_C01_01.cmd

C03 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
Get-ChildItem -Path IIS:\AppPools\ | Select-Object name, state, <#@(e=
{$_processModel.password};l="password"), #> @(e={$_processModel.identityType};l="identityType")
```

Listing: BL115-5216_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.4

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS and also partially IIS 8.x measure M383319; strengthened the rule that each application pool must run under a unique identity. Changed during review: Rewrote the *Rule*, and *Exemption* section, aligning better with the CIS rule. Added a Note to the *Description* section which better explains the advantage of the ApplicationPoolIdentity. Added a Note to *Implementation* 01 that this procedure only configures the DefaultAppPool.

BL115-3321

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Unique Application Pools' is set

Rule

Ensure 'unique application pools' is set for sites.

Description

IIS has introduced a new security feature called *Application Pool Identities* that allows Application Pools to run under unique accounts without the need to create and manage local or domain accounts. It is recommended that all Sites run under unique, dedicated Application Pool Identity.

Rationale

By setting sites to run under unique Application Pools, resource-intensive applications can be assigned to their own application pools, which could improve server and application performance. In addition, it can help maintain application availability: if an application in one pool fails, applications in other pools are not affected. Last, isolating applications helps mitigate the potential risk of one application being allowed access to the resources of another application.

I01 - GUI Implementation Example

1. Open IIS Manager
2. Open the Sites node underneath the machine node
3. Select the Site to be changed
4. In the Actions pane, select Basic Settings
5. Click the Select... box next to the Application Pool text box
6. Select the desired Application Pool
7. Once selected, click OK

I02 - Command Line Implementation Example

The following appcmd.exe command will set the application pool for a given application:

```
%systemroot%\system32\inetsrv\appcmd.exe set app '<website name>/' /applicationpool:<apppool name>
```

Listing: BL115-3321_I02_01.cmd

The output of this command will be similar to the following: APP object "Default Web Site/" changed (applicationPool:DefaultAppPool)

Run the above command to ensure a unique application pool is assigned for each site listed.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Set-ItemProperty -Path 'IIS:\Sites\<website name>' -Name applicationPool -Value <apppool name> -Force
```

Listing: BL115-3321_I03_01.ps1

C01 - Command Line Check Example

The following appcmd.exe command will give a list of all applications configured, which site they are in, which application pool is serving them and which *Application Pool Identity* they are running under:

```
%systemroot%\system32\inetsrv\appcmd.exe list app
```

Listing: BL115-3321_C01_01.cmd

The output of this command will be similar to the following:

```
APP "Default Web Site/" (applicationPool:DefaultAppPool)
```

Run the above command and ensure a unique application pool is assigned for each site listed.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-Website | Select-Object Name, applicationPool
```

Listing: BL115-3321_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.5

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS and also partially IIS 8.x measure M383319.

BL115-3081

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure 'Application Pool Identity' for Anonymous User Identity

Rule

Ensure *Application Pool Identity* is configured for anonymous user identity.

Description

To achieve isolation in IIS, application pools can be run as separate identities. IIS can be configured to automatically use the *Application Pool Identity*, if no anonymous user account is configured for a Web site. This can greatly reduce the number of accounts needed for Web sites and make management of the accounts easier. It is recommended the *Application Pool Identity* be set as the Anonymous User Identity.

Rationale

Configuring the anonymous user identity to use the *Application Pool Identity* will help ensure site isolation - provided sites are set to use the *Application Pool Identity*. Since a unique principal will run each application pool, it will ensure the identity has least privilege. Additionally, it will simplify Site management.

I01 - GUI Implementation Example

The Anonymous User Identity can be set to *Application Pool Identity* by using the IIS Manager GUI, using AppCmd.exe commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the username attribute of the anonymousAuthentication node in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate to the desired server, site, or application
2. In Features View, find and double-click the Authentication icon
3. Select the Anonymous Authentication option and in the Actions pane select Edit...
4. Choose *Application Pool Identity* in the modal window and then press the OK button

I02 - Command Line Implementation Example

To use AppCmd.exe to configure anonymousAuthentication at the server level, the command would look like this:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:anonymousAuthentication /username:"" --password
```

Listing: BL115-3081_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Set-ItemProperty -Path IIS:\AppPools\<apppool name> -Name passAnonymousToken -Value True
```

Listing: BL115-3081_I03_01.ps1

C01 - GUI Check Example

Find and open the `applicationHost.config` file and verify that the `userName` attribute of the `anonymousAuthentication` tag is set to a blank string:

```
<system.webServer>
  <security>
    <authentication>
      <anonymousAuthentication userName="" />
    </authentication>
  </security>
</system.webServer>
```

Listing: BL115-3081_C01_01.config

This configuration is stored in the same `applicationHost.config` file for websites and application/virtual directories, at the bottom of the file, surrounded by `<location path="path/to/resource">` tags.

C02 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
Get-WebConfiguration system.webServer/security/authentication/anonymousAuthentication -Recurse | where  
{$_ .enabled -eq $true} | format-list location
```

Listing: BL115-3081_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. This rule was partially addressed in former IIS 8.x measure M383351.

BL115-0784

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Disable WebDav Feature

Rule

Ensure WebDav feature is disabled.

Description

WebDAV is an extension to the HTTP protocol which allows clients to create, move, and delete files and resources on the web server. This functionality is available in IIS when the WebDAV feature is enabled.

Rationale

WebDAV is not widely used, and it has serious security concerns because it may allow clients to modify unauthorized files on the web server. Therefore, the WebDav feature should be disabled.

I01 - PowerShell Implementation Example

To disable this feature using PowerShell, enter the following command:

```
Remove-WindowsFeature Web-DAV-Publishing
```

Listing: BL115-0784_I01_01.ps1

Verify that Success is True.

C01 - PowerShell Check Example

To verify using PowerShell, enter the following command:

```
Get-WindowsFeature Web-DAV-Publishing
```

Listing: BL115-0784_C01_01.ps1

Verify that the Install State is Available.

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 1.7

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS

Configure Authentication and Authorization

This section contains recommendations around the different layers of authentication in IIS.

BL115-5251

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Global Authorization Rule' is set

Rule

Ensure 'global authorization rule' is set to restrict access.

Description

IIS introduced URL Authorization, which allows the addition of Authorization rules to the actual URL, instead of the underlying file system resource, as a way to protect it. Authorization rules can be configured at the server, website, folder (including Virtual Directories), or file level. The native URL Authorization module applies to all requests, whether they are .NET managed or other types of files (e.g. static files or ASP files).

Rationale

Configuring a global authorization rule that restricts access will ensure inheritance of the settings down through the hierarchy of web directories; if that content is copied elsewhere, the authorization rules flow with it. This will ensure access to current and future content is only granted to the appropriate principals, mitigating risk of accidental or unauthorized access.

I01 - GUI Implementation Example

To configure URL Authorization at the server level using IIS Manager:

1. Connect to Internet Information Services (IIS Manager)
2. Select the server
3. Select Authorization Rules
4. Remove the "Allow All Users" rule
5. Click Add Allow Rule...
6. Allow access to the user(s), user groups, or roles that are authorized across all of the websites and applications (e.g. the Administrators group)

I02 - Command Line Implementation Example

To configure URL Authorization at the server level:

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/authorization /-  
"[users='*',roles='',verbs='']"  
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/authorization  
/+"[accessType='Allow',roles='Administrators']"
```

Listing: BL115-5251_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/authorization" -name "." -AtElement @{users='*';roles='';verbs=''}  
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/authorization" -name "." -value @{accessType='Allow';roles='Administrators'}
```

Listing: BL115-5251_I03_01.ps1

C01 - Manual Check Example

To verify an authorization rule specifying no access to all users except the Administrators group, browse to and open the web.config file for the configured site/application/content:

```
<configuration>  
  <system.webServer>  
    <security>  
      <authorization>  
        <remove users="" roles="" verbs="" />  
        <add accessType="Allow" roles="administrators" />  
      </authorization>  
    </security>  
  </system.webServer>  
</configuration>
```

Listing: BL115-5251_C01_01.config

C02 - GUI Check Example

At the website or application level, verify that the authorization rule configured has been applied:

1. Connect to Internet Information Services (IIS Manager)
2. Select the site or application where Authorization was configured
3. Select Authorization Rules and verify the configured rules were added

It is recommended that URL Authorization be configured to only grant access to the necessary security principals.

C03 - Command Line Check Example

Verify an authorization rule specifying no access to all users except the Administrators group.

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.webserver/security/authorization
```

Listing: BL115-5251_C03_01.cmd

C04 - PowerShell Check Example

Verify an authorization rule specifying no access to all users except the Administrators group. To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-WebConfiguration -pspath 'IIS:\' -filter 'system.webServer/security/authorization'
```

Listing: BL115-5251_C04_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-1891

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Restrict Access to Sensitive Site Features

Rule Ensure access to sensitive site features is restricted to authenticated principals only:

- in the **Internet**: any information which is classified as *Restricted*, *Confidential*, or *Strictly confidential*,
- in the **Intranet**: any information which is classified as *Confidential*, or *Strictly confidential*.

Description

IIS supports both challenge-based and login redirection-based authentication methods. Challenge-based authentication methods, such as Integrated Windows Authentication, require a client to respond correctly to a server-initiated challenge. A login redirection-based authentication method such as Forms Authentication relies on redirection to a login page to determine the identity of the principal. Challenge-based authentication and login redirection-based authentication methods cannot be used in conjunction with one another.

Authentication will help confirm the identity of clients who request access to sites, application, and content. IIS provides the following authentication modules by default:

- Anonymous Authentication - allows anonymous users to access sites, applications, and/or content
- Integrated Windows Authentication - authenticates users using the NTLM or Kerberos protocols; Kerberos v5 requires a connection to Active Directory
- ASP.NET Impersonation - allows ASP.NET applications to run under a security context different from the default security context for an application
- Forms Authentication - enables a user to login to the configured space with a valid user name and password which is then validated against a database or other credentials store
- Basic authentication - requires a valid user name and password to access content
- Client Certificate Mapping Authentication - allows automatic authentication of users who log on with client certificates that have been configured; requires SSL
- Digest Authentication - uses Windows domain controller to authenticate users who request access

Note that none of the challenge-based authentication modules can be used at the same time Forms Authentication is enabled for certain applications/content. Forms Authentication does not rely on IIS authentication, so anonymous access for the ASP.NET application can be configured if Forms Authentication will be used.

Rationale

Configuring authentication will mitigate the risk of unauthorized users accessing data and/or services, and in some cases reduce the potential harm that can be done to a system.

I01 - GUI Implementation Example

When configuring an authentication module for the first time, each mechanism must be completely configured before use.

Enabling authentication can be performed by using the user interface (UI), running `AppCmd.exe` commands in a command-line window, editing configuration files directly, or by writing WMI scripts. To verify an authentication mechanism is in place for sensitive content using the IIS Manager GUI:

1. Open IIS Manager and navigate to level with sensitive content
2. In Features View, double-click Authentication
3. On the Authentication page, make sure an authentication module is enabled, while anonymous authentication is enabled (Forms Authentication can have anonymous as well)
4. Select the desired authentication module, then in the Actions pane, click Enable

I02 - Command Line Implementation Example

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.web/authentication /mode:  
<Windows|Passport|Forms>
```

Listing: BL115-1891_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website location>' -filter  
'system.webServer/security/authentication/anonymousAuthentication' -name 'enabled' -value 'False'  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website location>' -filter  
'system.webServer/security/authentication/windowsAuthentication' -name 'enabled' -value 'True'
```

Listing: BL115-1891_I03_01.ps1

C01 - GUI Check Example

To verify that the authentication module is enabled for a specific site, application, or content, browse to and open the `web.config` file pertaining to the content. Verify the configuration file now has a mode defined within the `<authentication>` tags. The example below shows that Forms Authentication is configured, cookies will always be used, and SSL is required:

```
<system.web>  
  <authentication>  
    <forms cookieless="UseCookies" requireSSL="true" />  
  </authentication>  
</system.web>
```

Listing: BL115-1891_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.web/authentication
```

Listing: BL115-1891_C02_01.cmd

C03 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-WebConfiguration system.webServer/security/authentication/* -Recurse | Where-Object {$_.enabled -eq  
$true} | Format-Table
```

Listing: BL115-1891_C03_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Specified the rule more precisely what sensitive site features are; this part is from former IIS 8.x measure M383351.

BL115-1426

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Forms Authentication' is set to Require SSL

Rule

Ensure 'forms authentication' is set to require SSL.

Description

Forms-based authentication can pass credentials across the network in clear text. It is therefore imperative that the traffic between client and server be encrypted using SSL, especially in cases where the site is publicly accessible. It is recommended that communications with any portion of a site using Forms Authentication be encrypted using SSL.

Note: Due to identified security vulnerabilities, SSL is no longer considered to provide adequate protection for a sensitive information. The naming of the rule might be misleading as the type of protocol (TLS 1.x, SSL x) will be defined by the *SChannel* settings.

Rationale

Requiring SSL for Forms Authentication will protect the confidentiality of credentials during the login process, helping mitigate the risk of stolen user information.

I01 - GUI Implementation Example

1. Open IIS Manager and navigate to the appropriate tier
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. Check the Requires SSL checkbox in the cookie settings section, click OK

I02 - Command Line Implementation Example

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.web/authentication /mode:Forms
```

Listing: BL115-1426_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web Site' -filter
'system.web/authentication/forms' -name 'requireSSL' -value 'True'
```

Listing: BL115-1426_I03_01.ps1

C01 - GUI Check Example

To verify that SSL is required for forms authentication for a specific site, application, or content, browse to and open the web.config file for the level in which forms authentication was enabled. Verify the tag <forms requireSSL="true" />:

```
<system.web>
  <authentication>
    <forms requireSSL="true" />
  </authentication>
</system.web>
```

Listing: BL115-1426_C01_01.config

C02 - Command Line Check Example

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.web/authentication
```

Listing: BL115-1426_C02_01.cmd

C03 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web Site' -filter
'system.web/authentication/forms' -name 'requireSSL' | Format-Table Name, Value
```

Listing: BL115-1426_C03_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.3

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added more information to the *Note* regarding SSL.

BL115-3491

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Forms Authentication' is set to use Cookies

Rule

Ensure 'forms authentication' is set to use cookies.

Description

Forms Authentication can be configured to maintain the site visitor's session identifier in either a URI or cookie. It is recommended that Forms Authentication be set to use cookies.

Rationale

Using cookies to manage session state may help mitigate the risk of session hi-jacking attempts by preventing ASP.NET from having to move session information to the URL. Moving session information identifiers into the URL may cause session IDs to show up in proxy logs, browsing history, and be accessible to client scripting via `document.location`.

I01 - GUI Implementation Example

1. Open IIS Manager and navigate to the level where Forms Authentication is enabled
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. In the Cookie settings section, select "Use cookies" from the Mode dropdown

I02 - Command Line Implementation Example

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.web/authentication  
/forms.cookieless:"UseCookies"
```

Listing: BL115-3491_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web Site' -filter  
'system.web/authentication/forms' -name 'cookieless' -value 'UseCookies'
```

Listing: BL115-3491_I03_01.ps1

C01 - GUI Check Example

Locate and open the `web.config` for the configured application. Verify the presence of `<forms cookieless="UseCookies" />`:

```
<system.web>
  <authentication>
    <forms cookieless="UseCookies" requireSSL="true" timeout="30" />
  </authentication>
</system.web>
```

Listing: BL115-3491_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.web/authentication
```

Listing: BL115-3491_C02_01.cmd

C03 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web Site' -filter
'system.web/authentication/forms' -Recurse -name 'cookieless'
```

Listing: BL115-3491_C03_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.4

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-5401

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Cookie Protection Mode' is Configured for Forms Authentication

Rule

Ensure 'cookie protection mode' is configured for forms authentication.

Description

The cookie protection mode defines the protection Forms Authentication cookies will be given within a configured application. The four cookie protection modes that can be defined are:

- Encryption and validation - Specifies that the application use both data validation and encryption to help protect the cookie; this option uses the configured data validation algorithm (based on the machine key) and triple-DES (3DES) for encryption, if available and if the key is long enough (48 bytes or more)
- None - Specifies that both encryption and validation are disabled for sites that are using cookies only for personalization and have weaker security requirements
- Encryption - Specifies that the cookie is encrypted by using Triple-DES or DES, but data validation is not performed on the cookie; cookies used in this manner might be subject to plain text attacks
- Validation - Specifies that a validation scheme verifies that the contents of an encrypted cookie have not been changed in transit

It is recommended that cookie protection mode always encrypt and validate Forms Authentication cookies.

Rationale

By encrypting and validating the cookie, the confidentiality and integrity of data within the cookie is assured. This helps mitigate the risk of attacks such as session hijacking and impersonation.

I01 - GUI Implementation Example

Cookie protection mode can be configured by using the user interface (UI), by running `Appcmd.exe` commands in a command-line window, by editing configuration files directly, or by writing WMI scripts. Using IIS Manager:

1. Open IIS Manager and navigate to the level where Forms Authentication is enabled
2. In Features View, double-click Authentication
3. On the Authentication page, select Forms Authentication
4. In the Actions pane, click Edit
5. In the Cookie settings section, verify the drop-down for Protection mode is set for "encryption" and "validation"

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms' -name 'protection' -value 'All'
```

Listing: BL115-5401_I02_01.ps1

C01 - GUI Check Example

Locate and open the `web.config` for the configured application. Verify the presence of `<forms protection="All" />`:

```
<system.web>
  <authentication>
    <forms cookieless="UseCookies" protection="All" />
  </authentication>
</system.web>
```

Listing: BL115-5401_C01_01.config

Note: The `protection="All"` property will only show up if cookie protection mode was set to something different, and then changed to Encryption and validation. To truly verify the `protection="All"` property in the `web.config`, the protection mode can be changed, and then changed back. Conversely, the `protection="All"` line can be added to the `web.config` manually.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms' -name 'protection'
```

Listing: BL115-5401_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.5

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-2711

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Transport Layer Security for 'Basic Authentication' is Configured

Rule

Ensure transport layer security for 'basic authentication' is configured.

Description

Basic Authentication can pass credentials across the network in clear text. It is therefore imperative that the traffic between client and server be encrypted, especially in cases where the site is publicly accessible and is recommended that TLS be configured and required for any Site or Application using Basic Authentication.

Note: Due to identified security vulnerabilities, SSL is no longer considered to provide adequate protection for a sensitive information. The naming of the rule might be misleading as the type of protocol (TLS 1.x, SSL x) will be defined by the *SChannel* settings.

Rationale

Credentials sent in clear text can be easily intercepted by malicious code or persons. Enforcing the use of Transport Layer Security will help mitigate the chances of hijacked credentials.

I01 - GUI Implementation Example

To protect Basic Authentication with transport layer security:

1. Open IIS Manager
2. In the Connections pane on the left, select the server to be configured
3. In the Connections pane, expand the server, then expand Sites and select the site to be configured
4. In the Actions pane, click Bindings; the Site Bindings dialog appears
5. If an HTTPS binding is available, click Close and see below "To require SSL"
6. If no HTTPS binding is visible, perform the following steps

To add an HTTPS binding:

1. In the Site Bindings dialog, click Add; the Add Site Binding dialog appears
2. Under Type, select https
3. Under SSL certificate, select an X.509 certificate
4. Click OK, then close

To require TLS:

1. In Features View, double-click "SSL Settings"
2. On the SSL Settings page, select "Require SSL".
3. In the Actions pane, click Apply

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website name>' -filter  
'system.webServer/security/access' -name 'sslFlags' -value 'Ssl'
```

Listing: BL115-2711_I02_01.ps1

C01 - GUI Check Example

Once transport layer security has been configured and required for a Site or application, only the `https://` address will be available. Attempt loading the Site or application for which Basic Authentication is configured using `http://`, the requests will fail, and IIS will throw a 403.4 - Forbidden error.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -location '<website name>' -filter  
'system.webServer/security/access' -name 'sslFlags'
```

Listing: BL115-2711_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added Note regarding SSL

BL115-3161

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'passwordFormat' is set to 'SHA256' or Higher

Rule Ensure 'passwordFormat' is set to SHA512, SHA384, or SHA256.

Note: The more secure SHA-2 hash options (SHA256, SHA384, and SHA512) have been introduced by Microsoft with .NET framework, version 4.7.1. As this version is not installed by default on the initial version of Windows Server 2016, you need to install the latest .NET framework version (higher than 4.7) first. Starting with Windows Server, version 1709, the version 4.7.1 or higher of the .NET framework is preinstalled on the OS.

E01 - Web applications requiring .NET framework lower than 4.7.1

If the web application requires a .NET framework version lower than 4.7.1 then it is allowed to use the algorithm SHA1 instead.

Description

The <credentials> element of the <authentication> element allows optional definitions of name and password for IIS Manager User accounts within the configuration file. Forms based authentication also uses these elements to define the users. IIS Manager Users can use the administration interface to connect to sites and applications in which they've been granted authorizations. Note that the <credentials> element only applies when the default provider, ConfigurationAuthenticationProvider, is configured as the authentication provider. It is recommended that passwordFormat be set to a value other than Clear, like the algorithm SHA1 or stronger.

Rationale

Authentication credentials should always be protected to reduce the risk of stolen authentication credentials.

I01 - GUI Implementation Example

Authentication mode is configurable at the machine.config, root-level web.config, or application-level web.config:

1. Locate and open the configuration file where the credentials are stored,
2. Find the <credentials> element,
3. If present, ensure passwordFormat is not set to Clear,
4. Change passwordFormat to SHA512.

The clear text passwords of the User who authenticates will need to be replaced with the appropriate hashed version.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms/credentials' -name 'passwordFormat' -value 'SHA512'
```

Listing: BL115-3161_I02_01.ps1

C01 - GUI Check Example

Locate and open the configuration file for the configured application. Verify the `credentials` element is either not present or set to `SHA512`, `SHA384`, or `SHA256`:

```
<configuration>
  <system.web>
    <authentication mode="Forms">
      <forms name="SampleApp" loginUrl="/login.aspx">
        <credentials passwordFormat="SHA512">
          <user
            name="<UserName1>"
            password="<SHA1EncryptedPassword1>"/>
          <user
            name="<UserName2>"
            password="<SHA1EncryptedPassword2>"/>
        </credentials>
      </forms>
    </authentication>
  </system.web>
</configuration>
```

Listing: BL115-3161_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms/credentials' -name 'passwordFormat'
```

Listing: BL115-3161_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.7

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; changed the rule such that `SHA256` and higher is requested; added an exemption.

Changed during review: Removed html tags in the listing of *Check 01*.

BL115-3661

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Credentials' are not Stored in Configuration Files

Rule

Ensure 'credentials' are not stored in configuration files.

Description

The `<credentials>` element of the `<authentication>` element allows optional definitions of name and password for IIS Manager User accounts within the configuration file. Forms based authentication also uses these elements to define the users. IIS Manager Users can use the administration interface to connect to sites and applications in which they've been granted authorization. Note that the `<credentials>` element only applies when the default provider, `ConfigurationAuthenticationProvider`, is configured as the authentication provider. It is recommended to avoid storing passwords in the configuration file even in form of hash.

Rationale

Authentication credentials should always be protected to reduce the risk of stolen authentication credentials. For security reasons, it is recommended that user credentials not be stored in any IIS configuration files.

I01 - GUI Implementation Example

Authentication mode is configurable at the `machine.config`, root-level `web.config`, or application-level `web.config`:

1. Locate and open the configuration file where the credentials are stored
2. Find the `<credentials>` element
3. If present, remove the section

This will remove all references to stored users in the configuration files.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms/credentials' -name '.'
```

Listing: BL115-3661_I02_01.ps1

C01 - GUI Check Example

Locate and open the configuration file for the configured application. Verify the `credentials` element is not present:

```
<configuration>
  <system.web>
    <authentication mode="Forms">
      <forms name="SampleApp" loginUrl="/login.aspx">
      </forms>
    </authentication>
  </system.web>
</configuration>
```

Listing: BL115-3661_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
'system.web/authentication/forms/credentials' -name 'passwordFormat'
```

Listing: BL115-3661_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 2.8

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-0846

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Set NTFS File System Permissions on Web Content Folders

Rule Configure ACLs as restrictive as possible on every web content folder:

- Keep the default setting where following groups/users have access:
CREATOR OWNER, SYSTEM, Administrators, and TrustedInstaller,
- Remove the local Users group and any other group from the web content folder, if they are not explicitly required by an application. Instead, depending on your configuration, grant preferably only *Read* access explicitly to:
 - A particular application pool (IIS APPPOOL\<NameOfAppPool>),
 - The anonymous user account IUSR (only if your web server hosts one website),
 - The Windows identities used with a particular authentication mechanism.

E01 - Exemption

You can deviate from the requirements in the *Rule* section, if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

When IIS requests a service, it typically has to access resources such as html files, scripts or images. These resources are located in website's root folder and are protected by access control lists (ACLs) provided by the NTFS file system. Depending on the request, different accounts may require access. Typically,

- The *Application Pool Identity* requires at least read access,
- The anonymous access user account (IUSR) requires access if anonymous authentication is in place (only on web servers hosting one website), and
- Other Windows identities require access if another authentication method (e.g., Windows Integrated authentication) is used.

As a rule of thumb, requests for static content require the anonymous user account or the Windows identity to have access while requests for ASP.NET applications, scripts and ISAPI extensions require the *Application Pool Identity* to have proper NTFS ACLs configured. However, it always depends on the particular configuration.

Rationale

One of the most critical security concepts is permissions management: ensuring that proper permissions are set with users. Users might get higher levels of access than security administrators intend. NTFS permissions serve the purpose to prevent unauthorized user access.

I01 - Implementation Example

To set the NTFS permissions:

1. Open the IIS Manager.
2. Select the corresponding website and select `Edit Permissions` in the Actions pane.
3. In the Properties dialog box select the tab `Security`.

Alternatively, you can use the `icacls.exe` command line tool.

Set the ACLs as tight as possible ("*Least Privilege Principle*"). For almost any resource, *Read Only* should be sufficient. Some legacy directly executed scripts (`.exe`, `.dll`) require *Read & Execute*.

If additional permissions should be necessary (e.g., for web content authors), grant them according to the "*Least Privilege Principle*".

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383846. Changed during review: Divided rule in two rules BL115-0846 and BL115-0847.

BL115-0847

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Restrict Access to Built-In Executables

Rule

Make sure that the *Application Pool Identity* and the authentication accounts do not have any access to built-in executables of the Operating System (`powershell.exe`, `cmd.exe`, `tftp.exe`, `cscript.exe`, `net.exe`, `netsh.exe`, `wscript.exe`, ...) or any other content. For that reason, never add the *Application Pool Identity*, anonymous access accounts, or the Windows identities to the local `Users` group or to other local groups that are not explicitly created for web server administration.

Description

If the *Application Pool Identity*, or authentication accounts have access to built-in executables of the Operating System, those might be used via the web interface of the webserver.

Rationale

One of the most critical security concepts is permissions management: ensuring that proper permissions are set with users. Users might get higher levels of access than security administrators intend. NTFS permissions serve the purpose to prevent unauthorized user access.

I01 - Implementation Example

Use the Windows Explorer to check or configure the permissions of the built-in executables of the Operating System. Alternatively, you can use the `icacls.exe` command line tool.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383846. Changed during review: Created this rule (which was former part of BL115-0846).

ASP.NET Configuration

This section contains recommendations specific to ASP.NET.

BL115-5046

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Deployment Method Retail' is set

Rule Ensure 'deployment method retail' is set.

Description

The `<deployment retail>` switch is intended for use by production IIS servers. This switch is used to help applications run with the best possible performance and least possible security information leakages by disabling the application's ability to generate trace output on a page, disabling the ability to display detailed error messages to end users, and disabling the debug switch. Often times, switches and options that are developer-focused, such as failed request tracing and debugging, are enabled during active development. It is recommended that the deployment method on any production server be set to retail.

Rationale

Utilizing the switch specifically intended for production IIS servers will eliminate the risk of vital application and system information leakages that would otherwise occur if tracing or debug were to be left enabled, or `customErrors` were to be left off.

I01 - Implementation Example

1. Open the `machine.config` file located in:
`%systemroot%\Microsoft.NET\Framework\<framework version>\CONFIG`
2. Add the line
`<deployment retail="true" />`
within the `<system.web>` section
3. If systems are 64-bit, do the same for the `machine.config` located in:
`%systemroot%\Microsoft.NET\Framework64\<framework version>\CONFIG`

C01 - Example Check

After the next time IIS is restarted, open the `machine.config` file and verify that `<deployment retail="true" />` remains set to `true`:

```
<system.web>  
  <deployment retail="true" />  
</system.web>
```

Listing: BL115-5046_C01_01.config

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-4166

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Debug' is Turned off

Rule

Ensure 'debug' is turned off.

E01 - Exemption

If debugging is required to identify, analyze, and solve problems, then this setting can be turned on for a limited period of time until the problem is solved.

Description

Developers often enable the debug mode during active ASP.NET development, so that they do not have to continually clear their browsers cache every time they make a change to a resource handler. The problem would arise from this being left "on" or set to "true". Compilation debug output is displayed to the end user, allowing malicious persons to obtain detailed information about applications.

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` configuration file overriding any debug settings. It is recommended that debugging still be turned off.

Rationale

Setting `<compilation debug>` to `false` ensures that detailed error information is not inadvertently displayed during live application usage, mitigating the risk of application information leakage falling into unscrupulous hands.

I01 - GUI Implementation Example

To use the UI to make this change:

1. Open IIS Manager and navigate desired server, site, or application
2. In Features View, double-click .NET Compilation
3. On the .NET Compilation page, in the Behavior section, ensure the Debug field is set to False
4. When finished, click Apply in the Actions pane

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/compilation" -name "debug" -value "False"
```

Listing: BL115-4166_I02_01.ps1

C01 - GUI Check Example

Note: The `<compilation debug>` switch will not be present in the `web.config` file unless it has been added manually, or has previously been configured using the IIS Manager GUI.

Browse to and open the `web.config` file pertaining to the server or specific application that has been configured. Locate the `<compilation debug>` switch and verify it is set to `false`:

```
<configuration>
  <system.web>
    <compilation debug="false" />
  </system.web>
</configuration>
```

Listing: BL115-4166_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/compilation" -name "debug" | format-list Name, Value
```

Listing: BL115-4166_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-5726

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Custom Error Messages are set to On

Rule

Ensure custom error messages are set to On.

E01 - Exemption

The custom error messages can also be set to `RemoteOnly` if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

When an ASP.NET application fails and causes an HTTP/1.x 500 Internal Server Error, or a feature configuration (such as Request Filtering) prevents a page from being displayed, an error message will be generated. Administrators can choose whether or not the application should display a friendly message to the client, detailed error message to the client, or detailed error message to localhost only. The `<customErrors>` tag in the `web.config` has three modes:

- **On:** Specifies that custom errors are enabled. If no `defaultRedirect` attribute is specified, users see a generic error. The custom errors are shown to the remote clients and to the local host
- **Off:** Specifies that custom errors are disabled. The detailed ASP.NET errors are shown to the remote clients and to the local host
- **RemoteOnly:** Specifies that custom errors are shown only to the remote clients, and that ASP.NET errors are shown to the local host. This is the default value

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` file overriding any settings for `customErrors` to be turned `Off`. It is recommended that `customErrors` still be turned to `On` or `RemoteOnly`.

Rationale

`customErrors` can be set to `On` or `RemoteOnly` without leaking detailed application information to the client. Ensuring that `customErrors` is not set to `Off` will help mitigate the risk of malicious persons learning detailed application error and server configuration information.

I01 - GUI Implementation Example

`customErrors` may be set for a server, site, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the `customErrors` mode to `RemoteOnly` or `On` for a Web Site in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate to the site to be configured
2. In Features View, find and double-click ".NET Error Pages" icon
3. In the Actions Pane, click Edit Feature Settings

4. In modal dialog, choose "On" for Mode settings
5. Click OK

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/Default Web Site' -filter
"system.web/customErrors" -name "mode" -value "On"
```

Listing: BL115-5726_I02_01.ps1

C01 - GUI Check Example

Find and open the `web.config` file for the application/site and verify that the tag has `<customErrors mode="On" />` defined.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/customErrors" -name "mode"
```

Listing: BL115-5726_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.3

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Specified rule more precisely allowing only one setting; added the other setting as an exemption. This rule was former part of IIS 8.x Measure Plan, measure M383818.

BL115-4476

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure IIS HTTP Detailed Errors are set to Custom

Rule Ensure IIS HTTP detailed errors are set to Custom.

E01 - Exemption

The IIS HTTP detailed errors can also be set to `DetailedLocalOnly` if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

A Web site's error pages are often set to show detailed error information for troubleshooting purposes during testing or initial deployment. To prevent unauthorized users from viewing this privileged information, detailed error pages must not be seen by remote users. This setting can be modified in the `errorMode` attribute setting for a Web site's error pages. By default, the `errorMode` attribute is set in the `Web.config` file for the Web site or application and is located in the `<httpErrors>` element of the `<system.webServer>` section. It is recommended that custom errors be prevented from displaying remotely.

Rationale

The information contained in custom error messages can provide clues as to how applications function, opening up unnecessary attack vectors. Ensuring custom errors are never displayed remotely can help mitigate the risk of malicious persons obtaining information as to how the application works.

I01 - GUI Implementation Example

The following describes how to change the `errorMode` attribute to `Custom` for a Web site by using IIS Manager:

1. Open IIS Manager with Administrative privileges
2. In the Connections pane on the left, expand the server, then expand the Sites folder
3. Select the Web site or application to be configured
4. In Features View, select Error Pages, in the Actions pane, select Open Feature
5. In the Actions pane, select Edit Feature Settings
6. In the Edit Error Pages Settings dialog, under Error Responses, select Custom error pages
7. Click OK and exit the Edit Error Pages Settings dialog

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.webServer/httpErrors" -name "errorMode" -value "Custom"
```

Listing: BL115-4476_I02_01.ps1

C01 - GUI Check Example

Note: The `errorMode` attribute is set in the `Web.config` file for the Web site or application in the `<httpErrors>` element of the `<system.webServer>` section.

Browse to the `web.config` and verify the `errorMode` is set to `Custom`:

```
<system.web>
  <system.webServer>
    <httpErrors errorMode="Custom">
    </httpErrors>
  </system.webServer>
</system.web>
```

Listing: BL115-4476_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.webServer/httpErrors" -name "errorMode"
```

Listing: BL115-4476_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.4

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Specified rule more precisely allowing only one setting; added the other setting as an exemption. This rule was former part of IIS 8.x Measure Plan, measure M383818.

BL115-1801

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure ASP.NET Stack Tracing is not Enabled

Rule

Ensure ASP.NET stack tracing is not enabled.

E01 - Exemption

If stack tracing is required to identify, analyze, and solve problems, then this setting can be turned on for a limited period of time until the problem is solved.

Description

The `trace` element configures the ASP.NET code tracing service that controls how trace results are gathered, stored, and displayed. When tracing is enabled, each page request generates trace messages that can be appended to the page output or stored in an application trace log.

This is a defense in depth recommendation due to the `<deployment retail="true" />` in the `machine.config` file overriding any settings for ASP.NET stack tracing that are left on. It is recommended that ASP.NET stack tracing still be turned off.

Rationale

In an active Web Site, tracing should not be enabled because it can display sensitive configuration and detailed stack trace information to anyone who views the pages in the site. If necessary, the `localOnly` attribute can be set to true to have trace information displayed only for localhost requests. Ensuring that ASP.NET stack tracing is not on will help mitigate the risk of malicious persons learning detailed stack trace information.

I01 - GUI Implementation Example

Per Page:

1. Ensure `<deployment retail="true" />` is enabled in the `machine.config`.
2. Remove all attribute references to ASP.NET tracing by deleting the `trace` and `trace enable` attributes.

Remove any references to `trace="true"`.

Per Application:

1. Ensure `<deployment retail="true" />` is enabled in the `machine.config`.
2. Remove all attribute references to ASP.NET tracing by deleting the `trace` and `trace enable` attributes.

```
<configuration>
  <system.web>
    <trace enabled="true">
  </system.web>
</configuration>
```

Listing: BL115-1801_I01_01.config

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/trace" -name "enabled" -value "False"
```

Listing: BL115-1801_I02_01.ps1

C01 - GUI Check Example

Tracing is configurable at numerous levels:

1. Machine.config
2. Root-level web.config
3. Application-level web.config
4. Virtual or physical directory-level web.config
5. Individual ASP.NET page level

Verify ASP.NET tracing is not turned on, via a per-page basis in the application. Ensure the trace attribute is **not** enabled:

trace="true"

On an application basis like in the web.config ensure that tracing is **not** enabled like:

```
<configuration>
  <system.web>
    <trace enabled="true">
  </system.web>
</configuration>
```

Listing: BL115-1801_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter "system.web/trace"
-name "enabled" | Format-List Name,Value
```

Listing: BL115-1801_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.5

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-1271

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'httpcookie' Mode is Configured for Session State

Rule

Ensure 'httpcookie' mode is configured for Session State.

Description

A session cookie associates session information with client information for that session, which can be the duration of a user's connection to a site. The cookie is passed in an HTTP header together with all requests between the client and server.

Session information can also be stored in the URL. However, storing session information in this manner has security implications that can open attack vectors such as session hijacking. An effective method used to prevent session hijacking attacks is to force web applications to use cookies to store the session token. This is accomplished by setting the `cookieless` attribute of the `sessionState` node to `UseCookies` or `False` which will in turn keep session state data out of URI. It is recommended that session state be configured to `UseCookies`.

Rationale

Cookies that have been properly configured help mitigate the risk of attacks such as session hi-jacking attempts by preventing ASP.NET from having to move session information to the URL; moving session information in URI causes session IDs to show up in proxy logs, and is accessible to client scripting via `document.location`.

I01 - GUI Implementation Example

`SessionState` can be set to `UseCookies` by using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, directly editing the configuration files, or by writing WMI scripts. Perform the following to set the `cookieless` attribute of the `sessionState` node to `UseCookies` in the IIS Manager GUI:

1. Open the IIS Manager GUI and navigate desired server, site, or application
2. In Features View, find and double-click the Session State icon
3. In the Cookie Settings section, choose Use Cookies from the Mode dropdown
4. In the Actions Pane, click Apply

I02 - Command Line Implementation Example

To use `AppCmd.exe` to configure `sessionState` at the server level, the command would look like this:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /commit:WEBROOT /section:sessionState  
/cookieless:UseCookies /cookieName:ASP.NET_SessionID /timeout:20
```

Listing: BL115-1271_I02_01.cmd

When Appcmd.exe is used to configure the <sessionstate> element at the global level in IIS, the /commit:WEBROOT switch must be included so that configuration changes are made to the root web.config file instead of ApplicationHost.config.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/sessionState" -name "mode" -value "StateServer"
```

Listing: BL115-1271_I03_01.ps1

C01 - GUI Check Example

Find and open the web.config file for the application/site and verify that the sessionState tag is set to use cookies:

```
<system.web>
  <sessionState cookieless="UseCookies" />
</system.web>
```

Listing: BL115-1271_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/sessionState" -name "mode"
```

Listing: BL115-1271_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-3336

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Cookies' are set with HttpOnly Attribute

Rule

Ensure 'cookies' are set with HttpOnly attribute.

Description

The `httpOnlyCookies` attribute of the `httpCookies` node determines if IIS will set the `HttpOnly` flag on HTTP cookies it sets. The `HttpOnly` flag indicates to the user agent that the cookie must not be accessible by client-side script (i.e., `document.cookie`). It is recommended that the `httpOnlyCookies` attribute be set to `true`.

Rationale

When cookies are set with the `HttpOnly` flag, they cannot be accessed by client side scripting running in the user's browser. Preventing client-side scripting from accessing cookie content may reduce the probability of a cross site scripting attack materializing into a successful session hijack.

I01 - GUI Implementation Example

1. Locate and open the application's `web.config` file
2. Add the `<httpCookies httpOnlyCookies="true" />` tag within `<system.web>`:

```
<configuration>
  <system.web>
    <httpCookies httpOnlyCookies="true" />
  </system.web>
</configuration>
```

Listing: BL115-3336_I01_01.config

Setting the value of the `httpOnlyCookies` attribute of the `httpCookies` element to `true` will add the `HttpOnly` flag to all the cookies set by the application. All modern versions of browsers recognize `HttpOnly` attribute; older versions will either treat them as normal cookies or simply ignore them altogether.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpCookies" -name "httpOnlyCookies" -value "True"
```

Listing: BL115-3336_I02_01.ps1

C01 - GUI Check Example

After the next time IIS is restarted, browse to and open the `web.config` for the application in which `httpOnly` cookies have been turned on. Confirm the `httpOnlyCookies` attribute is set to `true`:

```
<configuration>
  <system.web>
    <httpCookies httpOnlyCookies="true" />
  </system.web>
</configuration>
```

Listing: BL115-3336_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpCookies" -name "httpOnlyCookies" | Format-List Name,Value
```

Listing: BL115-3336_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.7

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Added PowerShell scripts.

BL115-9971

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Cookies' are set with RequireSSL to True

Rule

Ensure 'cookies' are set with RequireSSL to true.

Description

The `RequireSSL` property enables or disables output of the secure cookie attribute as described in [RFC2109]. When used by compliant browsers, the cookie will only be sent back over a connection using TLS. The default is `false`.

Rationale

Cookie sniffing and manipulation could cause session hijacking or other forms of attacks that are based on the content of the cookies.

I01 - GUI Implementation Example

1. On the IIS, go to the root directory of the website.
2. Open the file `web.config` in a text or XML editor.
3. Make sure configuration element `httpCookies` in section `<system.web>` is set to `requireSSL="true"`, e.g.:

```
<configuration>
  <system.web>
    <httpCookies httpOnlyCookies="true" requireSSL="true" />
  </system.web>
</configuration>
```

Listing: BL115-9971_I01_01.config

4. Save the file.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpCookies" -name "requireSSL" -value "True"
```

Listing: BL115-9971_I02_01.ps1

C01 - GUI Check Example

Find and open the `web.config` file for the application/site and verify that 'cookies' are set with `RequireSSL to true`:

```
<configuration>
  <system.web>
    <httpCookies httpOnlyCookies="true" requireSSL="true" />
  </system.web>
</configuration>
```

Listing: BL115-9971_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpCookies" -name "requireSSL" | Format-List Name,Value
```

Listing: BL115-9971_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO.

BL115-3216

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'MachineKey Validation Method - .NET 3.5' is Configured for SHA1

Rule

Ensure 'MachineKey validation method - .NET 3.5' is configured for SHA1.

Description

The `machineKey` element of the ASP.NET `web.config` specifies the algorithm and keys that ASP.NET will use for encryption. The Machine Key feature can be managed to specify hashing and encryption settings for application services such as view state, Forms authentication, membership and roles, and anonymous identification.

The following validation methods are available:

- Advanced Encryption Standard (AES) is relatively easy to implement and requires little memory. AES has a key size of 128, 192, or 256 bits. This method uses the same private key to encrypt and decrypt data, whereas a public-key method must use a pair of keys
- Message Digest 5 (MD5) is used for digital signing of applications. This method produces a 128-bit message digest, which is a compressed form of the original data
- Secure Hash Algorithm (SHA1) is considered more secure than MD5 because it produces a 160-bit message digest
- Triple Data Encryption Standard (TripleDES) is a minor variation of Data Encryption Standard (DES). It is three times slower than regular DES but can be more secure because it has a key size of 192 bits. If performance is not a primary consideration, consider using TripleDES

It is recommended that SHA1 method be configured for use at the global level.

Rationale

In general, the usage of SHA1 as hash algorithm shall be avoided, but in .NET 3.5 this is the strongest hashing algorithm supported by the vendor for the validation property.

The better approach is to get rid of .NET 3.5 and use a newer, more secure, version of .NET. Keep in mind that .NET 3.5 is only supported on Windows Server 2016 but not on Windows Server 2019.

I01 - Command Line Implementation Example

Machine key encryption can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the Machine Key encryption at the global level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /commit:WEBROOT /section:machineKey /validation:SHA1
```

Listing: BL115-3216_I01_01.cmd

Note: When `Appcmd.exe` is used to configure the `<machineKey>` element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

I02 - PowerShell Implementation Example

To set the Machine Key encryption at the global level using an `powershell.exe` command:

```
Import-Module WebAdministration
Set-WebConfiguration -filter /system.web/machinekey 'IIS:\' -value @{validation='SHA1'}
```

Listing: BL115-3216_I02_01.ps1

C01 - GUI Check Example

To verify the Machine Key validation method using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the WEBROOT, or server in this case
2. In the features view, double-click Machine Key
3. On the Machine Key page, verify that SHA1 is selected in the validation method dropdown

C02 - PowerShell Check Example

To verify the Machine Key validation method using PowerShell:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -PSPath Machine/Webroot /system.web/machineKey -name * | select *
```

Listing: BL115-3216_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.8

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; requested in the rule specifically SHA1. Change during review: Rephrased the Rationale such that the usage of .NET 3.5 should be avoided.

BL115-4876

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'MachineKey Validation Method - .NET 4.5' is configured for SHA-2 Methods

Rule

Ensure 'MachineKey validation method - .NET 4.5' is configured to use one of the SHA-2 methods: HMACSHA512, HMACSHA384, or HMACSHA256.

Description

The `machineKey` element of the ASP.NET `web.config` specifies the algorithm and keys that ASP.NET will use for encryption. The Machine Key feature can be managed to specify hashing and encryption settings for application services such as view state, Forms authentication, membership and roles, and anonymous identification.

The following validation methods are available:

- Advanced Encryption Standard (AES) is relatively easy to implement and requires little memory. AES has a key size of 128, 192, or 256 bits. This method uses the same private key to encrypt and decrypt data, whereas a public-key method must use a pair of keys
- Message Digest 5 (MD5) is used for digital signing of applications. This method produces a 128-bit message digest, which is a compressed form of the original data
- Secure Hash Algorithm (SHA1) is considered more secure than MD5 because it produces a 160-bit message digest
- Triple Data Encryption Standard (TripleDES) is a minor variation of Data Encryption Standard (DES). It is three times slower than regular DES but can be more secure because it has a key size of 192 bits. If performance is not a primary consideration, consider using TripleDES
- Secure Hash Algorithm (SHA-2) is a family of two similar hash functions, with different block sizes known as SHA-256 and SHA-512. They differ in the word size; SHA-256 used 32-bit words and SHA-512 uses 64-bit words.

It is recommended that SHA-2 methods be configured for use at the global level.

Rationale

SHA-2 is the strongest hashing algorithm supported by the validation property, so it should be used as the validation method for the MachineKey in .NET 4.5.

I01 - Command Line Implementation Example

Machine key encryption can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the Machine Key encryption at the global level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /commit:WEBROOT /section:machineKey  
/validation:HMACSHA256
```

Listing: BL115-4876_I01_01.cmd

Note: When `Appcmd.exe` is used to configure the `<machineKey>` element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/machineKey" -name
"validation" -value "HMACSHA256"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/machineKey" -name
"decryption" -value "HMACSHA256"
```

Listing: BL115-4876_I02_01.ps1

C01 - GUI Check Example

To verify the Machine Key validation method using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the WEBROOT, or server in this case
2. In the features view, double-click Machine Key
3. On the Machine Key page, verify that HMACSHA256 is selected in the validation method dropdown

C02 - PowerShell Check Example

To verify the Machine Key validation and decryption method using PowerShell:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/machineKey" -name
"validation"
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/machineKey" -name
"decryption"
```

Listing: BL115-4876_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.9

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; requested in the rule specifically SHA-2 methods.

BL115-2731

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Global .NET Trust Level is Configured

Rule

Ensure global .NET trust level is configured to `Medium` or lower.

E01 - Exemption

Certain applications might require custom ASP.NET trust levels (e.g., SharePoint Server). If the application comes from a trustworthy source (e.g., Microsoft) this custom setting can be accepted.

If you have to use a higher trust level than `Medium`, make sure that the .NET application does not compromise overall security.

Description

An application's trust level determines the permissions that are granted by the ASP.NET code access security (CAS) policy. CAS defines two trust categories: full trust and partial trust. An application that has full trust permissions may access all resource types on a server and perform privileged operations, while applications that run with partial trust have varying levels of operating permissions and access to resources.

The possible values for the Level property of the TrustSection class are:

- **Full:** Specifies unrestricted permissions and grants the ASP.NET application permissions to access any resource that is subject to operating system security; all privileged operations are supported
- **High:** specifies a high level of code access security which limits the application from doing the following:
 - Call unmanaged code
 - Call serviced components
 - Write to the event log
 - Access Microsoft Windows Message Queuing queues
 - Access ODBC, OLD DB, or Oracle data sources
- **Medium:** specifies a medium level of code access security, which means that in addition to the restrictions for High, the ASP.NET application cannot do any of the following things:
 - Access files outside the application directory
 - Access the registry
- **Low:** specifies a low level of code access security, which means that in addition to the restrictions for Medium, the application is prevented from performing any of the following actions:
 - Write to the file system
 - Call the `System.Security.CodeAccessPermission.Assert` method to expand permissions to resources
- **Minimal:** specifies a minimal level of code access security, which means that the application has only execute permission

It is recommended that the global .NET Trust Level be set to `Medium` or lower.

Rationale

The CAS determines the permissions that are granted to the application on the server. Setting a minimal level of trust that is compatible with the applications will limit the potential harm that a compromised application could cause to a system.

I01 - Command Line Implementation Example

Trust level can be set by using the UI, running `appcmd.exe` commands, by editing configuration files directly, or by writing WMI scripts. To set the .NET Trust Level to Medium at the server level using an `appcmd.exe` command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /commit:WEBROOT /section:trust /level:Medium
```

Listing: BL115-2731_I01_01.cmd

When `Appcmd.exe` is used to configure the element at the global level in IIS, the `/commit:WEBROOT` switch must be included so that configuration changes are made to the root `web.config` file instead of `ApplicationHost.config`.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/trust" -name "level" -value  
"Medium"
```

Listing: BL115-2731_I02_01.ps1

C01 - GUI Check Example

To verify the global .NET Trust Level using IIS Manager:

1. Open IIS Manager and navigate to the level that was configured, the server in this example
2. In the features view, double-click .NET Trust Levels
3. On the .NET Trust Levels page, verify that Medium (`web_mediumtrust.config`) is selected in the Trust Level dropdown

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT' -filter "system.web/trust" -name "level"
```

Listing: BL115-2731_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.10

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; aligned with M383190 from previous IIS 8.x Measure Plan. Changed during review:
Removed the note in the rule which states that this setting applies only to .NET version 2.0 as this is not confirmed yet. The settings are still available in the IIS Manager.

BL115-4911

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure X-Powered-By Header is removed

Rule Ensure X-Powered-By Header is removed.

Description

The x-powered-by headers may specify the underlying technology used by an application. Attackers are able to conduct reconnaissance on a website using these response headers. This header could be used to target attacks for specific known vulnerabilities associated with the underlying technology. Removing this header will prevent targeting of your application for specific exploits by non-determined attackers.

Rationale

Attackers are able to conduct reconnaissance on a website using these response headers. This header could be used to target attacks for specific known vulnerabilities associated with the underlying technology.

While this is not the only way to fingerprint a site through the response headers, it makes it harder and prevents some potential attackers.

I01 - GUI Implementation Example

1. On the IIS, go to the root directory of the website.
2. Open the file `web.config` in a text or XML editor.
3. Add the following line in section `<customHeaders>`:

```
<configuration>
  <system.webServer>
    <httpProtocol>
      <customHeaders>
        <remove name="X-Powered-By" />
      </customHeaders>
    </httpProtocol>
  </system.webServer>
</configuration>
```

Listing: BL115-4911_I01_01.config

4. Save the file.

I02 - Command Line Implementation Example

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/httpProtocol /-  
"customHeaders.[name='X-Powered-By']" /commit:apphost
```

Listing: BL115-4911_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Remove-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webserver/httpProtocol/customHeaders" -name "." -AtElement @{name='X-Powered-By'}
```

Listing: BL115-4911_I03_01.ps1

C01 - Command Line Check Example

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.webServer/httpProtocol
```

Listing: BL115-4911_C01_01.cmd

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.11

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Specified *Rationale* section more precisely.

BL115-8201

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Server Header is removed

Rule

Ensure Server Header is removed.

Description

The server header may specify the underlying technology used by an application. Attackers are able to conduct reconnaissance on a website using these response headers. This header could be used to target attacks for specific known vulnerabilities associated with the underlying technology. Removing this header will prevent targeting of your application for specific exploits by non-determined attackers.

Rationale

Attackers are able to conduct reconnaissance on a website using these response headers.

While this is not the only way to fingerprint a site through the response headers, it makes it harder and prevents some potential attackers. This header could be used to target attacks for specific known vulnerabilities associated with the underlying technology. The server header removal directive is a new feature in IIS 10 that can assist in mitigating this risk.

I01 - GUI Implementation Example

1. On the IIS, go to the root file of the configuration system.
By default, this is located in C:\Windows\System32\inetsrv\config\.
2. Open the file `applicationHost.config` in a text or XML editor.
3. Make sure the configuration element `requestFiltering` in section `<system.webServer>/<security>` has set the property `removeServerHeader="true"` accordingly, e.g.:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestFiltering allowHighBitCharacters="false" removeServerHeader="true" />
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-8201_I01_01.config

4. Save the file.

Impact:

This will remove the server header.

I02 - Command Line Implementation Example

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/requestFiltering  
/removeServerHeader:"True" /commit:apphost
```

Listing: BL115-8201_I02_01.cmd

Impact:

This will remove the server header.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/' -filter  
'system.webServer/security/requestFiltering' -name 'removeServerHeader' -value 'True'
```

Listing: BL115-8201_I03_01.ps1

Impact:

This will remove the server header.

C01 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.webServer/security/requestFiltering
```

Listing: BL115-8201_C01_01.cmd

C02 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
Import-Module WebAdministration  
Get-WebConfigurationProperty -pspath machine/webroot/apphost -filter  
'system.webServer/security/requestFiltering' -name 'removeServerHeader'
```

Listing: BL115-8201_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 3.12

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Specified *Rationale* section more precisely; added *Implementation* I01. Changed during review: Added the information to the *Rationale* section that *removeServerHeader* is a new feature in IIS 10.

BL115-2596

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Remove the Unwanted X-AspNet-Version Header

Rule

Remove the unwanted X-AspNet-Version header X-Powered-By.

Description

The default IIS response includes detailed technical information on the server, the ASP.NET version, and MVC version.

Rationale

Headers that disclose internal implementation and technical details shall be omitted.

I01 - GUI Implementation Example

1. On the IIS, go to the root directory of the website.
2. Open the file `web.config` in a text or XML editor.
3. Make sure the configuration element `httpRuntime` in section `<system.web>` has set the property `enableVersionHeader` to `false`, e.g.:

```
<configuration>
  <system.web>
    <httpRuntime enableVersionHeader="false" />
  </system.web>
</configuration>
```

Listing: BL115-2596_I01_01.config

4. Save the file.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "enableVersionHeader" -value "False"
```

Listing: BL115-2596_I02_01.ps1

C01 - GUI Check Example

Find and open the `web.config` file for the application/site and verify that the configuration element `httpRuntime` has set the property `enableVersionHeader` to `false`:

```
<configuration>
  <system.web>
    <httpRuntime enableVersionHeader="false" />
  </system.web>
</configuration>
```

Listing: BL115-2596_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "enableVersionHeader" | Format-List Name,Value
```

Listing: BL115-2596_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO.

BL115-1295

Asset Manager

EVAL until 2021-02-28

C	I	A
		123

Set the Maximum Execution Time for File Uploads

Rule

Set the `ExecutionTimeout` property to `<= 110` seconds.

E01 - Exemption

The `ExecutionTimeout` value can be changed to a value `>= 110` seconds if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

The `ExecutionTimeout` property specifies the maximum time a request is allowed to execute before ASP.NET kills the request automatically. The default is 110 seconds.

Rationale

This limit can be used to prevent denial of service attacks that are caused by users who post large files to the server.

I01 - GUI Implementation Example

1. On the IIS, go to the root directory of the website.
2. Open the file `web.config` in a text or XML editor.
3. Make sure the configuration element `httpRuntime` in section `<system.web>` has adjusted property `executionTimeout` accordingly, e.g.:

```
<configuration>
  <system.web>
    <httpRuntime executionTimeout="110" />
  </system.web>
</configuration>
```

Listing: BL115-1295_I01_01.config

4. Save the file.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "executionTimeout" -value "00:00:110"
```

Listing: BL115-1295_I02_01.ps1

C01 - GUI Check Example

Find and open the `web.config` file for the application/site and verify the configuration element `httpRuntime` adjusted property `executionTimeout` accordingly, e.g.:

```
<configuration>
  <system.web>
    <httpRuntime executionTimeout="110" />
  </system.web>
</configuration>
```

Listing: BL115-1295_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "executionTimeout" | Format-List Name,Value
```

Listing: BL115-1295_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO.

BL115-5223

EVAL until 2021-02-28

Asset Manager

C	I	A
		123

Set the Maximum Request Size for File Uploads

Rule

Set the `MaxRequestLength` property to `<= 30000000` (approx. 28.6 MB).

E01 - Exemption

The `MaxRequestLength` value can be changed if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

The `MaxRequestLength` property specifies the limit for the buffering threshold of the input stream (e.g., file uploads).

Rationale

This limit can be used to prevent denial of service attacks that are caused by users who post large files to the server.

I01 - GUI Implementation Example

1. On the IIS, go to the root directory of the website.
2. Open the file `web.config` in a text or XML editor.
3. Make sure the configuration element `httpRuntime` in section `<system.web>` has adjusted property `maxRequestLength` accordingly, e.g.:

```
<configuration>
  <system.web>
    <httpRuntime maxRequestLength="30000000" />
  </system.web>
</configuration>
```

Listing: BL115-5223_I01_01.config

4. Save the file.

Make sure the value of the property `maxRequestLength` in section `<system.web>` is less or equal to the value of the property `maxAllowedContentLength` in section `<system.webServer>`.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "maxRequestLength" -value "30000000"
```

Listing: BL115-5223_I02_01.ps1

C01 - GUI Check Example

Find and open the `web.config` file for the application/site and verify the configuration element `httpRuntime` in section `<system.web>` has adjusted property `maxRequestLength` accordingly, e.g.:

```
<configuration>
  <system.web>
    <httpRuntime maxRequestLength="30000000" />
  </system.web>
</configuration>
```

Listing: BL115-5223_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST/<website name>' -filter
"system.web/httpRuntime" -name "maxRequestLength" | Format-List Name,Value
```

Listing: BL115-5223_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO.

Request Filtering and Other Restriction Modules

Introduced in IIS 7.0 for the first time, Request Filtering is a powerful module that provides a configurable set of rules that enables administrators to allow or reject the types of requests that they determine should be allowed or rejected at the server, website, or web application levels.

Earlier versions of Internet Information Services provided the tool UrlScan, which was provided as an add-on to enable system administrators to enforce tighter security policies on their web servers. All of the core features of URLScan have been incorporated into the Request Filtering module. Due to the close nature of functionality in these two tools, reference to legacy URLScan settings will be made where applicable.

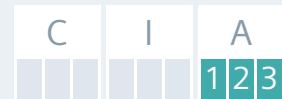
Since Version IIS 8 it also introduced modules for Dynamic IP Address Restrictions. This module can be configured to automatically block website access based on specific rules.

Note: Request Filtering and IP and Domain Restrictions must be enabled as a role service under IIS in order to configure any of its features.

BL115-4236

EVAL until 2021-02-28

Asset Manager



Ensure 'maxAllowedContentLength' is Configured

Rule

Ensure 'maxAllowedContentLength' is configured to <= 30000000 (approx. 28.6 MB).

E01 - Exemption

The `maxAllowedContentLength` value can be changed if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

The `maxAllowedContentLength` Request Filter is the maximum size of the http request, measured in bytes, which can be sent from a client to the server. Configuring this value enables the total request size to be restricted to a configured value. It is recommended that the overall size of requests be restricted to a maximum value appropriate for the server, site, or application.

Rationale

Setting an appropriate value that has been tested for the `maxAllowedContentLength` filter will lower the impact an abnormally large request would otherwise have on IIS and/or web applications. This helps to ensure availability of web content and services and may also help mitigate the risk of buffer overflow type attacks in unmanaged components.

I01 - GUI Implementation Example

The `MaxAllowedContentLength` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, click on the server, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key the maximum content length in bytes that will allow applications to retain their intended functionality, such as 30000000 (approx. 28.6 MB)

Note: Upon exceeding the configured value set for the Request Filter, IIS will throw a Status Code 404.13.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering  
/requestLimits.maxAllowedContentLength:30000000
```

Listing: BL115-4236_I02_01.cmd

Note: Upon exceeding the configured value set for the Request Filter, IIS will throw a Status Code 404.13.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/requestLimits" -name "maxAllowedContentLength" -value  
30000000
```

Listing: BL115-4236_I03_01.ps1

Note: Upon exceeding the configured value set for the Request Filter, IIS will throw a Status Code 404.13.

C01 - GUI Check Example

To manually verify the change, locate and open the `web.config` for the website or application in which the request filter was set. Ensure the value defined for `maxAllowedContentLength` is what was set. The 28.6MB max example would show:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxAllowedContentLength="30000000" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

Listing: BL115-4236_C01_01.config

C02 - PowerShell Check Example

Ensure the value defined for `maxAllowedContentLength` is set. To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxAllowedContentLength"
```

Listing: BL115-4236_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified rule such that a value ≤ 30000000 is requested; added an exemption.

BL115-3256

EVAL until 2021-02-28

Asset Manager

C	I	A
		123

Ensure 'maxURL Request Filter' is Configured

Rule

Ensure 'maxURL request filter' is configured to 4096.

E01 - Exemption

The maxURL value can be changed if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

The maxURL attribute of the <requestLimits> property is the maximum length (in Bytes) in which a requested URL can be (excluding query string) in order for IIS to accept. Configuring this Request Filter enables administrators to restrict the length of the requests that the server will accept. It is necessary that a limit be put on the length of URL.

Rationale

With a properly configured Request Filter limiting the amount of data accepted in the URL, chances of undesired application behaviors affecting the availability of content and services are reduced.

I01 - GUI Implementation Example

To configure using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, click on the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key in 4096 as the maximum URL length in bytes

Note: IIS will log a 404.14 HTTP status if the requested URL was rejected because it exceeded the length defined in the filter.

I02 - Command Line Implementation Example

To set this Request Filter using an AppCmd.exe command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering /requestLimits.maxURL:4096
```

Listing: BL115-3256_I02_01.cmd

Note: IIS will log a 404.14 HTTP status if the requested URL was rejected because it exceeded the length defined in the filter.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxUrl" -value 4096
```

Listing: BL115-3256_I03_01.ps1

Note: IIS will log a 404.14 HTTP status if the requested URL was rejected because it exceeded the length defined in the filter.

C01 - GUI Check Example

To manually verify the change, locate and open the `web.config` for the website or application in which the request filter was set. Verify the value defined for `maxURL`.

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxURL="4096" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

Listing: BL115-3256_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxUrl"
```

Listing: BL115-3256_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified rule such that a value = 4096 is requested; added an exemption.

BL115-3496

EVAL until 2021-02-28

Asset Manager

C	I	A
		123

Ensure 'MaxQueryString Request Filter' is Configured

Rule

Ensure 'MaxQueryString request filter' is configured to 2048.

E01 - Exemption

The MaxQueryString value can be changed if business needs are requiring this. In this case the reasons for the change have to be documented accordingly.

Description

The MaxQueryString Request Filter describes the upper limit on the length of the query string that the configured IIS server will allow for websites or applications. It is necessary that values always be established to limit the amount of data will/can be accepted in the query string.

Rationale

With a properly configured Request Filter limiting the amount of data accepted in the query string, chances of undesired application behaviors such as app pool failures are reduced.

I01 - GUI Implementation Example

The MaxQueryString Request Filter may be set for a server, website, or application using the IIS Manager GUI, using AppCmd.exe commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, go to the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the Request Limits section, key in 2048 in the Maximum query string (Bytes) textbox

Note: If a request is rejected because it exceeds the value set in the maxQueryString Request Filter, a 404.15 HTTP status is logged to the IIS log file.

I02 - Command Line Implementation Example

To set this Request Filter using an AppCmd.exe command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering  
/requestLimits.maxQueryString:2048
```

Listing: BL115-3496_I02_01.cmd

Note: If a request is rejected because it exceeds the value set in the maxQueryString Request Filter, a 404.15 HTTP status is logged to the IIS log file.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxQueryString" -value 2048
```

Listing: BL115-3496_I03_01.ps1

Note: If a request is rejected because it exceeds the value set in the maxQueryString Request Filter, a 404.15 HTTP status is logged to the IIS log file.

C01 - GUI Check Example

To manually verify the change, locate and open the web.config for the website or application in which the filter was set. Ensure the value defined for maxQueryString is what was configured.

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <requestLimits
          maxQueryString="2048" />
        </requestFiltering>
      </security>
    </system.webServer>
  </configuration>
```

Listing: BL115-3496_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/requestLimits" -name "maxQueryString"
```

Listing: BL115-3496_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.3

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified rule such that a value = 2048 is requested; added an exemption.

BL115-4416

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Non-ASCII Characters in URLs are not Allowed

Rule

Ensure non-ASCII characters in URLs are not allowed.

E01 - Exemption

If there is a valid business reason to use non-ASCII characters in URLs (e.g., country specific characters) then this rule can be omitted. However, the business reasons for this exemption must be documented.

Description

This setting is used to allow or reject all requests to IIS that contain non-ASCII characters. When using this feature, Request Filtering will deny the request if high-bit characters are present in the URL. The UrlScan equivalent is `AllowHighBitCharacters`. It is recommended that requests containing non-ASCII characters be rejected, where possible.

Rationale

This setting can help defend against canonicalization attacks, reducing the potential attack surface of servers, sites, and/or applications.

I01 - GUI Implementation Example

The `AllowHighBitCharacters` Request Filter may be set for a server, website, or application. To configure using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, go to the connection, site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow high-bit characters

Note: Disallowing high-bit ASCII characters in the URL may negatively impact the functionality of sites requiring international language support. If a request is rejected because it contains a high-bit character, a 404.12 HTTP status is logged to the IIS log file.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering  
/allowHighBitCharacters:false
```

Listing: BL115-4416_I02_01.cmd

Note: Disallowing high-bit ASCII characters in the URL may negatively impact the functionality of sites requiring international language support. If a request is rejected because it contains a high-bit character, a 404.12 HTTP status is logged to the IIS log file.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering" -name "allowHighBitCharacters" -value "False"
```

Listing: BL115-4416_I03_01.ps1

Note: Disallowing high-bit ASCII characters in the URL may negatively impact the functionality of sites requiring international language support. If a request is rejected because it contains a high-bit character, a 404.12 HTTP status is logged to the IIS log file.

C01 - GUI Check Example

To manually verify the change, locate and open the `web.config` for the website or application in which the request filter was set. Ensure the value defined for the filter is false, as such:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering
        allowHighBitCharacters="false">
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-4416_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
'system.webServer/security/requestFiltering' -name 'allowHighBitCharacters'
```

Listing: BL115-4416_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.4

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added an exemption.

BL115-1391

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Double-Encoded Requests will be Rejected

Rule

Ensure Double-Encoded requests will be rejected.

Description

This Request Filter setting prevents attacks that rely on double-encoded requests and applies if an attacker submits a double-encoded request to IIS. When the double-encoded requests filter is enabled, IIS will go through a two iteration process of normalizing the request. If the first normalization differs from the second, the request is rejected, and the error code is logged as a 404.11. The double-encoded requests filter was the `VerifyNormalization` option in `UrlScan`. It is recommended that double-encoded requests be rejected.

Rationale

This setting will help prevent attacks that rely on URLs that have been crafted to contain double-encoded request(s).

I01 - GUI Implementation Example

The `allowDoubleEscaping` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow double escaping

Note: If a file name in a URL includes "+" then `allowDoubleEscaping` must be set to `true` to allow functionality. If a request is rejected because it contains a double-encoded request, a 404.11 HTTP status is logged to the IIS log file.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering /allowDoubleEscaping:false
```

Listing: BL115-1391_I02_01.cmd

Note: If a file name in a URL includes "+" then `allowDoubleEscaping` must be set to `true` to allow functionality. If a request is rejected because it contains a double-encoded request, a 404.11 HTTP status is logged to the IIS log file.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering" -name "allowDoubleEscaping" -value "False"
```

Listing: BL115-1391_I03_01.ps1

Note: If a file name in a URL includes "+" then allowDoubleEscaping must be set to true to allow functionality. If a request is rejected because it contains a double-encoded request, a 404.11 HTTP status is logged to the IIS log file.

C01 - GUI Check Example

To manually verify the change, locate and open the web.config for the website or application in which the request filter was set. Ensure the value defined for allowDoubleEscaping is false:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering
        allowDoubleEscaping="false">
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-1391_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering" -name "allowDoubleEscaping"
```

Listing: BL115-1391_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.5

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-1951

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'HTTP Trace Method' is Disabled

Rule

Ensure 'HTTP Trace Method' is disabled.

Description

The HTTP TRACE method returns the contents of client HTTP requests in the entity-body of the TRACE response. Attackers could leverage this behavior to access sensitive information, such as authentication data or cookies, contained in the HTTP headers of the request. One such way to mitigate this is by using the <verbs> element of the <requestFiltering> collection. The <verbs> element replaces the [AllowVerbs] and [DenyVerbs] features in UrlScan. It is recommended the HTTP TRACE method be denied.

Rationale

Attackers may abuse HTTP TRACE functionality to gain access to information in HTTP headers such as cookies and authentication data. This risk can be mitigated by not allowing the TRACE verb.

I01 - GUI Implementation Example

1. Open IIS Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. In the Request Filtering pane, click the HTTP verbs tab, and then click Deny Verb... in the Actions pane
5. In the Deny Verb dialog box, enter the TRACE, and then click OK

Note: IIS will return an HTTP 404.6 error to the client when Request Filtering blocks an HTTP request because of a denied HTTP verb.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering /+verbs.  
[verb='TRACE',allowed='false']
```

Listing: BL115-1951_I02_01.cmd

Note: IIS will return an HTTP 404.6 error to the client when Request Filtering blocks an HTTP request because of a denied HTTP verb.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/verbs" -name "." -value @{verb='TRACE';allowed='False'}
```

Listing: BL115-1951_I03_01.ps1

Note: IIS will return an HTTP 404.6 error to the client when Request Filtering blocks an HTTP request because of a denied HTTP verb.

C01 - GUI Check Example

To manually verify the change, browse to the `web.config` file for which the change was made and verify the below configuration:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <verbs>
          <add verb="TRACE" allowed="false" />
        </verbs>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-1951_C01_01.config

C02 - Command Line Check Example

To view this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:requestfiltering
```

Listing: BL115-1951_C02_01.cmd

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS and also partially IIS 8.x measure M383580.

BL115-1952

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'HTTP Options Method' is Disabled

Rule

Ensure 'HTTP Options Method' is disabled.

Description

The HTTP OPTIONS method represents a request for information about the communication options available on the request/response chain identified by the Request-URI.

Rationale

Attackers may abuse HTTP OPTIONS functionality to gain access to information in HTTP headers. It will provide information to an attacker at the reconnaissance stage of this attack.

I01 - GUI Implementation Example

1. Open IIS Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. In the Request Filtering pane, click the HTTP verbs tab, and then click Deny Verb... in the Actions pane
5. In the Deny Verb dialog box, enter the OPTIONS, and then click OK

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering /+verbs.  
[verb='OPTIONS',allowed='false']
```

Listing: BL115-1952_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/verbs" -name "." -value @{verb='OPTIONS';allowed='False'}
```

Listing: BL115-1952_I03_01.ps1

C01 - GUI Check Example

To manually verify the change, browse to the `web.config` file for which the change was made and verify the below configuration:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <verbs>
          <add verb="OPTIONS" allowed="false" />
        </verbs>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-1952_C01_01.config

C02 - Command Line Check Example

To view this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:requestfiltering
```

Listing: BL115-1952_C02_01.cmd

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. The corresponding CIS rule requests only the disabling of the HTTP Trace method, but the HTTP Options method shall also be disabled. This was also partially addressed in IIS 8.x measure M383580.

BL115-1953

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'HTTP Connect Method' is Disabled

Rule

Ensure 'HTTP Connect Method' is disabled.

Description

Request Filtering can be used to filter unwanted HTTP methods also known as verbs (e.g., GET, PUT, POST, OPTIONS, TRACE). Some methods can potentially pose a security risk for a web application, as they allow an attacker to modify the files stored on the web server and, in some scenarios, steal the credentials of legitimate users.

Rationale

The HTTP CONNECT method could allow a client to use the web server as a proxy.

I01 - GUI Implementation Example

1. Open IIS Manager
2. In the Connections pane, select the site, application, or directory to be configured
3. In the Home pane, double-click Request Filtering
4. In the Request Filtering pane, click the HTTP verbs tab, and then click Deny Verb... in the Actions pane
5. In the Deny Verb dialog box, enter the CONNECT, and then click OK

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering /+verbs.  
[verb='CONNECT',allowed='false']
```

Listing: BL115-1953_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.webServer/security/requestFiltering/verbs" -name "." -value @{verb='CONNECT';allowed='False'}
```

Listing: BL115-1953_I03_01.ps1

C01 - GUI Check Example

To manually verify the change, browse to the `web.config` file for which the change was made and verify the below configuration:

```
<configuration>
  <system.webServer>
    <security>
      <requestFiltering>
        <verbs>
          <add verb="CONNECT" allowed="false" />
        </verbs>
      </requestFiltering>
    </security>
  </system.webServer>
</configuration>
```

Listing: BL115-1953_C01_01.config

C02 - Command Line Check Example

To view this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:requestfiltering
```

Listing: BL115-1953_C02_01.cmd

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.6

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. The corresponding CIS rule requests only the disabling of the HTTP Trace method, but the HTTP Connect method shall also be disabled. This was also partially addressed in IIS 8.x measure M383580.

BL115-5851

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Unlisted File Extensions are not allowed

Rule

Ensure Unlisted File Extensions are not allowed.

Description

The `FileExtensions` Request Filter allows administrators to define specific extensions their web server(s) will allow and disallow. The property `allowUnlisted` will cover all other file extensions not explicitly allowed or denied. Often times, extensions such as `.config`, `.bat`, `.exe`, to name a few, should never be served. The `AllowExtensions` and `DenyExtensions` options are the `UrlScan` equivalents. It is recommended that all extensions be disallowed at the most global level possible, with only those necessary being allowed.

Rationale

Disallowing all but the necessary file extensions can greatly reduce the attack surface of applications and servers.

I01 - GUI Implementation Example

The `allowUnlisted` Request Filter may be set for a server, website, or application using the IIS Manager GUI, using `AppCmd.exe` commands in a command-line window, and/or directly editing the configuration files. To configure at the server level using the IIS Manager GUI:

1. Open IIS Manager
2. In the Connections pane, select the server
3. In the Home pane, double-click Request Filtering
4. Click Edit Feature Settings... in the Actions pane
5. Under the General section, uncheck Allow unlisted file name extensions

Note: When IIS rejects a request based on a file extensions filter, the error code logged is 404.7.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:requestfiltering  
/fileExtensions.allowunlisted:false
```

Listing: BL115-5851_I02_01.cmd

Note: When IIS rejects a request based on a file extensions filter, the error code logged is 404.7.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/fileExtensions" -name "allowUnlisted" -value "False"
```

Listing: BL115-5851_I03_01.ps1

C01 - GUI Check Example

To manually verify the change, locate and open the `web.config` for the website or application in which the Request Filter was set. Ensure `<fileExtensionsallowUnlisted="false">`. The following `web.config` will disallow any requests for files that do not have `.asp`, `.aspx`, or `.html` as their extension:

```
<configuration>
<system.webServer>
  <security>
    <requestFiltering>
      <fileExtensions allowUnlisted="false">
        <add fileExtension=".asp" allowed="true" />
        <add fileExtension=".aspx" allowed="true" />
        <add fileExtension=".html" allowed="true" />
      </fileExtensions>
    </requestFiltering>
  </security>
</system.webServer>
</configuration>
```

Listing: BL115-5851_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config /section:requestfiltering
```

Listing: BL115-5851_C02_01.cmd

C03 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/requestFiltering/fileExtensions" -name "allowUnlisted"
```

Listing: BL115-5851_C03_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.7

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-3691

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Handler is not Granted Write and Script/Execute

Rule Ensure Handler is not granted Write together with Script or with Execute at the same time.

Description

Handler mappings can be configured to give permissions to Read, Write, Script, or Execute depending on what the use is for - reading static content, uploading files, executing scripts, etc. It is recommended to grant a handler either Execute/Script or Write permissions, but not both.

Rationale

By allowing both Execute or Script together with Write permissions, a handler can run malicious code on the target server. Ensuring these two permissions are never together will help lower the risk of malicious code being executed on the server.

I01 - GUI Implementation Example

The `accessPolicy` attribute in the `<handlers>` section of either the `ApplicationHost.config` (server-wide) or `web.config` (site or application) must not have `Write` present when `Script` or `Execute` are present. To resolve this issue for a Web server, the attribute in the `<handlers>` section of the `ApplicationHost.config` file for the server must manually be edited. To edit the `ApplicationHost.config` file by using Notepad, perform the following steps:

1. Open Notepad as Administrator
2. Open the `ApplicationHost.config` file in `%systemroot%\system32\inetsrv\config`
3. Edit the `<handlers>` section `accessPolicy` attribute so that `Write` is not present when `Script` or `Execute` are present

Note: This configuration change cannot be made by using IIS Manager.

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config /section:handlers /accessPolicy:Read,Script
```

Listing: BL115-3691_I02_01.cmd

Note: This configuration change cannot be made by using IIS Manager.

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/handlers" -
name "accessPolicy" -value "Read,Script"
```

Listing: BL115-3691_I03_01.ps1

Note: This configuration change cannot be made by using IIS Manager.

C01 - GUI Check Example

Open the ApplicationHost.config file in %systemroot%\system32\inetsrv\config. Find the <handlers> section and verify that the accessPolicy attribute does not contain Write when Script or Execute are present. The following is an acceptable example:

```
<system.webserver>
  <handlers accessPolicy="Read, Script">
  </handlers>
</system.webserver>
```

Listing: BL115-3691_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.webServer/handlers" -name
"accessPolicy"
```

Listing: BL115-3691_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.8

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS and also partially IIS 8.x measure M383580. Simplified the And/Or combination in the rule.

BL115-1046

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'notListedIsapisAllowed' is set to False.

Rule

Ensure 'notListedIsapisAllowed' is set to false.

Description

The `notListedIsapisAllowed` attribute is a server-level setting that is located in the `ApplicationHost.config` file in the `<isapiCgiRestriction>` element of the `<system.webServer>` section under `<security>`. This element ensures that malicious users cannot copy unauthorized ISAPI binaries to the Web server and then run them. It is recommended that `notListedIsapisAllowed` be set to `false`.

Rationale

Restricting this attribute to `false` will help prevent potentially malicious ISAPI extensions from being run.

I01 - GUI Implementation Example

To use IIS Manager to set the `notListedIsapisAllowed` attribute to `false`:

1. Open IIS Manager as Administrator
2. In the Connections pane on the left, select server to be configured
3. In Features View, select ISAPI and CGI Restrictions; in the Actions pane, select Open Feature
4. In the Actions pane, select Edit Feature Settings
5. In the Edit ISAPI and CGI Restrictions Settings dialog, clear the Allow unspecified ISAPI modules check box, if checked
6. Click OK

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/security/isapiCgiRestriction /notListedIsapisAllowed:false
```

Listing: BL115-1046_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name "notListedIsapisAllowed" -value "False"
```

Listing: BL115-1046_I03_01.ps1

C01 - GUI Check Example

Open the `applicationHost.config` file in `%systemroot%\system32\inetsrv\config`. Verify that the `notListedIsapisAllowed` attribute in the `<isapiCgiRestriction>` element is set to `false`:

```
<system.webServer>
  <security>
    <isapiCgiRestriction notListedIsapisAllowed="false">
    </isapiCgiRestriction>
  </security>
</system.webServer>
```

Listing: BL115-1046_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name "notListedIsapisAllowed"
```

Listing: BL115-1046_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.9

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-5466

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'notListedCgisAllowed' is set to False

Rule

Ensure 'notListedCgisAllowed' is set to false.

Description

The `notListedCgisAllowed` attribute is a server-level setting that is located in the `ApplicationHost.config` file in the `<isapiCgiRestriction>` element of the `<system.webServer>` section under `<security>`. This element ensures that malicious users cannot copy unauthorized CGI binaries to the Web server and then run them. It is recommended that `notListedCgisAllowed` be set to `false`.

Rationale

Restricting this attribute to `false` will help prevent unlisted CGI extensions, including potentially malicious CGI scripts from being run.

I01 - GUI Implementation Example

To set the `notListedCgisAllowed` attribute to `false` using IIS Manager:

1. Open IIS Manager as Administrator
2. In the Connections pane on the left, select the server to configure
3. In Features View, select ISAPI and CGI Restrictions; in the Actions pane, select Open Feature
4. In the Actions pane, select Edit Feature Settings
5. In the Edit ISAPI and CGI Restrictions Settings dialog, clear the Allow unspecified CGI modules check box
6. Click OK

I02 - Command Line Implementation Example

To set this Request Filter using an `AppCmd.exe` command, run the following command at an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -  
section:system.webServer/security/isapiCgiRestriction /notListedCgisAllowed:false
```

Listing: BL115-5466_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name "notListedCgisAllowed" -value "False"
```

Listing: BL115-5466_I03_01.ps1

C01 - GUI Check Example

Browse to and open the `applicationHost.config` file and verify that the `notListedCgisAllowed` attribute in the `<isapiCgiRestriction>` element is set to `false`:

```
<system.webServer>
  <security>
    <isapiCgiRestriction notListedCgisAllowed="false">
    </isapiCgiRestriction>
  </security>
</system.webServer>
```

Listing: BL115-5466_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/isapiCgiRestriction" -name "notListedCgisAllowed"
```

Listing: BL115-5466_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.10

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-4641

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'Dynamic IP Address Restrictions' is Enabled

Rule

Ensure 'Dynamic IP Address Restrictions' is enabled.

Description

IIS Dynamic IP Address Restrictions capability can be used to thwart DDos attacks. This is complimentary to the IP Addresses and Domain names Restrictions lists that can be manually maintained within IIS. In contrast, Dynamic IP address filtering allows administrators to configure the server to block access for IPs that exceed the specified request threshold. The default action Deny action for restrictions is to return a Forbidden response to the client.

Rationale

Dynamic IP address filtering allows administrators to configure the server to block access for IPs that exceed the specified number of requests or requests frequency. Ensure that you receive the Forbidden page once the block has been enforced.

I01 - GUI Implementation Example

1. Open IIS Manager.
2. Open the IP Address and Domain Restrictions feature.
3. Click Edit Dynamic Restrictions Settings..
4. Check the Deny IP Address based on the number of concurrent requests and the Deny IP Address based on the number of requests over a period of time boxes. The values can be tweaked as needed for your specific environment.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "enabled" -value "True"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "maxConcurrentRequests" -
value <number of requests>
```

Listing: BL115-4641_I02_01.ps1

C01 - Manual Check Example

Access the web server enough times to trigger the IP restriction based on the settings entered.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "enabled"
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/security/dynamicIpSecurity/denyByConcurrentRequests" -name "maxConcurrentRequests"
```

Listing: BL115-4641_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 4.11

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS.

BL115-3243

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Block SQL Injections

Rule Add a blocking list to the `<requestFiltering>` rules with following conditions:

- The blocking applies to the file extensions `.asp`, `.aspx`, and `.php`,
- The list blocks the following terms: `--`, `;`, `/*`, `@`, `@@version`, `char`, `alter`, `begin`, `bchar`, `cast`, `char`, `Connect`, `create`, `cursor`, `count`, `convert`, `DBNETLIB`, `declare`, `delete`, `drop`, `end`, `exec`, `fetch`, `insert`, `int%2c`, `kill`, `open`, `select`, `(SeLeCt`, `sqlmap`, `sys`, `sysobjects`, `sysdatabases`, `table`, `update`.

E01 - Problematic terms for specific websites

As this rule is strict about blocking requests, there might be the problem for specific websites that this rule will block legitimate requests. If this is an issue for your content, it is possible to exclude **only** problematic terms for those websites which have problems with these terms. It is recommended to exclude those terms on a temporary base and to try solving the problem on application level instead. If you want to suspend the complete rule, you must apply for an exception using the **Exception Handling Tool**.

The reasons for the change have to be documented accordingly.

Description

SQL Injection became a favorite hacking technique in 2007. Despite being widely documented for so many years it continues to evolve and be utilized.

Rationale

A SQL injection attack involves the alteration of SQL statements that are used within a web application through the use of attacker-supplied data. Insufficient input validation and improper construction of SQL statements in web applications can expose them to SQL injection attacks.

I01 - GUI Implementation Example for the root "applicationhost.config" file

This implementation describes the default implementation for the complete webserver.

1. On the IIS, go to the root file of the configuration system.
By default, this is located in `C:\Windows\System32\inetsrv\config\`.
2. Open the file `applicationHost.config` in a text or XML editor.
3. Add the following lines in section `<system.webServer>` - `<security>` - `<requestFiltering>`:

```
<security>
  <requestFiltering>
    <filteringRules>
      <filteringRule name="SQLInjection_Server" scanUrl="false" scanQueryString="true">
        <appliesTo>
          <clear />
          <add fileExtension=".asp" />
          <add fileExtension=".aspx" />
          <add fileExtension=".php" />
        </appliesTo>
        <denyStrings>
          <clear />
          <add string="--" />
          <add string=";" />
          <add string="*" />
          <add string="@ " />
          <add string="@@version" />
          <add string="char" />
          <add string="alter" />
          <add string="begin" />
          <add string="bchar(" />
          <add string="cast(" />
          <add string="char(" />
          <add string="Connect(" />
          <add string="create" />
          <add string="cursor" />
          <add string="count(" />
          <add string="convert(" />
          <add string="DBNETLIB" />
          <add string="declare" />
          <add string="delete" />
          <add string="drop" />
          <add string="end" />
          <add string="exec" />
          <add string="fetch" />
          <add string="insert" />
          <add string="int%2c(" />
          <add string="kill" />
          <add string="open" />
          <add string="select" />
          <add string="(SeLeCt" />
          <add string="sqlmap" />
          <add string="sys" />
          <add string="sysobjects" />
          <add string="sysdatabases" />
          <add string="table" />
          <add string="update" />
        </denyStrings>
        <scanHeaders>
          <clear />
        </scanHeaders>
      </filteringRule>
    </filteringRules>
  </requestFiltering>
</security>
```

Listing: BL115-3243_I01_01.config

4. Save the file.

Note: The <scanHeaders> directive has been added as there is no need to filter the http headers for SQL commands. If you require the filtering of http headers in your configuration, you can disregard the above <scanHeaders> directive.

The request filter logs all blocked requests in the IIS W3SVC logs. Rejections triggered by a filteringRule will have a status of 404 with a substatus 19. Check these logs periodically to see if you've been getting requests with SQL Injection attempts and to adjust a rule that may be blocking legitimate requests.

I02 - GUI Implementation Example for a "web.config" file

This implementation describes the implementation if specific requests cause a problem for specific websites. However, you need to apply *Implementation I01* first.

1. Remove any overly restrictive strings from the `<filteringRule>` in above `applicationhost.config` file, so that the term will not be blocked anymore for *all* websites - as an example remove the line `<add string="end" />`.
2. For those websites where *no* problems occur with the blocking of the string `end` perform following steps:
 1. Open the file `web.config` for this website in a text or XML editor.
 2. Add the following lines in section `<system.webServer>` - `<security>` - `<requestFiltering>`:

```
<security>
  <requestFiltering>
    <filteringRules>
      <filteringRule name="SQLInjection_Website" scanUrl="false" scanQueryString="true">
        <appliesTo>
          <add fileExtension=".asp" />
          <add fileExtension=".aspx" />
          <add fileExtension=".php" />
        </appliesTo>
        <denyStrings>
          <add string="end" />
        </denyStrings>
        <scanHeaders>
          <clear />
        </scanHeaders>
      </filteringRule>
    </filteringRules>
  </requestFiltering>
</security>
```

Listing: BL115-3243_I02_01.config

3. Save the file.
Note: The `<scanHeaders>` directive has been added as there is no need to filter the http headers for SQL commands. If you require the filtering of http headers in your configuration, you can disregard the above `<scanHeaders>` directive.

I03 - Command Line Implementation Example for the root "applicationhost.config" file

This implementation describes the default implementation for the complete webserver.

Enter the following command in `AppCmd.exe` to configure:

```
SET APPCMD="%systemroot%\system32\inetsrv\apcmd.exe"
REM Deleting filteringRules SQLInjection_Server
%APPCMD% set config -section:system.webServer/security/requestFiltering /-"filteringRules.
[name='SQLInjection_Server']"
REM Adding new filteringRules SQLInjection_Server
%APPCMD% set config -section:system.webServer/security/requestFiltering /+"filteringRules.
[name='SQLInjection_Server',scanUrl='False',scanQueryString='True']"
REM Adding <appliesTo> directive
%APPCMD% set config -section:system.webServer/security/requestFiltering /~"filteringRules.
[name='SQLInjection_Server'].appliesTo
FOR %S IN (".asp",".aspx",".php") DO (
    %APPCMD% set config -section:system.webServer/security/requestFiltering /+"filteringRules.
[name='SQLInjection_Server'].appliesTo.[fileExtension='%S']"
)
REM Adding <denyStrings> directive
%APPCMD% set config -section:system.webServer/security/requestFiltering /~"filteringRules.
[name='SQLInjection_Server'].denyStrings
FOR %S IN ("--
",",",",","/,%2A","@","@@version","char","alter","begin","bchar(","cast(","char(","Connect(","create","curso
r","count(","convert(","DBNETLIB","declare","delete","drop","end","exec","fetch","insert","int%252c(","
kill","open","select","(SeLeCt","sqlmap","sys","sysobjects","sysdatabases","table","update") DO (
    %APPCMD% set config -section:system.webServer/security/requestFiltering /+"filteringRules.
[name='SQLInjection_Server'].denyStrings.[string='%S']"
)
REM Adding <scanHeaders> directive
%APPCMD% set config -section:system.webServer/security/requestFiltering /~"filteringRules.
[name='SQLInjection_Server'].scanHeaders
```

Listing: BL115-3243_I03_01.cmd

Note: The <scanHeaders> directive has been added as there is no need to filter the http headers for SQL commands. If you require the filtering of http headers in your configuration, you can disregard the above <scanHeaders> directive (which is the last line of the listing).

The request filter logs all blocked requests in the IIS W3SVC logs. Rejections triggered by a filteringRule will have a status of 404 with a substatus 19. Check these logs periodically to see if you've been getting requests with SQL Injection attempts and to adjust a rule that may be blocking legitimate requests.

I04 - Command Line Implementation Example for a "web.config" file

This implementation describes the implementation if specific requests cause a problem for specific websites. However, you need to apply *Implementation I03* first.

1. Remove any overly restrictive strings from the <filteringRule> in above applicationhost.config file, so that the term will not be blocked anymore for all websites - as an example remove the line
<add string="end" />:

```
SET APPCMD="%systemroot%\system32\inetsrv\apcmd.exe"
%APPCMD% set config -section:system.webServer/security/requestFiltering /-"filteringRules.
[name='SQLInjection_Server'].denyStrings.[string='end']"
```

Listing: BL115-3243_I04_01.cmd

2. For those websites where *no* problems occur with the blocking of the string end enter the following command in AppCmd.exe to configure:

```
SET APPCMD="%systemroot%\system32\inetsrv\appcmd.exe"
REM Please enter the name of the website which shall be configured
SET MYSITE("<name of the website>")
REM Deleting filteringRules SQLInjection_Website
%APPCMD% set config %MYSITE% -section:system.webServer/security/requestFiltering /-
"filteringRules.[name='SQLInjection_Website']"
REM Adding new filteringRules SQLInjection_Website
%APPCMD% set config %MYSITE% -section:system.webServer/security/requestFiltering
/+"filteringRules.[name='SQLInjection_Website',scanUrl='False',scanQueryString='True']"
REM Adding <appliesTo> directive
FOR %S IN (".asp",".aspx",".php") DO (
    %APPCMD% set config %MYSITE% -section:system.webServer/security/requestFiltering
    /+"filteringRules.[name='SQLInjection_Website'].appliesTo.[fileExtension='%S']"
)
REM Adding <denyStrings> directive
%APPCMD% set config %MYSITE% -section:system.webServer/security/requestFiltering
/+"filteringRules.[name='SQLInjection_Website'].denyStrings.[string='end']"
REM Adding <scanHeaders> directive
%APPCMD% set config %MYSITE% -section:system.webServer/security/requestFiltering
/~"filteringRules.[name='SQLInjection_Website'].scanHeaders

Listing: BL115-3243_I04_02.cmd
```

Note: The <scanHeaders> directive has been added as there is no need to filter the http headers for SQL commands. If you require the filtering of http headers in your configuration, you can disregard the above <scanHeaders> directive (which is the last line of the listing).

C01 - GUI Check Example for the root "applicationhost.config" file

Check the root file `applicationHost.config` of the configuration system that it contains the `fileExtensions` and `denyStrings` as listed in *Implementation* section *I01*.

C02 - GUI Check Example for a "web.config" file

In case specific `denyStrings` are missing in the root file, check the file `web.config` for those websites where more restrictive settings apply to that it contains the `fileExtensions` and `denyStrings` which are not part of the root file `applicationHost.config`.

C03 - Command Line Check Example for the root "applicationhost.config" file

Enter the following command in `AppCmd.exe` to check:

```
SET APPCMD="%systemroot%\system32\inetsrv\appcmd.exe"
%APPCMD% list config -section:system.webServer/security/requestFiltering

Listing: BL115-3243_C03_01.cmd
```

Check the output that it contains the `fileExtensions` and `denyStrings` as listed in *Implementation* section *I01*.

Note: The command does not list the `<clear />` statements and may list the directives in a different order.

C04 - Command Line Check Example for a "web.config" file

In case specific `denyStrings` are missing in the root file, enter the following command in `AppCmd.exe` to check:

```
SET APPCMD="%systemroot%\system32\inetsrv\apcmd.exe"  
REM Please enter the name of the website which shall be configured  
SET MYSITE="<name of the website>"  
%APPCMD% list config %MYSITE% -section:system.webServer/security/requestFiltering
```

Listing: BL115-3243_C04_01.cmd

Check the output for those websites where more restrictive settings apply to that it contains the fileExtensions and denyStrings which are not part of the root file applicationHost.config.

Note: The command does not list the <clear /> statements and may list the directives in a different order.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. Changed during review: Reworded the Exemption to make clear that this exemption is only for problematic terms for specific websites.

BL115-4971

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Deny Directory Traversal

Rule

Deny directory traversal by adding the sequence `..` to the deny list.

Description

Using this rule, an application can be protected from directory traversal by simply adding the URL sequence `..` to the deny list, even the application's code doesn't deal with that kind of vulnerabilities. This rule is only a simple way to defend against directory traversal attacks. There are also other methods, like e.g., restricting users with Access Control Lists (ACLs) (see [BL115-0846](#)).

Rationale

This attack is to use an affected application to gain unauthorized access to the file system and access restricted files or directories and execute commands outside of the web server's root directory. Directory traversal is also known as the *../ attack, directory climbing, and backtracking*.

I01 - GUI Implementation Example

1. On the IIS, go to the root file of the configuration system. By default, this is located in `C:\Windows\System32\inetsrv\config\`.
2. Open the file `applicationHost.config` in a text or XML editor.
3. Add the following lines in section `<system.webServer>` - `<security>` - `<requestFiltering>`:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence=".." />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4971_I01_01.config

4. Save the file.

I02 - Command Line Implementation Example

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/requestFiltering
/+"denyUrlSequences.[sequence='..']"
```

Listing: BL115-4971_I02_01.cmd

C01 - GUI Check Example

Browse to and open the `applicationHost.config` file and verify that the line `<add sequence=".." />` is included within the `<denyUrlSequences>` section:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence=".." />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4971_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -
section:system.webServer/security/requestFiltering"
```

Listing: BL115-4971_C02_01.cmd

The output should include `<add sequence=".." />` within the `<denyUrlSequences>` section.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. Changed during review: Reworded parts of the Description for better understanding.

BL115-4972

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Deny Alternate Data Streams

Rule

Deny Alternate Data Streams by adding the sequence : to the deny list.

Description

With *NTFS* Microsoft added the functionality to add alternate data streams to any file and accessing those by adding :<name of the data stream> to the filename.

Rationale

An attacker could hide malicious code in an alternate data stream, upload the file to the webserver, and bypassing any security controls (if they are not able to handle alternate data streams). Afterwards he or she could use this malicious code to, e.g., gain access to the webserver.

I01 - GUI Implementation Example

1. On the IIS, go to the root file of the configuration system. By default, this is located in C:\Windows\System32\inetsrv\config\.
2. Open the file `applicationHost.config` in a text or XML editor.
3. Add the following lines in section `<system.webServer>` - `<security>` - `<requestFiltering>`:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence=":" />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4972_I01_01.config

4. Save the file.

I02 - Command Line Implementation Example

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/requestFiltering /+"denyUrlSequences.[sequence=':']"
```

Listing: BL115-4972_I02_01.cmd

C01 - GUI Check Example

Browse to and open the `applicationHost.config` file and verify that the line `<add sequence=":" />` is included within the `<denyUrlSequences>` section:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence=":" />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4972_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -
section:system.webServer/security/requestFiltering"
```

Listing: BL115-4972_C02_01.cmd

The output should include `<add sequence=":" />` within the `<denyUrlSequences>` section.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO.

BL115-4973

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Deny Backslashes in URLs

Rule

Deny backslashes in URLs by adding the sequence \ to the deny list.

Description

Using this rule, an application can be protected from directory traversal by simply adding the URL sequence \ to the deny list, even the application's code doesn't deal with that kind of vulnerabilities. This rule is only a simple way to defend against directory traversal attacks. There are also other methods, like e.g., restricting users with Access Control Lists (ACLs) (see [BL115-0846](#)).

Rationale

This attack is to use an affected application to gain unauthorized access to the file system and access restricted files or directories and execute commands outside of the web server's root directory.

I01 - GUI Implementation Example

1. On the IIS, go to the root file of the configuration system. By default, this is located in `C:\Windows\System32\inetsrv\config\`.
2. Open the file `applicationHost.config` in a text or XML editor.
3. Add the following lines in section `<system.webServer>` - `<security>` - `<requestFiltering>`:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence="\ " />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4973_I01_01.config

4. Save the file.

I02 - Command Line Implementation Example

Enter the following command in `AppCmd.exe` to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/security/requestFiltering
/+"denyUrlSequences.[sequence='\']"
```

Listing: BL115-4973_I02_01.cmd

C01 - GUI Check Example

Browse to and open the `applicationHost.config` file and verify that the line `<add sequence="\ " />` is included within the `<denyUrlSequences>` section:

```
<system.webServer>
  <security>
    <requestFiltering>
      <denyUrlSequences>
        <add sequence="\ " />
      </denyUrlSequences>
    </requestFiltering>
  </security>
</system.webServer>
```

Listing: BL115-4973_C01_01.config

C02 - Command Line Check Example

To verify using `AppCmd.exe` enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -
section:system.webServer/security/requestFiltering"
```

Listing: BL115-4973_C02_01.cmd

The output should include `<add sequence="\ " />` within the `<denyUrlSequences>` section.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. Changed during review: Reworded parts of the Description for better understanding.

IIS Logging

This section contains recommendations regarding IIS logging that have not been covered in the Basic Configurations section.

BL115-5441

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Default IIS web log location is moved

Rule

Ensure Default IIS web log location is moved to a restricted, non-system drive or partition.

E01 - Exemption

This rule can be omitted, if the log files are regularly copied to a different server/location (e.g., Intrusion detection service).

Description

IIS will log relatively detailed information on every request. These logs are usually the first item looked at in a security response, and can be the most valuable. Malicious users are aware of this and will often try to remove evidence of their activities.

Rationale

Moving IIS logging to a restricted, non-system drive will help mitigate the risk of logs being maliciously altered, removed, or lost in the event of system drive failure(s).

I01 - Command Line Implementation Example

Moving the default log location can be easily accomplished using `AppCmd.exe`.

To change to `D:\LogFiles` use the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:sites -  
siteDefaults.logfile.directory:"D:\LogFiles"
```

Listing: BL115-5441_I01_01.cmd

Moving log file stores to a non-system drive or partition separate from where web applications run and/or content is served is preferred.

While standard IIS logs can be moved and edited using IIS Manager, additional management tool add-ons are required in order to manage logs generated by other IIS features, such as Request Filtering. These add-ons can be obtained using the Web Platform Installer or from Microsoft's site. The HTTPErr logging location can be changed by adding a registry key.

I02 - PowerShell Implementation Example

Moving the default log location can be easily accomplished using PowerShell.

To change to D:\LogFiles enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/logFile" -name "directory" -value "D:\LogFiles"
```

Listing: BL115-5441_I02_01.ps1

Moving log file stores to a non-system drive or partition separate from where web applications run and/or content is served is preferred. While standard IIS logs can be moved and edited using IIS Manager, additional management tool add-ons are required in order to manage logs generated by other IIS features, such as Request Filtering. These add-ons can be obtained using the Web Platform Installer or from Microsoft's site. The HTTPErr logging location can be changed by adding a registry key.

C01 - Manual Check Example

To verify web logs are being logged to the new location, open Windows Explorer and browse to the path that was defined. Depending on how the logging was configured, there will be either:

- A folder containing .log files or
- .log files in the root of the specified directory

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/logFile" -name "directory"
```

Listing: BL115-5441_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 5.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified the rule more precisely; added an exemption. Changed during review:
Removed the comment regarding Advanced Logging as Microsoft included this functionality in IIS 8.5.

BL115-4386

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure Enhanced Logging for IIS

Rule

- Ensure Enhanced Logging for IIS is enabled.
- Make sure the following fields will be logged: Date, Time, Client IP Address, User Name, Service Name, Server Name, Server IP Address, Server Port, Method, URI Stem, URI Query, Protocol Status, Protocol Substatus, Win32 Status, Bytes Sent, Bytes Received, Time Taken, Protocol Version, Host, User Agent, Referer.

Description

Enhanced Logging for IIS has been introduced by Microsoft with IIS 8.5 and provides flexibility in logging requests and client data. It provides controls that allow businesses to specify what fields are important, easily add additional fields, and provide policies pertaining to log file rollover and Request Filtering. HTTP request/response headers, server variables, and client-side fields can be easily logged with minor configuration in the IIS management console.

Rationale

Many of the fields available in Enhanced Logging for IIS many can provide extensive, real-time data and details not otherwise obtainable. Developers and security professionals can use this information to identify and remediate application vulnerabilities/attack patterns.

I01 - GUI Implementation Example

Enhanced Logging for IIS can be configured for servers, Web sites, and directories in IIS Manager. To enable Enhanced Logging for IIS using the UI:

1. Open Internet Information Services (IIS) Manager.
2. Click the server in the **Connections** pane.
3. Double-click the **Logging** icon on the **Home** page.
4. Click **Select Fields**.
5. Enable all fields outlined in the table below:

GUI Name	Field name	Description
Date	Date	The date of the request
Time	Time	The time (in UTC) of the request
Client IP Address	ClientIP	IP address of the client
User Name	UserName	Logon name of the user accessing the web server
Service Name	SiteName	Name of the Service that fulfilled the request
Server Name	ComputerName	Name of the Server
Server IP Address	ServerIP	IP address of the server
Server Port	ServerPort	Port to which the client connects
Method	Method	HTTP verb used for request
URI Stem	UriStem	IIS path to the requested file, script or folder

URI Query	UriQuery	String after the URI stem
Protocol Status	HttpStatus	HTTP status response code from server to client
Protocol Substatus	HttpSubStatus	HTTP Substatus response code from server to client
Win32 Status	Win32Status	Operating system response code
Bytes Sent	BytesSent	The number of bytes that the server sent
Bytes Received	BytesRecv	The number of bytes that the server received
Time Taken	TimeTaken	Length of time that the action took in milliseconds
Protocol Version	ProtocolVersion	Protocol version used by the client
Host	Host	Host header [if any]
User Agent	UserAgent	Logs the browser from which the request came
Referer	Referer	URL of the site that the user last visited and which provided a link to the current site

Note: In above table you can find the names being used in the *Fields* dialog box, and the *field names* to be used with the PowerShell command. Please consider that the *field names* are case-sensitive.

6. Use the *Directory* box to specify where to store the log files. Confirm the settings by clicking *Apply* in the *Actions* pane.

To disable IIS logging for single files and folders mark them (*Content View*), right-click and select *Switch to Features View*, and double-click the *Logging* icon. To disable logging select *Disable* in the *Actions* pane.

Note: There may be performance considerations depending on the extent of the configuration.

Note #2: It is recommended to use the W3C log file format which is a customizable ASCII format with a variety of different properties. Another advantage of the W3C format is the fact that it is using GMT time for logging instead of local system time which makes analysis and correlation of different log files easier.

I02 - PowerShell Implementation Example

To configure the fields to be logged enter the following commands in PowerShell:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -Filter System.Applicationhost/Sites/SiteDefaults/logfile -Name
LogExtFileFlags -Value
"Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,ServerPort,Method,UriStem,UriQuery,HttpStatus
s,HttpSubStatus,Win32Status,BytesSent,BytesRecv,TimeTaken,ProtocolVersion,Host,UserAgent,Referer"
```

Listing: BL115-4386_I02_01.ps1

C01 - GUI Check Example

To verify that the correct fields are being logged, perform following steps:

1. Open the Event Viewer.
2. Expand the *Applications and Services Logs*.
3. Expand *Microsoft*, expand *Windows*, scroll down to *IIS-Logging*, and select it.
4. In the middle part of the window you will find an overview table.
5. The column *Number of Events* should list a value higher than 0.
6. Double-click on the row *Logs* and select in the next windows the first entry.
7. It will show you in the lower part of the middle *Logs* window in the tab *General* the fields which have been recorded. Verify that all required fields have been logged.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -Filter System.Applicationhost/Sites/SiteDefaults/logfile -Name
LogExtFileFlags
```

Listing: BL115-4386_C02_01.ps1

The output should list following fields:

Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,Method,UriStem,UriQuery,HttpStatus,Win32Status,BytesSent,BytesRecv,TimeTaken,ServerPort,UserAgent,Referer,ProtocolVersion,Host,HttpSubStatus

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 5.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added fields to be logged from IIS 8.x measure M383919, but removed the field 'Cookie' as this could impose a security risk. Also removed the field 'Client Port' as this is only relevant for the FTP module. Added PowerShell scripts to ease implementation. Rewrote *Check C01* (from CIS) as it does not make sense this way. Changed during review: Renamed the feature *Advanced Logging* to *Enhanced Logging*; removed the comment to enable this feature as Microsoft integrated this functionality already in IIS 8.5.

BL115-3441

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'ETW Logging' is Enabled

Rule

Ensure 'ETW Logging' is enabled.

Description

IIS supports an additional logging method. Administrators have the option to send logging information to Event Tracing for Windows (ETW). This provides an advantage over text-based log files that are not updated in real time.

Rationale

IIS flushes log information to disk, therefore prior to IIS, administrators do not have access to real-time logging information. Text-based log files can also be difficult and time consuming to process. By enabling ETW, administrators have access to use standard query tools for viewing real-time logging information.

I01 - GUI Implementation Example

To configure ETW logging:

1. Open IIS Manager.
2. Select the server or site to enable ETW.
3. Select Logging.
4. Ensure Log file format is W3C.
5. Select either ETW event only or Both log file and ETW event.
6. Save your settings.

I02 - PowerShell Implementation Example

Changing the log file format can be easily accomplished using PowerShell.

To change to W3C enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.applicationHost//log" -
name "CentralLogFileMode" -value "CentralW3C"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter 'system.applicationHost/log' -
name "centralW3CLogFile.directory" -value "D:\LogFiles"
```

Listing: BL115-3441_I02_01.ps1

C01 - Manual Check Example

Using Message Analyzer, configure the query for Microsoft-Windows-IIS-Logging. Verify you see live logging data by accessing the website.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.applicationHost/log" -
name "CentralLogFileMode"
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter "system.applicationHost/log" -
name "centralW3CLogFile.directory"
```

Listing: BL115-3441_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 5.3

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified the *Description* section more precisely; allowed both ETW settings in the *Implementation* section; added PowerShell scripts.

BL115-0987

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'IIS-Configuration' Logging is Enabled

Rule

- Ensure IIS-Configuration logging is enabled.
- Increase the Maximum Log Size to at least 36032 KB.

Description

When enabled, you can monitor the changes that are done to the IIS configuration store. It generates event messages which show the configuration element which has been changed, the user who initiated the change, and the original as well as the new value of the element.

Rationale

Many of the fields available in IIS-Configuration Logging can provide extensive, real-time data and details not otherwise obtainable. Developers and security professionals can use this information to identify and remediate application vulnerabilities/attack patterns.

IO1 - Implementation Example

The 'IIS-Configuration' logging cannot be set by a Group policy and needs to be configured manually:

1. Open the Event Viewer.
2. Expand the Applications and Services Logs.
3. Expand Microsoft, and expand Windows.
4. Select IIS-Configuration, and select Properties in the Actions Pane.
5. Click on Enable Logging.
6. Increase the Maximum Log Size to at least 36032 KB.
7. Confirm by clicking OK.

C01 - Example Check

To verify 'IIS-Configuration' is being logged, perform following steps:

1. Open the Event Viewer.
2. Expand the Applications and Services Logs.
3. Expand Microsoft, expand Windows, scroll down to IIS-Configuration, and select it.
4. In the middle part of the window you will find an overview table.
5. The column Number of Events should list a value higher than 0 at least for one event Type (Administrative or Operational).

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383987; removed the part regarding Windows Server logging as this is already demanded by the OS Security Measure Plan.

BL115-1957

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure Default FTP log location is moved

Rule

Ensure Default FTP log location is moved to a restricted, non-system drive or partition.

E01 - Exemption

This rule can be omitted if you do **not** have the Server Role "FTP Server" installed.

E02 - Exemption

This rule can be omitted, if the log files are regularly copied to a different server/location (e.g., Intrusion detection service).

Description

IIS will log relatively detailed information on every request. These logs are usually the first item looked at in a security response, and can be the most valuable. Malicious users are aware of this, and will often try to remove evidence of their activities.

Rationale

Moving FTP logging to a restricted, non-system drive will help mitigate the risk of logs being maliciously altered, removed, or lost in the event of system drive failure(s).

I01 - Command Line Implementation Example

Moving the default log location can be easily accomplished using `AppCmd.exe`.

To change to `D:\LogFiles` use the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:sites -  
siteDefaults.ftpServer.logfile.directory:"D:\LogFiles"
```

Listing: BL115-1957_I01_01.cmd

Moving log file stores to a non-system drive or partition separate from where web applications run and/or content is served is preferred.

While standard IIS logs can be moved and edited using IIS Manager, additional management tool add-ons are required in order to manage logs generated by other IIS features, such as Request Filtering. These add-ons can be obtained using the Web Platform Installer or from Microsoft's site. The HTTPError logging location can be changed by adding a registry key.

I02 - PowerShell Implementation Example

Moving the default log location can be easily accomplished using PowerShell.

To change to D:\LogFiles enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/logFile" -name "directory" -value "D:\LogFiles"
```

Listing: BL115-1957_I02_01.ps1

Moving log file stores to a non-system drive or partition separate from where web applications run and/or content is served is preferred.

While standard IIS logs can be moved and edited using IIS Manager, additional management tool add-ons are required in order to manage logs generated by other IIS features, such as Request Filtering. These add-ons can be obtained using the Web Platform Installer or from Microsoft's site. The HTTPError logging location can be changed by adding a registry key.

C01 - Manual Check Example

To verify web logs are being logged to the new location, open Windows Explorer and browse to the path that was defined. Depending on how the logging was configured, there will be either:

- A folder containing .log files or
- .log files in the root of the specified directory

Note that logs will be written to disk after a non-determined period of time.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/logFile" -name "directory"
```

Listing: BL115-1957_C02_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 5.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS, but adapted it for 'default FTP log location'; specified the rule more precisely; added an exemption. Changed during review: Removed the comment regarding Advanced Logging as Microsoft integrated this functionality already in IIS 8.5.

BL115-1956

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'FTP Logging' is enabled

Rule

- Ensure FTP logging is enabled.
- Make sure the following fields will be logged: Date, Time, Client IP Address, User Name, Service Name, Server Name, Server IP Address, Server Port, Method, URI Stem, Protocol Status, Protocol Substatus, Win32 Status, Bytes Sent, Bytes Received, Time Taken, Host, Client Port.

E01 - Exemption

This rule can be omitted if you do **not** have the Server Role "FTP Server" installed.

Description

In addition to the Windows Server system and security logs, IIS provides application logging as well. These logs provide valuable information that can be used to identify any unauthorized attempts to compromise the Web server.

Rationale

Many of the fields available in FTP Logging can provide extensive data and details not otherwise obtainable. Developers and security professionals can use this information to identify and remediate application vulnerabilities/attack patterns.

I01 - GUI Implementation Example

IIS FTP Logging can be configured for servers, Web sites, and directories in IIS Manager. To enable FTP Logging using the UI:

1. Open IIS Manager.
2. Click the server in the Connections pane.
3. Double-click the FTP Logging icon on the Home page.
4. Click Select W3C Fields.
5. Enable all fields outlined in the table below:

GUI Name	Field name	Description
Date	Date	The date of the request
Time	Time	The time (in UTC) of the request
Client IP Address	ClientIP	IP address of the client
User Name	UserName	Logon name of the user accessing the web server
Service Name	SiteName	Name of the Service that fulfilled the request
Server Name	ComputerName	Name of the Server

Server IP Address	ServerIP	IP address of the server
Method	Method	HTTP verb used for request
URI Stem	UriStem	IIS path to the requested file, script or folder
Protocol Status	FtpStatus	FTP status response code from server to client
Win32 Status	Win32Status	Operating system response code
Bytes Sent	BytesSent	The number of bytes that the server sent
Bytes Received	BytesRecv	The number of bytes that the server received
Time Taken	TimeTaken	Length of time that the action took in milliseconds
Server Port	ServerPort	Port to which the client connects
Host	Host	Host header [if any]
Protocol Substatus	FtpSubStatus	FTP Substatus response code from server to client
Client Port	ClientPort	Port which is used by the client

Note: In above table you can find the names being used in the *Fields* dialog box, and the *field names* to be used with the PowerShell command. Please consider that the *field names* are case-sensitive.

6. Use the *Directory* box to specify where to store the log files. Confirm the settings by clicking *Apply* in the *Actions* pane.

To disable IIS logging for single files and folders mark them (*Content View*), right-click and select *Switch to Features View*, and double-click the *Logging* icon. To disable logging select *Disable* in the *Actions* pane.

Note: There may be performance considerations depending on the extent of the configuration. It is recommended to use the W3C log file format which is a customizable ASCII format with a variety of different properties. Another advantage of the W3C format is the fact that it is using GMT time for logging instead of local system time which makes analysis and correlation of different log files easier.

I02 - PowerShell Implementation Example

To configure the fields to be logged enter the following commands in PowerShell:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/logfile" -name "logExtFileFlags" -value
"Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,Method,UriStem,FtpStatus,Win32Status,BytesSe
nt,BytesRecv,TimeTaken,ServerPort,Host,FtpSubStatus,ClientPort"
```

Listing: BL115-1956_I02_01.ps1

Note: The above script configures the settings for the server. If you want to configure the settings for a specific website, you need to replace *siteDefaults/ftpServer/logfile* with *site[@name='<name of the website>']/ftpServer/logFile*. The script could look like this:

```
Import-Module WebAdministration
# Please enter the name of your FTP site
$FTPSite = "<name of the website>"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/site[@name='$FTPSite']/ftpServer/logFile" -name "logExtFileFlags" -value
"Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,Method,UriStem,FtpStatus,Win32Status,BytesSe
nt,BytesRecv,TimeTaken,ServerPort,Host,FtpSubStatus,ClientPort"
```

Listing: BL115-1956_I02_02.ps1

C01 - GUI Check Example

Browse to the location of the IIS Logs and verify .log files are being generated. Note that logs will be written to disk after a non-determined period of time. They can be written into their specified directory immediately if, in the Log Definition, the Publish real-time events and Write to disk options are selected.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/logfile" -name "logExtFileFlags"
```

Listing: BL115-1956_C02_01.ps1

The output should list following fields:

Date,Time,ClientIP,UserName,SiteName,ComputerName,ServerIP,Method,UriStem,FtpStatus,Win32Status,BytesSent,BytesRecv,TimeTaken,ServerPort,Host,FtpSubStatus,ClientPort

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created by Siemens CYS PRO. Changed during review: Removed the comment regarding Advanced Logging as Microsoft integrated this functionality already in IIS 8.5.

BL115-0192

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure 'NTFS Auditing' is Enabled

Rule

Ensure 'NTFS Auditing' is enabled for every web content folder.

Description

The NTFS file system allows fine-grained audit settings on volume, folder and file level. For each object, multiple properties can be configured. Log entries are created for successful or failed events and are displayed in the event viewer Security log.

Rationale

NTFS auditing enables to record relevant changes to the NTFS file structure which can provide valuable information together with other security relevant log files.

I01 - Implementation Example

To configure 'NTFS Auditing' perform following steps for every web content folder:

1. Open the IIS Manager.
2. Select the corresponding *website* and select Edit Permissions in the Actions pane.
3. In the Properties dialog box select the tab Security and click Advanced.
4. Select the Auditing tab.
5. Click on the Add button, then select in the next dialog box Select a principal.
6. Enter the Everyone group and configure the following settings:
 - Applies to -> This folder, subfolders and files
 - Type -> Fail -> Select Full control to select all entries and then OK to activate the settings.
7. Again, click on the Add button and enter the Everyone group with following settings:
 - Applies to -> This folder, subfolders and files
 - Type -> All -> Select Show Advanced permissions and select following entries:
 - Create files / write data,
 - Create folders / append data,
 - Delete subfolders and files,
 - Delete,
 - Change Permissions,
 - Take ownership,
 - Again, select OK to activate these settings.
8. In the Advanced Security Settings window select the option Replace all child object auditing entries with inheritable auditing entries from this object and select OK to activate these settings.

C01 - Example Check

To verify 'NTFS Auditing' is configured correctly for every web content folder:

1. Open the IIS Manager.
2. Select the corresponding *website* and select Edit Permissions in the Actions pane.
3. In the Properties dialog box select the tab Security and click Advanced.
4. Select the Auditing tab.
5. Verify that the following Auditing entries exist:
 - Type→ Fail, Principal → Everyone, Access → Full control, Applies to → This folder, subfolders and files;
 - Type → All, Principal → Everyone, Access → Special, Applies to → This folder, subfolders and files; double-click on the All entry, select Show Advanced permissions and verify that following entries are set:
 - Create files / write data,
 - Create folders / append data,
 - Delete subfolders and files,
 - Delete,
 - Change Permissions,
 - Take ownership.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383192; removed the part regarding Windows Server Auditing as this is already demanded by the OS Security Measure Plan.

FTP Requests

This section contains a crucial configuration setting for running file transfer protocol (FTP).

Keep in mind, that the FTP protocol has been developed at a time where security did not matter, so you should think twice if you really need it or if other services can be used instead.

BL115-0356

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure FTP Securely

Rule

Configure the FTP module as follows:

- Never grant **anonymous users** *Read* and *Write* access simultaneously on the same folder, but use a separate UPLOAD directory instead.
- If you offer an UPLOAD directory for users to store data on the server, set NTFS quotas for this directory.
- Configure a unique binding in a way that IIS listens only to those IP addresses which it shall listen to (see [BL115-0725](#)).

E01 - Exemption

This rule can be omitted if you do **not** have the Server Role *FTP Server* installed.

Description

FTP is a protocol which enables the transfer of files from a client to the server.

Rationale

The FTP protocol has been developed at a time where security did not matter, so you should think twice if you really need it or if other services can be used instead.

I01 - GUI Implementation Example

Enable FTP:

1. Open the IIS Manager.
2. Either add a new FTP site (right-click in the *Connections* pane and select *Add FTP Site...*) or add this feature by right-clicking on an existing site and selecting *Add FTP Publishing...*

Please keep in mind that the option *Add FTP Publishing...* will make the directory structure of this website available through HTTP and FTP.

Configuring FTP in general:

You can configure FTP settings on server or on site level. While the FTP options on server level are accessible as soon as the FTP module has been installed you need to add an FTP site before getting access to the FTP site settings.

Preferably configure FTP Security settings for the whole server and lower settings only for those FTP sites where absolutely required.

As FTP content need to be stored on a dedicated disk volume (see [BL115-5716](#) for details), following registry settings need to be adjusted as well:

```
# Please enter your <new drive letter> and  
# your <destination path> without trailing  
$DestPath = "<new drive letter>:\<destination path>"  
New-ItemProperty -path 'HKLM:\Software\Microsoft\inetstp' -name 'PathFTPRoot' -value $DestPath -  
PropertyType 'String' -Force | Out-Null  
New-Item 'HKLM\Software\Wow6432Node\Microsoft\inetstp' -Force | Out-Null  
New-ItemProperty -path 'HKLM:\Software\Wow6432Node\Microsoft\inetstp' -name 'PathFTPRoot' -value  
$DestPath -PropertyType 'String' -Force | Out-Null
```

Listing: BL115-0356_I01_01.ps1

Note: After you have changed the settings in the registry, you need to restart the operating system.

Configure a unique binding:

For required configurations see [BL115-0725](#) and [BL115-2921](#).

Check FTP Authorization Rules:

The FTP Authorization Rules are available on site and folder level by double-clicking the `FTP Authorization Rules` icon. Here you can either add an `Allow Rule` or a `Deny Rule`.

Check Read/Write permissions:

Besides the `FTP Authorization Rules` you can set more restrictive NTFS permissions for the object.

1. Open the IIS Manager.
2. Select the corresponding FTP site in the `Connections` pane.
3. In the `Actions` pane select `Edit Permissions...` to access the NTFS permissions.

For further settings see [BL115-0846](#).

Configure disk quotas:

1. Open the Windows File Explorer.
2. Navigate to the partition which contains the `UPLOAD` directory.
3. Right-click on it and select `Properties`.
4. Select `Quota -> Show Quota Settings` and select `Enable quota management`.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383356; the requirements regarding *Clear text* have been removed, as we request with BL115-4651 that all FTP traffic will be encrypted. Also, the requirements regarding *Logon Attempt Restrictions* have been removed, as this is covered by rule BL115-1256. Finally, the requirements regarding *FTP logging* have been removed as this is covered by rule BL115-1956.

BL115-4651

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Ensure FTP Requests are Encrypted

Rule

Ensure FTP requests are encrypted.

E01 - Exemption

This rule can be omitted if you do **not** have the Server Role "FTP Server" installed.

Description

The new FTP Publishing Service for IIS supports adding an SSL certificate to an FTP site. Using an SSL certificate with an FTP site is also known as FTP-S or FTP over Secure Socket Layers (SSL). FTP-S is an RFC standard ([RFC4217]) where an SSL certificate is added to an FTP site and thereby making it possible to perform secure file transfers.

Rationale

By using SSL, the FTP transmission is encrypted and secured from point to point and all FTP traffic as well as credentials are thereby guarded against interception.

I01 - GUI Implementation Example

To secure an existing FTP site using an SSL Certificate, a certificate must first be installed on the system. Production systems should always use a third party certificate from a trusted root, such as VeriSign. Once that certificate is installed for use in IIS, follow the steps below to configure the FTP site for SSL:

1. Open IIS Manager, select the FTP server and choose FTP SSL Settings in the Features View pane
2. Under the SSL Certificate dropdown, choose the X.509 certificate to be configured for use
3. In the SSL Policy section, click the radio button next to Require SSL connections; it is important to require SSL, because allow SSL still permits non-SSL FTP
4. Click Apply in the Actions pane

I02 - Command Line Implementation Example

Configure FTP over SSL at the server level.

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.applicationHost/sites  
/siteDefaults.ftpServer.security.ssl.controlChannelPolicy:"SslRequire"  
/siteDefaults.ftpServer.security.ssl.dataChannelPolicy:"SslRequire" /commit:apphost
```

Listing: BL115-4651_I02_01.cmd

I03 - PowerShell Implementation Example

Configure FTP over SSL at the server level.

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name "controlChannelPolicy" -value
"SslRequire"
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name "dataChannelPolicy" -value
"SslRequire"
```

Listing: BL115-4651_I03_01.ps1

C01 - Manual Check Example

The FTP site will now require the use of FTP-S; test this by attempting to use an FTP client which either does not support FTP-S or is not configured to use FTP-S. If setup was successful, the request will fail. Conversely, open a command prompt from the server and type `ftp localhost`. After entering credentials, the server should return an 'Access is Denied' message.

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name "controlChannelPolicy"
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.applicationHost/sites/siteDefaults/ftpServer/security/ssl" -name "dataChannelPolicy"
```

Listing: BL115-4651_C02_01.ps1

The output should be `SslRequire` for both commands.

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 6.1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS. Added an exemption.

BL115-1256

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure FTP Logon Attempt Restrictions

Rule

- Ensure FTP Logon attempt restrictions is enabled.
- Set 'Maximum number of failed login attempts' to 10 and 'Time period' to 90 seconds.

E01 - Exemption

This rule can be omitted if you do **not** have the Server Role "FTP Server" installed.

Description

IIS introduced a built-in network security feature to automatically block brute force FTP attacks. This can be used to mitigate a malicious client from attempting a brute-force attack on a discovered account, such as the local administrator account.

Rationale

Successful brute force FTP attacks can allow an otherwise unauthorized user to make changes to data that should not be made. This could allow the unauthorized user to modify website code by uploading malicious software or even changing functionality for items such as online payments.

I01 - GUI Implementation Example

1. Open IIS Manager
2. At the server level, open the FTP Logon Attempt Restrictions feature.
3. Check Enable FTP Logon Attempt Restrictions and enter the maximum number of failed attempts and the time period. Enable Deny IP addresses based on the number of failed login attempts.
Select "Enable FTP Logon Attempt Restrictions"
 - Enter 10 for "Maximum number of failed login attempts"
 - Enter 90 for "Time period (in seconds)"
 - Select "Enable Deny IP addresses based on the numbers of failed login attempts"
4. Click Apply

I02 - Command Line Implementation Example

Enter the following command in AppCmd.exe to configure:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.ftpServer/security/authentication  
/denyByFailure.enabled:"True" /denyByFailure.maxFailure:"10" /denyByFailure.entryExpiration:"00:00:90"  
/commit:apphost
```

Listing: BL115-1256_I02_01.cmd

I03 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "enabled" -value "True"  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "maxFailure" -value 10  
Set-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "entryExpiration" -value "00:00:90"
```

Listing: BL115-1256_I03_01.ps1

C01 - Manual Check Example

Access your FTP server using the administrator account and an invalid password. Verify after the maximum number of login attempts has been met that you receive a message 'Connection closed by remote host' when trying to access FTP.

C02 - Command Line Check Example

To verify using AppCmd.exe enter the following command:

```
%systemroot%\system32\inetsrv\appcmd.exe list config -section:system.ftpServer/security/authentication
```

Listing: BL115-1256_C02_01.cmd

The output should include denyByFailure = true

C03 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration  
Get-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter  
"system.ftpServer/security/authentication/denyByFailure" -name "enabled"
```

Listing: BL115-1256_C03_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 6.2

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added request to set maximum failed login attempts and time period (from previous IIS 8.x measure M383356). Added an exemption.

Transport Encryption

This section contains recommendations for configuring IIS protocols and cipher suites.

For security protocols (SSL, TLS), there are 2 registry paths that control a protocol state in the O/S: TLS client and TLS server. A web server normally acts as the TLS server in that it is serving web content to clients. There are some instances where a web server is configured as a 'client'. An example of a server acting as a client can be seen when there is dynamic content generation. The webserver queries a remote database server to return content specific to a user's request. In this configuration, the web server is acting as a TLS client. In cases such as these, the configured TLS server protocol and cipher suite preferences take precedence over the client's.

If SSLv3 registry keys are not set, the O/S defaults take precedence.

For example, to disable SSLv3 protocol on the TLS server, you need to set the following registry key to 0:

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
3.0\Server\Enabled
```

To prevent a client from issuing the Hello command over that legacy protocol the following registry must be set to 0:

```
HKLM\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL  
3.0\Client\Enabled
```

The fact that the key is named Enabled can be confusing. The setting of the value to either 0 or 1 actually sets the state of the protocol. 0 being disabled and 1 being enabled.

Here are some specifics into how "Enabled" and "DisabledByDefault" registry settings work. The following article, [Transport Layer Security \(TLS\) registry settings](#), provides additional information related to controlling these protocols and ciphers.

Using the "Enabled = 0" registry setting disables the protocol in a way that can't be overridden by application settings. This is the only robust way to prevent the protocol from being used and no additional settings are required. At the same time, using the "DisabledByDefault" registry setting only prevents that protocol from issuing the Hello command over that protocol when an SSL connection with a server is initiated. This operating system level setting can be overridden by an application which has application specific TLS coding. An example of this can be shown by setting the protocol within a line of code in your .NET 4.5 application: `ServicePointManager.SecurityProtocol = SecurityProtocolType.Tls12`. This can override the O/S setting if the DisabledByDefault key is present. "DisabledByDefault" is useful in the case when you want to have some control over the system settings but also allow an application to explicitly specify the protocols they would like to use.

Enabled only works strongly in the negative case ("Enabled = 0"). If "Enabled=1" or is not set, then "DisabledByDefault" will override in the case where the application takes the system defaults. "Enabled=1" is also overridden by application specific protocol flags.

Note: Besides verifying the settings on the server itself, you could also scan the allowed protocols and ciphers from a different system.

On a Windows system you could use the following Tool: <https://github.com/rbsec/sslsan>.

BL115-0621

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Ensure the Usage of HTTPS

Rule

The use of HTTPS is **mandatory** for all HTTP-based web servers and web-based applications (internal and external).

Description

Transport Layer Security (TLS), and its predecessor Secure Sockets Layer (SSL) are cryptographic protocols which can be used to encrypt data sent between client and server. IIS supports Transport Layer Security (TLS), Secure Sockets Layer (SSL), and Datagram Transport Layer Security (DTLS).

In addition to encryption, TLS/SSL is used to:

- Authenticate the server to the client by using a server certificate,
- Authenticate the client to the server by using a client certificate (optional), and
- Verify that the data has not been modified during transmission.

Rationale

Establishing only a regular HTTP connection, the content of the website could be read or modified, putting you at risk. You are vulnerable to eavesdropping, DNS hijacking, and BGP attacks. Cryptographic keys and other secrets in the URL or query parameters could be recorded in logs or possibly even leaked to third parties in headers.

I01 - Implementation Example

Enable HTTPS on all websites by doing following tasks:

- Order a secure webserver certificate (see [BL115-0371](#)),
- Configure the HTTPS binding for every website (see [BL115-0725](#)),
- Configure the setting `Require SSL` for every website (see [BL115-1426](#)).

C01 - Example Check

Connect to the website by starting the 'Uniform Resource Locator' with the insecure scheme `http://` (e.g., `http://www.siemens.com`). You should be either redirected to the secure version of the website (starting with `https://`) or get no connection to the website at all.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383621; modified the rule such that HTTPS is now mandatory for all websites; removed the hint about WebDAV as there are security concerns with WebDAV (see BL115-0784)

BL115-0371

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Ensure Secure Certificate Handling

Rule

The following rules concerning the secure processing of server certificates must be obeyed for all web servers which provide websites with HTTPS protocol activated:

1. Use server certificates with a sufficient key length. The key pair of an RSA/DSA-based server certificate must have a length ≥ 2048 bits. In case of ECDSA-based certificates, a key length of ≥ 224 bits is adequate.
2. Ensure that a new key will be generated with every certificate order/renewal.
3. Ensure that the certificate contains the correct web server name (Fully Qualified Domain Name).
4. Ensure that the lifetime of the server certificate does not exceed 365 days.
5. Ensure that the server certificate has a valid time period.
6. Ensure that the chain of the server certificate is valid.
7. Only use server certificates from an official valid 'Server Registration Authority' (see Siemens Information Security Policy Framework [Rule 10.1.1-03](#)).
8. Protect the private key accordingly.

Description

Besides the usage of secure protocols and ciphers it is also crucial to ensure that a secure and valid Server certificate will be installed on web servers which have the HTTPS protocol enabled. This includes that the certificate contains the correct web server name (Fully Qualified Domain Name), that the certificate chain as well as the lifetime of the certificate is valid. Any error in the secure certificate handling will lead to an error message in the web browser which may irritate the user. Some web browsers even block access to websites with invalid certificates ensuring that the user does not connect to rogue websites.

Rationale

If the web server is equipped with a self-signed server certificate this can lead to security problems as well as self-generated server certificates can be faked easily tricking the user when connecting to this website.

Vulnerabilities like Heartbleed (<https://en.wikipedia.org/wiki/Heartbleed>) revealed once again that a secure handling of certificates is essential. This includes that with every certificate order/renewal a **new** key needs to be generated on the system. Additionally, the administrator needs to ensure that the private key of the server certificate will be adequately protected. If an attacker could retrieve the private key of a server certificate then all encryption measures remain useless.

I01 - Implementation Example

- **Create a Certificate Signing Request (CSR)**

1. Open IIS Manager
2. Click the server in the Connections pane
3. Double-click the *Server Certificates* icon on the Home page
4. Click *Create Certificate Request...* in the Actions Pane and follow the instructions.

Notes:

- Ensure to enter the "Fully Qualified Domain Name" in the field "Common Name" (e.g., when you generate a CSR for a website which will be later accessed via <https://www.siemens.com/>, enter `www.siemens.com` here).
- The key length will be defined with the creation of the Certificate Signing Request.

- **Obtain a server certificate:**

The order and renewal of the server certificate needs to be done at the *Siemens Server Registration Authority* (ServerRA) where detailed information about the ordering process is available.

- **Install the server certificate:**

Store the certificate file (e.g., `cert.cer`), which is included in the e-mail from the Server RA, on your file system. Open the IIS Manager, select the server (not a website) on which IIS runs in the Connections pane, and double-click the *Server Certificates* icon. Click *Complete Certificate Request* in the Actions pane and enter the file name and path to the certificate file from the Server RA. Type a name which helps you to identify the certificate in the *Friendly name* text box, and then select *OK*.

Note: You can either select the *Personal* or the *Web Hosting* store. The main difference between both is that the *Web Hosting* store is designed to scale to higher numbers of certificates which is beneficial if you want to manage multiple web servers with different certificates on a single server.

- **Ensure that the lifetime of the server certificate does not exceed 365 days.**

A reminder email will be sent by the Server RA before a server certificate (issued by the Server RA) expires, giving the certificate requester sufficient time to order a new certificate. With IIS 10 the administrator has the option to rebind automatically a renewed certificate by using the feature *Certificate Rebind*.

- **Ensure that the server certificate has a valid time period.**

1. Open IIS Manager
2. Click the server in the Connections pane
3. Select the *certificate* in the middle pane
4. Verify that the *Expiration Date* is at a later date than the current date.

- **Ensure that the chain of the server certificate is valid.**

The *Siemens Server Registration Authority* (Server RA) offers in the support section of their website the download of all Issuing and Root CA certificates giving the administrator the ability to install them on the server and ensuring with that a valid certificate chain.

- **Protect the private key accordingly:**

If you export the certificate for backup reasons or to store it on a NTFS share for the use of a "Central Certificate Store", ensure that you use a secure password to protect the certificate from misuse.

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383371; defined some rule parts more precisely.

BL115-4471

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Configure HSTS Header

Rule Ensure HSTS Header is set to 31536000 seconds (1 year).

Note: As the browser will ignore the HST header in any HTTP request, it is recommended to implement an additional redirect from HTTP to HTTPS together with the enabled HSTS feature. Thereby, the server sends an HTTPS response (including the HSTS header), even if a client requested a website via HTTP in the first place.

Description

HTTP Strict Transport Security (HSTS) allows a site to inform the user agent to communicate with the site only over HTTPS. This header takes two parameters:

- **max-age**, "specifies the number of seconds, after the reception of the STS header field, during which the user agent regards the host (from whom the message was received) as a Known HSTS Host [speaks only HTTPS]"; and
- **includeSubDomains**, which is an optional directive that defines how this policy is applied to subdomains. If includeSubDomains is included in the header, it provides the following definition: this HSTS Policy also applies to any hosts whose domain names are subdomains of the Known HSTS Host's domain name.

Rationale

HTTP Strict Transport Security (HSTS) is a simple and widely supported standard to protect visitors by ensuring that their browsers always connect to a website over HTTPS. HSTS exists to remove the need for the common, insecure practice of redirecting users from `http://` to `https://` URLs. HSTS relies on the User Agent/Browser to enforce the required behavior. All major browsers support it. If the browser doesn't support HSTS, it will be ignored.

When a browser knows that a domain has enabled HSTS, it does two things:

1. Always uses an `https://` connection, even when clicking on an `http://` link or after typing a domain into the location bar without specifying a protocol.
2. Removes the ability for users to click through warnings about invalid certificates.

A domain instructs browsers that it has enabled HSTS by returning an HTTP header over an HTTPS connection.

I01 - Implementation Example

To set the HTTP Header at the server level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/httpProtocol  
/+"customHeaders.[name='Strict-Transport-Security',value='max-age=31536000; preload']"
```

Listing: BL115-4471_I01_01.cmd

To set the HTTP Header and include subdomains at the server level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config -section:system.webServer/httpProtocol  
/+"customHeaders.[name='Strict-Transport-Security',value='max-age=31536000; includeSubDomains;  
preload']"
```

Listing: BL115-4471_I01_02.cmd

To set the HTTP Header at the Website level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config "<Name of the Website>" -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-Transport-Security',value='max-  
age=31536000; preload']"
```

Listing: BL115-4471_I01_03.cmd

To set the HTTP Header and include subdomains at the Website level using an `AppCmd.exe` command, run the following command from an elevated command prompt:

```
%systemroot%\system32\inetsrv\appcmd.exe set config "<Name of the Website>" -  
section:system.webServer/httpProtocol /+"customHeaders.[name='Strict-Transport-Security',value='max-  
age=31536000; includeSubDomains; preload']"
```

Listing: BL115-4471_I01_04.cmd

C01 - Example Check

Perform the following in IIS Manager to view host headers configured for the server:

1. Open IIS Manager
2. In the Connections pane, select your server
3. In the Features View pane, double-click HTTP Response Headers
4. Verify an entry exists named Strict-Transport-Security
5. Double-click Strict-Transport-Security and verify the Value: box contains the value 31536000
6. Click OK.

Perform the following in IIS Manager to view host headers configured for the Website:

1. Open IIS Manager
2. In the Connections pane, expand the tree and select Website
3. In the Features View pane, double-click HTTP Response Headers
4. Verify an entry exists name Strict-Transport-Security
5. Double-click Strict-Transport-Security and verify the Value: box contains the value 31536000
6. Click OK.

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.1

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; modified the value to 31536000 seconds as requested in IIS 8.x measure M383734; added a note to the *Rule* section. Changed during review: Corrected script 03 and 04 in the *Implementation* section.

BL115-5956

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'SSL 2.0' Protocol

Rule Ensure 'SSL 2.0' is set to 'Disabled' in client and server mode.

Note: Although this protocol is disabled by default if the registry key is not present, it is required to set the registry to key to ensure that the protocol will not be activated accidentally.

Description

Transport Layer Security (TLS), and its predecessor Secure Sockets Layer (SSL) are cryptographic protocols which can be used to encrypt data sent between client and server.

Rationale

SSLv2 has turned out to be an insecure protocol for the transmission of sensitive information. All major software and IT vendors disregard usage of SSLv2 and recommend more secure protocols such as the TLS suite. This measure follows the recommendation and disables SSLv2 within the Windows operating system (Schannel) entirely (client and server mode).

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client\DisabledByDefault

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on SSLv2 and uses Windows' Schannel implementation will run into problems. Furthermore, any client connecting to the server that relies on SSLv2 will fail.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' - Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' - Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 2.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-5956_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "SSL 2.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path $RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL115-5956_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.2

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-2561

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'SSL 3.0' Protocol

Rule

Ensure 'SSL 3.0' is set to 'Disabled' in client and server mode.

Description

Transport Layer Security (TLS), and its predecessor Secure Sockets Layer (SSL) are cryptographic protocols which can be used to encrypt data sent between client and server.

Rationale

SSLv3 has turned out to be an insecure protocol for the transmission of sensitive information. Encryption in SSLv3 uses either the RC4 stream cipher or block cipher in CBC mode. In both modes, severe security flaws were detected in the past (e.g., Poodle attack). All major software and IT vendors disregard usage of SSLv3 and recommend more secure protocols such as the TLS suite. This measure follows the recommendation and disables SSLv3 within the Windows operating system (Schannel) entirely (client and server mode).

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client\DisabledByDefault\ -Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL 3.0\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\SSL
3.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2561_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "SSL 3.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL115-2561_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.3

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-2691

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'TLS 1.0' Protocol

Rule

Ensure 'TLS 1.0' is set to 'Disabled' in client and server mode.

Description

TLS 1.0 is a direct further development of SSL 3.0 and is specified in [RFC2246]. Furthermore, the TLS protocol is available in the versions TLS 1.1 and TLS 1.2 which are specified in [RFC4346] and [RFC5246].

Secure Channel (Schannel) is primarily used for Internet applications that require secure Hypertext Transfer Protocol (HTTP) communications.

Note: Currently, the TLS 1.3 RFC has been formally approved, but TLS 1.3 should not be used before fully supported by Microsoft. Hence, there are no recommendations for TLS 1.3 yet.

Detailed information on implementing TLS 1.3 can be found here: [Microsoft Research - Implementing and Proving the TLS 1.3 Record Layer](#).

Rationale

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client\DisabledByDefault

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on TLS 1.0 and uses Windows Schannel implementation will fail.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' - Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' - Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2691_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.0"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path $RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL115-2691_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.4

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383524. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-3386

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'TLS 1.1' Protocol

Rule

Ensure 'TLS 1.1' is set to 'Disabled' in client and server mode.

E01 - Exemption

By now, the TLS protocol version TLS 1.1 is allowed for company use on systems rated with a maximum **ACP level 1 in Integrity and Confidentiality** .

Note: TLS 1.1 is already deprecated by *IETF RFC, NIST SP 80052r2*, et al. Therefore, TLS 1.1 will soon be prohibited for company use and an update of applications or services still requiring TLS 1.1 is highly recommended.

Note: If the exemption is used, TLS 1.1 shall be configured with these cipher suites only:

IANA name	OpenSSL name	Code
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA	ECDHE-ECDSA-AES128-SHA	0xC0,0x09
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA	ECDHE-ECDSA-AES256-SHA	0xC0,0x0A
TLS_DHE_DSS_WITH_AES_128_CBC_SHA	DHE-DSS-AES128-SHA	0x00,0x32
TLS_DHE_DSS_WITH_AES_256_CBC_SHA	DHE-DSS-AES256-SHA	0x00,0x38
TLS_DH_DSS_WITH_AES_128_CBC_SHA	DH-DSS-AES128-SHA	0x00,0x30
TLS_DH_DSS_WITH_AES_256_CBC_SHA	DH-DSS-AES256-SHA	0x00,0x36
TLS_DH_RSA_WITH_AES_128_CBC_SHA	DH-RSA-AES128-SHA	0x00,0x31
TLS_DH_RSA_WITH_AES_256_CBC_SHA	DH-RSA-AES256-SHA	0x00,0x37
TLS_ECDH_ECDSA_WITH_AES_128_CBC_SHA	ECDH-ECDSA-AES128-SHA	0xC0,0x04
TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA	ECDH-ECDSA-AES256-SHA	0xC0,0x05
TLS_ECDH_RSA_WITH_AES_128_CBC_SHA	ECDH-RSA-AES128-SHA	0xC0,0x0E
TLS_ECDH_RSA_WITH_AES_256_CBC_SHA	ECDH-RSA-AES256-SHA	0xC0,0x0F

Description

TLS 1.1 is a direct further development of TLS 1.0 and is specified in [RFC4346]. Furthermore, the TLS protocol is available in the versions TLS 1.2 and TLS 1.3 which are specified in [RFC5246] and [RFC8446].

Secure Channel (Schannel) is primarily used for Internet applications that require secure Hypertext Transfer Protocol (HTTP) communications.

Note: Currently, the TLS 1.3 RFC has been formally approved, but TLS 1.3 should not be used before fully supported by Microsoft. Hence, there are no recommendations for TLS 1.3 yet.

Detailed information on implementing TLS 1.3 can be found here: [Microsoft Research - Implementing and Proving the TLS 1.3 Record Layer](#).

Rationale

Disabling weak protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\Protocols\TLS 1.1\Server\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\Protocols\TLS 1.1\Client\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\Protocols\TLS 1.1\Server\DisabledByDefault

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\Protocols\TLS 1.1\Client\DisabledByDefault

-Type DWORD

-Value 0x1

To ensure that these settings are permanently updated on the client, ensure that the GP Preference
'Action:' is set to Update.

Impact:

None, as this has been requested in the Server as well as in the IIS Measure Plans for quite some time.

Any application that relies on TLS 1.1 and uses Windows Schannel implementation will fail.

I01 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.1\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Server' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Client' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Server' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.1\Client' -name 'DisabledByDefault' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-3386_I01_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.1"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
Foreach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 1) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 0))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL115-3386_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.5

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383524. Added an exemption. Added reboot note to the *Implementation* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-1156

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Enable 'TLS 1.2' Protocol

Rule

Ensure 'TLS 1.2' is set to 'Enabled' in client and server mode.

Description

TLS 1.2 is a recent and mature protocol for protecting the confidentiality and integrity of HTTP traffic. Enabling TLS 1.2 is recommended. This protocol is enabled by default if the registry key is not present. As with any registry changes, a reboot is required for changes to take effect.

Rationale

Enabling strong protocols will help ensure the confidentiality and integrity of in-transit data.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server\Enabled

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client\Enabled

-Type DWORD

-Value 0x1

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server\DisabledByDefault

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client\DisabledByDefault

-Type DWORD

-Value 0x0

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I01 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Server' -
Force | Out-Null
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.2\Client' -
Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Server' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Client' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null

New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Server' -name 'DisabledByDefault' -value '0' -PropertyType 'DWord' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS
1.2\Client' -name 'DisabledByDefault' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-1156_I01_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Protocol = "TLS 1.2"
$RgKy = "HKLM:\System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\$Protocol\"
ForEach ($scope in "Server", "Client")
{
    $RgKyPth = $RgKy + $scope
    if (((Get-ItemProperty -Path $RgKyPth).DisabledbyDefault -ne 0) -or ((Get-ItemProperty -Path
$RgKyPth).Enabled -ne 1))
    {
        "$Protocol $scope not configured correctly"
    }
    else
    {
        "$Protocol $scope configured correctly"
    }
}
```

Listing: BL115-1156_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.6

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; added client part of TLS 1.2 as well. Added reboot note to the *Implementation* section.
Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-4921

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'NULL' Cipher Suites

Rule

Ensure 'NULL' Cipher Suites are disabled.

Description

The NULL cipher does not provide data confidentiality or integrity. It is recommended that the NULL cipher be disabled.

Rationale

The usage of null cipher suites would effectively lead to clear-text communication. By disabling the NULL cipher, there is a better chance of maintaining data confidentiality and integrity.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following commands:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\NULL'
-name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-4921_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('NULL')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-4921_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.7

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-5881

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'DES' Cipher Suites

Rule

Ensure 'DES 56/56' Cipher Suites are disabled.

Description

The Data Encryption Standard (DES) is a symmetric-key algorithm for the encryption of electronic data. DES is a weak symmetric-key cipher and must therefore be disabled.

Rationale

It is fundamentally inadequate, because its 56-bit key is too short. By disabling DES, there is a better chance of maintaining data confidentiality and integrity.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES 56/56\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('DES 56/56')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\DES  
56/56' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-5881_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('DES 56/56')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-5881_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.8

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-4837

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'RC2' Cipher Suites

Rule

Ensure 'RC2 40/128', 'RC2 56/128', and 'RC2 128/128' Cipher Suites are disabled.

Description

RC2 is a stream cipher that has known practical attacks. It is recommended that RC2 be disabled.

Rationale

Use of RC2 in TLS and SSL could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 40/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 56/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2 128/128\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable RC2 40/128, RC2 56/128, and RC2 128/128 using PowerShell enter the following commands:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 40/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
40/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 56/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
56/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC2 128/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC2  
128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-4837_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('RC2 40/128', 'RC2 56/128', 'RC2 128/128')  
ForEach ($Cipher in $Ciphers)  
{  
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"  
    $RegValue = "Enabled"  
    $ExpValue = 0  
    $result = (Get-ItemProperty -Path $RegKey).$RegValue  
    if (($result) -eq ($ExpValue))  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."  
    }  
    else  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."  
    }  
}
```

Listing: BL115-4837_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Adapted RC4 rule from CIS benchmark for the RC2 cipher suites; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; added more information to the *Rationale* section. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-4836

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'RC4' Cipher Suites

Rule Ensure 'RC4 40/128', 'RC4 56/128', 'RC4 64/128', and 'RC4 128/128' Cipher Suites are disabled.

Description

RC4 is a stream cipher that has known practical attacks. It is recommended that RC4 be disabled.

Rationale

Use of RC4 in TLS and SSL could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Items

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 40/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 56/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 64/128\Enabled

-Type DWORD

-Value 0x0

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4 128/128\Enabled

-Type DWORD

-Value 0x0

To ensure that these settings are permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I01 - PowerShell Implementation Example

To disable RC4 40/128, RC4 56/128, RC4 64/128 and RC4 128/128 using PowerShell enter the following commands:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC4 40/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4  
40/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC4 56/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4  
56/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC4 64/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4  
64/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null  
  
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('RC4 128/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\RC4  
128/128' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-4836_I01_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('RC4 40/128', 'RC4 56/128', 'RC4 64/128', 'RC4 128/128')  
ForEach ($Cipher in $Ciphers)  
{  
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"  
    $RegValue = "Enabled"  
    $ExpValue = 0  
    $result = (Get-ItemProperty -Path $RegKey).$RegValue  
    if (($result) -eq ($ExpValue))  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."  
    }  
    else  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."  
    }  
}
```

Listing: BL115-4836_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.9

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; formerly part of IIS 8.x measure M383360. Added reboot note to the *Implementation* section; removed obsolete information. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-1386

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'Triple DES' Cipher Suites

Rule

Ensure 'Triple DES 168' Cipher Suites are disabled.

Description

Triple DES (Triple Data Encryption Algorithm) relies on a series of three DES keys and appears to offer 168 bit key length of protection, but due to the ability for attackers to generate three dimensional lookup tables that have all combinations of the first and third key available in the realm of potential 56 bit key length combinations, something known as the meet-in-the-middle vulnerability arises which reduces the mathematical complexity of cracking the keys exponentially and significantly. 3DES key strength provides only 112 bits of protection.

Rationale

Security institutions (e.g., the German BSI) clearly recommend migrating away from it because Triple DES does not fulfill the requirement of 128 bit symmetric key size equivalent. 3DES vulnerabilities are, e.g., collision attacks like `sweet32` and `meet-in-the-middle` attack.

Although the 'Triple DES 168' keying option '3TDEA' is considered to be secure, 'Triple DES 168' has to be disabled completely. In Windows operating systems you can only enable or disable 'Triple DES 168' but not differentiate between specific keying options.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable Triple DES 168 using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple DES 168' -  
Force | Out-Null  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\Triple  
DES 168' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-1386_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Ciphers = @('Triple DES 168')  
ForEach ($Cipher in $Ciphers)  
{  
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\${Cipher}"  
    $RegValue = "Enabled"  
    $ExpValue = 0  
    $result = (Get-ItemProperty -Path $RegKey).$RegValue  
    if (($result) -eq ($ExpValue))  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."  
    }  
    else  
    {  
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."  
    }  
}
```

Listing: BL115-1386_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383360. Changed during review: Corrected the registry key from 'Triple DES 168/168' to 'Triple DES 168'. Aligned the rule with the Windows Server Security Measure Plan.

BL115-2886

EVAL until 2021-02-28

Asset Manager

C	I	A
1	2	3
2	1	2
3	3	1

Enable 'AES 128/128' Cipher Suites

Rule

Ensure 'AES 128/128' Cipher Suites are enabled.

Description

AES (acronym of Advanced Encryption Standard) is a symmetric encryption algorithm. The algorithm was developed by two Belgian cryptographer Joan Daemen and Vincent Rijmen. AES was designed to be efficient in both hardware and software, and supports a block length of 128 bits and key lengths of 128, 192, and 256 bits.

Rationale

Enabling this cipher will help ensure the confidentiality and integrity of data in transit.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES 128/128\Enabled

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I01 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('AES 128/128')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
128/128' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2886_I01_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Ciphers = @('AES 128/128')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 1
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-2886_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.10

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; modified *Rationale* and *Description* section; added an exemption. Changed during review: Encryption-Mode AES128 is also allowed, only CBC-Mode must be disabled. Aligned the rule with the Windows Server Security Measure Plan.

BL115-4481

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Enable 'AES 256/256' Cipher Suites

Rule

Ensure 'AES 256/256' Cipher Suites are enabled.

Description

AES 256/256 is the most recent and mature cipher suite for protecting the confidentiality and integrity of HTTP traffic. Enabling AES 256/256 is recommended.

Rationale

Enabling this cipher will help ensure the confidentiality and integrity of data in transit.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES 256/256\Enabled

-Type DWORD

-Value 0x1

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I01 - PowerShell Implementation Example

To enable using PowerShell enter the following command:

```
(Get-Item 'HKLM:\').OpenSubKey('SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers',  
$true).CreateSubKey('AES 256/256')  
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\AES  
256/256' -name 'Enabled' -value '1' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-4481_I01_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Ciphers = @('AES 256/256')
ForEach ($Cipher in $Ciphers)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Ciphers\$Cipher"
    $RegValue = "Enabled"
    $ExpValue = 1
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for cipher '$Cipher' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for cipher '$Cipher' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-4481_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.11

[Based on Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; modified *Description* section. Added reboot note to the *Implementation* section.
Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-2563

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'MD5' Hashing Algorithm

Rule

Ensure 'MD5' Hashing Algorithm is disabled.

Description

This hash algorithm is not considered secure anymore. Disabling it is recommended.

Rationale

The MD5 algorithm is reported prone to a hash collision weakness. This weakness reportedly allows attackers to create multiple, differing input sources that, when the MD5 algorithm is used, result in the same MD5-Hash output.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2563_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
$Hashes = @('MD5')
ForEach ($Hash in $Hashes)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\$Hash"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for hash '$Hash' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for hash '$Hash' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-2563_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383360. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-2544

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Disable 'SHA-1' Hashing Algorithm

Rule

Ensure 'SHA-1' Hashing Algorithm is disabled.

Description

The term "Secure Hash Algorithms" describes a group of standardized cryptographic hash functions which are used to calculate a unique checksum for any digital data. These checksums play an important part in TLS/SSL encryption and are used as unique identifier within a server certificate.

Note: Contrary to information on many Microsoft websites there are more values available under the registry key Hashes besides MD5 and SHA. The additional values are SHA256, SHA384, and SHA512. Therefore, disabling the value SHA will only disable the SHA-1 hash algorithm, but not the newer more secure SHA algorithms.

Rationale

The SHA-1 algorithm is reported prone to a hash collision weakness. In 2017, it was performed a collision attack against SHA-1, publishing two dissimilar PDF files which produced the same SHA-1 hash.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA\Enabled

-Type DWORD

-Value 0x0

To ensure that this setting is permanently updated on the client, ensure that the GP Preference 'Action:' is set to Update.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To disable using PowerShell enter the following command:

```
New-Item 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA' -name 'Enabled' -value '0' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2544_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$Hashes = @('SHA')
ForEach ($Hash in $Hashes)
{
    $RegKey = "HKLM:SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\$Hash"
    $RegValue = "Enabled"
    $ExpValue = 0
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -eq ($ExpValue))
    {
        "Registry value '$RegValue' for hash '$Hash' correctly set to '$ExpValue'."
    }
    else
    {
        "Registry value '$RegValue' for hash '$Hash' not correctly set to '$ExpValue' but to '$result'."
    }
}
```

Listing: BL115-2544_C01_01.ps1

Crossreferences

Based on [Siemens Information Security Policy Framework Rule 10.1.1-02](#)

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383360. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-2386

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Ensure sufficient 'Modulus Size in the DHE Key Exchange'

Rule Ensure the modulus size of Diffie-Hellman Ephemeral (DHE) is set to 2048 bit or higher.

Note: A bit size higher than 2048 bits for DHE should be evaluated carefully as this may impose performance issues.

Description

Ephemeral Diffie-Hellman (DHE in the context of TLS) differs from the static Diffie-Hellman (DH) in the way that static Diffie-Hellman key exchange always use the same Diffie-Hellman private keys. So, each time the same parties do a DH key exchange, they end up with the same shared secret.

When a key exchange uses Ephemeral Diffie-Hellman a temporary DH key is generated for every connection and thus the same key is never used twice. This enables *Perfect Forward Secrecy* (PFS), which means that if the long-term private key of the server gets leaked, past communication is still secure.

By default, the modulus size of Diffie-Hellman Ephemeral (DHE) is set to 1024 bit.

Rationale

In 2015, a group of researchers published a paper, describing weaknesses in Diffie- Hellmann key exchange when using a modulus size up to 1024 bit. This vulnerability is known as the Logjam attack (see here [https://en.wikipedia.org/wiki/Logjam_\(computer_security\)](https://en.wikipedia.org/wiki/Logjam_(computer_security))).

The improper configuration of DHE key exchange could allow an attacker to perform man-in-the-middle attacks and recover plaintext from encrypted sessions.

I01 - Group Policy Preferences (GPP)

To establish the recommended configuration using GP Preferences, add the following Registry Item

Computer Configuration\Preferences\Windows Settings\Registry

-Path

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL
\KeyExchangeAlgorithms\Diffie-Hellman\ServerMinKeyBitLength

-Type DWORD

-Value 0x800

To ensure that this setting is permanently updated on the server, ensure that the GP Preference 'Action:' is set to Update.

Possible values for ServerMinKeyBitLength:

Modulus size (Dec)	Modulus Size (Hex)
1024	default
2048	0x800
3072	0xC00
4096	0x1000

More information can be found here: [Microsoft Security Advisory 3174644](#).

Note:

For Windows Versions before Windows 10 and Windows Server 2019 make sure that Microsoft Advisory 3174644 [Microsoft security advisory: Updated support for Diffie-Hellman Key Exchange](#) already has been implemented.

Impact:

None, this has been requested in Windows Server as well as in the IIS Measure Plans for quite some time.

I02 - PowerShell Implementation Example

To set the modulus size of Diffie-Hellman Ephemeral to 2048 bits using PowerShell enter the following command:

```
New-Item
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\Diffie-Hellman'
-Force | Out-Null
New-ItemProperty -path
'HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\Diffie-Hellman'
-name 'ServerMinKeyBitLength' -value '0x00000800' -PropertyType 'DWord' -Force | Out-Null
```

Listing: BL115-2386_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$KEAs = @('Diffie-Hellman')
ForEach ($KEA in $KEAs)
{
    $RegKey =
    "HKLM:System\CurrentControlSet\Control\SecurityProviders\SCHANNEL\KeyExchangeAlgorithms\$KEA"
    $RegValue = "ServerMinKeyBitLength"
    $ExpValue = 2048
    $result = (Get-ItemProperty -Path $RegKey).$RegValue
    if (($result) -ge ($ExpValue))
    {
        "Registry value '$RegValue' for modulus size of '$KEA' (DHE) correctly set to '$result'."
    }
    else
    {
        "Registry value '$RegValue' for modulus size of '$KEA' (DHE) not correctly set to '$result' but to '$result'."
    }
}
```

Listing: BL115-2386_C01_01.ps1

Crossreferences

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Rule based on IIS 8.x measure M383386. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

BL115-4906

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	

Configure TLS Cipher Suite Ordering

Rule

Ensure TLS Cipher Suite ordering is ordered from strongest to weakest Cipher Suite. Use the following order and thus, enabled cipher suites:

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

Note: From the list of currently supported and by default enabled cipher suites in Windows Server 2019, only the above listed cipher suites are allowed.

E01 - Exemption

The TLS Cipher Suite ordering can be changed, if business needs are requiring this. In this case, the reasons for the change have to be documented accordingly.

Note: Avoid cipher suites that do not provide Perfect Forward Secrecy or use weak hashing function, use them only if you need to support backwards compatibility and in the bottom of the order preference list.

Description

Cipher suites are a named combination of authentication, encryption, message authentication code, and key exchange algorithms used for the security settings of a network connection using TLS protocol. Clients send a cipher list and a list of ciphers that it supports in order of preference to a server. The server then replies with the cipher suite that it selects from the client cipher suite list.

Cipher suites should be ordered from strongest to weakest in order to ensure that the more secure configuration is used for encryption between the server and client.

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
- TLS_DHE_RSA_WITH_AES_256_GCM_SHA384
- TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

Note: From the list of currently supported and by default enabled cipher suites in Windows Server 2019, only the above listed cipher suites are allowed. The following cipher suites are disallowed with appropriately given reason:

- Disallowed due to deprecated and vulnerable CBC padding mode used in AES-encryption:
 - TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
 - TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
 - TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384
 - TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256
 - TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA
 - TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA
 - TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
 - TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
 - TLS_RSA_WITH_AES_256_CBC_SHA256
 - TLS_RSA_WITH_AES_128_CBC_SHA256
- Disallowed due to lack of perfect forward secrecy (PFS):
 - TLS_RSA_WITH_AES_256_GCM_SHA384
 - TLS_RSA_WITH_AES_128_GCM_SHA256
- Disallowed due to NULL encryption and lack of perfect forward secrecy (PFS):
 - TLS_RSA_WITH_NULL_SHA256
- Disallowed due to deprecated CBC padding mode for AES encryption, lack of perfect forward secrecy (PFS), deprecated 3DES or NULL encryption and deprecated SHA-1 message authentication method:
 - TLS_RSA_WITH_AES_256_CBC_SHA
 - TLS_RSA_WITH_AES_128_CBC_SHA
 - TLS_RSA_WITH_3DES_EDE_CBC_SHA
 - TLS_RSA_WITH_NULL_SHA

Rationale

A weak cipher defines an encryption/decryption algorithm that uses a key of insufficient length. Using a key with insufficient length could cause an attack where the encryption scheme could be broken.

I01 - Group Policy Implementation Example

To establish the recommended configuration via Group Policy, set the following UI path to

Computer Configuration\Administrative Templates\Network\SSL Configuration
Settings\SSL Cipher Suite Order

Enabled:TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_128_GCM_SHA256

This group policy setting is backed by the following registry:

HKLM\System\CurrentControlSet\Control\Cryptography\Configuration\Local\SSL\00010002:Functions

A reboot of the operating systems is required for these changes to be reflected.

Note: Please be aware, that you need to use a correct syntax for this setting - this means that every Cipher suite must be delimited by comma only (without spaces), that the exact name of the Cipher suite must be used and that the length of the complete string does not exceed 1,023 characters.

Impact:

Cipher ordering is important to ensure that the most secure ciphers are listed first and will be applied over weaker ciphers when possible.

I02 - PowerShell Implementation Example

To configure TLS cipher suite order using PowerShell enter the following commands:

```
New-Item 'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -Force | Out-Null
New-ItemProperty -path 'HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002' -name
'Functions' -value
'TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_
128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WIT
H_AES_128_GCM_SHA256' -PropertyType 'MultiString' -Force | Out-Null
```

Listing: BL115-4906_I02_01.ps1

A reboot of the operating systems is required for these changes to be reflected.

Impact:

Cipher ordering is important to ensure that the most secure ciphers are listed first and will be applied over weaker ciphers when possible.

C01 - PowerShell Check Example

To verify using PowerShell enter the following command:

```
$RegKey = "HKLM:\SOFTWARE\Policies\Microsoft\Cryptography\Configuration\SSL\00010002"
$RegValue = "Functions"
$ExpValue =
"TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_
128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WIT
H_AES_128_GCM_SHA256"
$result = (Get-ItemProperty -Path $RegKey).$RegValue
if (($result) -eq ($ExpValue))
{
    "Registry value '$RegValue' for TLS Cipher Suite Ordering correctly set to '$ExpValue'."
}
else
{
    "Registry value '$RegValue' for TLS Cipher Suite Ordering not correctly set to '$ExpValue' but to
'$result'."
}
```

Listing: BL115-4906_C01_01.ps1

Crossreferences

Based on CIS Benchmark 'Microsoft IIS 10' (v1.1.1): 7.12

Based on Siemens Information Security Policy Framework Rule 10.1.1-02

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Import from CIS; specified the rule more precisely; added an exemption. Added reboot note to the *Implementation* section. Added GPO implementation example. Changed during review: Aligned the rule with the Windows Server Security Measure Plan.

HTTP Headers

HTTP Response headers are name-value pairs of strings sent back from a server with the content you requested. HTTP Response headers can be used to transmit security policies to the web browser of the user. By passing security policies back to the client in this way, hosts can ensure a more secure browsing experience for their visitors and also reduce the risk for everyone involved.

BL115-0514

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure Content Security Policy

Rule

- Define a policy about all origins of your hosted content,
- Apply the `Content-Security-Policy` HTTP header with a value fitting to your content and make sure it is served with every web resource,
- Do not use the options `unsafe-inline` and `unsafe-eval`.

E01 - Exemption

If you identify during your tests that your web application requires either the option `unsafe-inline` or the option `unsafe-eval`, you can use these options. However, keep in mind that with those options you render the protection useless. Therefore, you need to restrict the usage as much as possible.

The business and technical reasons for this change have to be documented accordingly.

Description

The CSP header allows you to define a white-list of approved sources of content for your site by restricting the assets that a browser can load for your site, like JS and CSS.

However, the required settings need to be evaluated first before a fitting `Content-Security-Policy` HTTP header can be implemented for your web application.

Some web applications will fail without inline scripting capabilities. Therefore, it is possible to circumstance this security feature with the special keywords `unsafe-inline` or `unsafe-eval`.

Rationale

Cross-site scripting (XSS) attacks are a common threat for web services. Once an attacker is able to inject its own code into a website, the users of this website are in danger. Sometimes, a single click on a prepared link is enough to load external scripts in the context of the affected website. Thus, the `Content-Security-Policy` HTTP header can be applied to limit the impact of such XSS attacks. Administrators can use it to declare the usage of dynamic resources that are allowed to load.

One of biggest threats posed by XSS attacks is inline script injection. A *Content-Security-Policy* with secure settings eliminates these risks by completely disallowing inline scripting.

I01 - Manual Implementation Example

Note: Keep in mind that there exists no single *Content-Security-Policy* which fits for all web applications. The owner of web content and web applications need to work hand in hand with the owner of web server to ensure that the *Content-Security-Policy* HTTP header will be configured securely and does not interfere with the web applications hosted on the web server.

General setup of a Content-Security-Policy:

The *Content-Security-Policy* HTTP header features a wide range of resource directives - the most common options are:

- **default-src:** fallback value for all options ending in `-src`.
- **font-src:** specifies the origin of web fonts.
- **child-src:** lists the origins of workers and embedded contents.
- **connect-src:** names origins where XHR, WebSockets and EventSources can connect to.
- **img-src:** defines origins from where images can be loaded.
- **script-src:** ensures that only scripts from the listed origins can be loaded.

For every resource directive you can specify a list a allowed sources divided by a blank. A source can be a scheme (e.g., `https:`), a host name (e.g., `siemens.com`), or even a fully qualified URI (e.g., `https://siemens.com:443`).

Additionally, you can use these four keywords:

- `none`: matches none,
- `self`: matches the origin,
- `unsafe-inline`: allows the use of inline source elements,
- `unsafe-eval`: allows the use of dynamic code evaluation.

To set the *Content-Security-Policy* HTTP header on your IIS server you need to add the following configuration lines to the `web.config` file within the root directory of the corresponding website:

```
<configuration>
<system.webServer>
  ...
  <httpProtocol>
    <customHeaders>
      <add name="Content-Security-Policy" value="..." />
    </customHeaders>
  </httpProtocol>
  ...
</system.webServer>
```

Listing: BL115-0514_I01_01.config

Keep in mind that `value="..."` in above sample is only the place holder for the *Content-Security-Policy* values you identified for your application.

The `customHeaders` directive is applicable within the `ApplicationHost.config` file for the whole IIS server, or within the `web.config` file of a website or even within a specific folder.

It is recommended to set the HTTP Header globally within the `Application-Host.config` file for all web resources. However, keep in mind that the directive can be only set either in the `Application-Host.config` file or within the `web.config` file. Having the settings in both files will result in unwanted behavior.

How to start with a Content-Security-Policy:

A good starting point could be to implement a policy which allows images, scripts, AJAX, and CSS from the same origin, and does not allow any other resources to load (e.g., object, frame, media). This would result in the following `<add name>` configuration line:

```
<add name="Content-Security-Policy" value="default-src 'none'; script-src 'self'; connect-src 'self';  
img-src 'self'; style-src 'self';" />
```

Listing: BL115-0514_I01_02.config

Start with the `-Report-Only` function for a few days to determine all origins of your hosted content. With the directive `report-uri` you can specify where the reports shall be sent to.

Using the above example, this would be the *report-only* configuration line:

```
<add name="Content-Security-Policy-Report-Only" value="script-src 'self'; connect-src 'self'; img-src  
'self'; style-src 'self' report-uri /my_csp_reports;" />
```

Listing: BL115-0514_I01_03.config

After you have identified all origins of your hosted content adapt the policy to your needs and implement it using without the `-Report-Only` function.

Keep in mind that you can use either the reporting or the writing function at the same time.

How to avoid overwriting existing **Content-Security-Policy** HTTP headers:

There are applications which have their own Content-Security Policy set.

To avoid the overwriting of these separate headers you could use the `Rewrite` module to keep separate headers but to set your desired header in case there is no header present:

```
<rewrite>  
  <outboundRules>  
    <rule name="Content-Security-Policy">  
      <match serverVariable="RESPONSE_Content-Security-Policy" pattern="^$" ignoreCase="true" />  
      <action type="Rewrite" value="..." />  
    </rule>  
  </outboundRules>  
</rewrite>
```

Listing: BL115-0514_I01_04.config

Keep in mind that `value="..."` in above sample is only the place holder for the `Content-Security-Policy` value you identified for your application.

Where to find more information:

You can find more information about *Content-Security-Policy* here:

- <https://developers.google.com/web/fundamentals/security/csp/>,
- <https://content-security-policy.com/>.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders" -name . -value @{name="Content-Security-Policy";
value="..."}
```

Listing: BL115-0514_I02_01.ps1

Keep in mind that `value="..."` in above sample is only the place holder for the `Content-Security-Policy` value you identified for your application.

C01 - Manual Check Example

To verify an `Content-Security-Policy` has been set, browse to and open the `web.config` file for the configured site/application/content:

```
<configuration>
<system.webServer>
  ...
  <httpProtocol>
    <customHeaders>
      <add name="Content-Security-Policy" value="..." />
    </customHeaders>
  </httpProtocol>
  ...
</system.webServer>
```

Listing: BL115-0514_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfiguration -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders/add[@name='Content-Security-Policy']"
```

Listing: BL115-0514_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Based on former IIS 8.x measure M383514; rewrote mainly *Implementation* section for better understanding or adding features.

BL115-8551

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure Frame-ancestors

Rule

Apply the `frame-ancestors` directive within your *Content Security Policy* with a value of `none` upon every web resource.

E01 - Exemption

If your web application does not work with the `frame-ancestors` value `none`, then you are allowed to use a different value. However, try the more secure value `self` first before using `scheme-source` or `host-source`.

The business and technical reasons for this change have to be documented accordingly.

Description

Setting the `frame-ancestors` directive can tell web browsers if such an embedding is allowed for the served content and for which origin resource.

Note: The `frame-ancestors` replaces the `X-Frame-Options` (see [BL115-0928](#)) but currently not all web browsers support both features completely. Therefore it is essential that you implement `frame-ancestors` as well as `X-Frame-Options` with a similar value.

Rationale

Clickjacking attacks are tricking users to click specially prepared user interface (UI) elements. A very common way to achieve this goal of manipulating web users to interact with malicious content is to insert valid websites into a specially prepared HTML context. Usually, such an embedding is done by using `iframe`, `frame` or `object` HTML tags.

I01 - Manual Implementation Example

Configuration of the `frame-ancestors` directive:

The `frame-ancestors` directive is part of the *Content Security Policy* and can be set to four different values. The following list sorts these options from the most conservative to the most relaxed one:

- **none**: which will prevent any page displaying the content within any origin.
- **self**: allows pages of the same origin to include the content.
Two web resources share the same origin whenever they share the same top-level browsing context. For example, a resource hosted under <https://shop.siemens.com> is served with a `SAMEORIGIN` option. This resource can be framed by any other resource hosted under the very same domain. However, the web browser will refuse an embedding of the same resource from a page hosted at <https://cert.siemens.com>.
- **<scheme-source>**: allows the content to be included from the given scheme.

- **<host-source>**: allows the content to be included from the given origin.
The main difference between both value is that with `<host-source>` you allow all schemes for that specific host whereas with `<scheme-source>` you allow only specific schemes. Typical schemes are `http:` or `https:`.
For instance, a value of `https://www.siemens.com` would allow any page of Siemens website to embed the corresponding content. Any other domain trying to embedding the very same content would be denied by the web browser.

To set the `frame-ancestors` directive on your IIS server you need to add it to your *Content Security Policy*

Let's assume you use the example given in rule [BL115-0514](#):

```
<add name="Content-Security-Policy" value="default-src 'none'; script-src 'self'; connect-src 'self';  
img-src 'self'; style-src 'self';" />
```

Listing: BL115-8551_I01_01.config

and you want to add the directive `frame-ancestors 'none'` then you need to add the following line to the `web.config` file within the root directory of the corresponding website:

```
<configuration>  
<system.webServer>  
  ...  
  <httpProtocol>  
    <customHeaders>  
      <add name="Content-Security-Policy" value="default-src 'none'; script-src 'self'; connect-src  
'self'; img-src 'self'; style-src 'self' frame-ancestors 'none';" />  
    </customHeaders>  
  </httpProtocol>  
  ...  
</system.webServer>
```

Listing: BL115-8551_I01_02.config

The `customHeaders` directive is applicable within the `ApplicationHost.config` file for the whole IIS server, or within the `web.config` file of a website or even within a specific folder.

It is recommended to set the HTTP Header globally within the `Application-Host.config` file for all web resources. However, keep in mind that the directive can be only set either in the `Application-Host.config` file or within the `web.config` file. Having the settings in both files will result in unwanted behavior.

How to start with the **frame-ancestors** directive:

Start with the most conservative value `none` and if you run into any problems, continue with `self`. If this value also does not fit, use the value `<scheme-source>` or `<host-source>`.

Where to find more information:

You can find more information about *frame-ancestors* here:

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy/frame-ancestors>,
- <https://content-security-policy.com/>.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders" -name . -value @{name="Content-Security-
value="..."}
```

Listing: BL115-8551_I02_01.ps1

Keep in mind that `value="..."` in above sample is only the place holder for the `Content-Security-Policy` value you identified for your application.

C01 - Manual Check Example

To verify `frame-ancestors` has been set, browse to and open the `web.config` file for the configured site/application/content:

```
<configuration>
<system.webServer>
  ...
  <httpProtocol>
    <customHeaders>
      <add name="Content-Security-Policy" value="..." />
    </customHeaders>
  </httpProtocol>
  ...
</system.webServer>
```

Listing: BL115-8551_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfiguration -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders/add[@name='Content-Security-Policy']"
```

Listing: BL115-8551_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Created.

BL115-0928

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure X-Frame-Options

Rule

Apply the X-Frame-Options HTTP header with a value of DENY upon every web resource.

E01 - Exemption

If your web application does not work with the X-Frame-Options value DENY, then you are allowed to use a different value. However, try the more secure value SAMEORIGIN first before using ALLOW-FROM uri.

The business and technical reasons for this change have to be documented accordingly.

Description

Setting the X-Frame-Options HTTP header can tell web browsers if such an embedding is allowed for the served content and for which origin resource. This header is standardized as [RFC7034] [3].

Note: The X-Frame-Options is being replaced with the frame-ancestors (see BL115-8551) but currently not all web browsers support both features completely. Therefore it is essential that you implement frame-ancestors as well as X-Frame-Options with a similar value.

Rationale

Clickjacking attacks are tricking users to click specially prepared user interface (UI) elements. A very common way to achieve this goal of manipulating web users to interact with malicious content is to insert valid websites into a specially prepared HTML context. Usually, such an embedding is done by using iframe, frame or object HTML tags.

I01 - Manual Implementation Example

Configuration of the X-Frame-Options HTTP header:

The X-Frame-Options HTTP header can be set to three different values. The following list sorts these options from the most conservative to the most relaxed one:

- **DENY:** which will prevent any page displaying the content within any origin.
- **SAMEORIGIN:** allows pages of the same origin to include the content.
Two web resources share the same origin whenever they share the same top-level browsing context. For example, a resource hosted under <https://shop.siemens.com> is served with a SAMEORIGIN option. This resource can be framed by any other resource hosted under the very same domain. However, the web browser will refuse an embedding of the same resource from a page hosted at <https://cert.siemens.com>.

- **ALLOW-FROM uri:** allows the content to be included from the given origin.
For instance, a value of `ALLOW-FROM https://www.siemens.com` would allow any page of Siemens website to embed the corresponding content. Any other domain trying to embedding the very same content would be denied by the web browser.

To set the `X-Frame-Options` HTTP header on your IIS server you need to add the following configuration lines to the `web.config` file within the root directory of the corresponding website:

```
<configuration>
<system.webServer>
  ...
  <httpProtocol>
    <customHeaders>
      <add name="X-Frame-Options" value="DENY" />
    </customHeaders>
  </httpProtocol>
  ...
</system.webServer>
```

Listing: BL115-0928_I01_01.config

The `customHeaders` directive is applicable within the `ApplicationHost.config` file for the whole IIS server, or within the `web.config` file of a website or even within a specific folder.

It is recommended to set the HTTP Header globally within the `Application-Host.config` file for all web resources. However, keep in mind that the directive can be only set either in the `Application-Host.config` file or within the `web.config` file. Having the settings in both files will result in unwanted behavior.

How to start with the `X-Frame-Options` HTTP header:

Start with the most conservative value `DENY` and if you run into any problems, continue with `SAMEORIGIN`. If this value also does not fit, use the value `ALLOW-FROM uri`.

How to avoid overwriting existing `X-Frame-Options` HTTP headers:

There are applications which have their own `X-Frame-Options` set.

To avoid the overwriting of these separate headers you could use the `Rewrite` module to keep separate headers but to set your desired header in case there is no header present:

```
<rewrite>
  <outboundRules>
    <rule name="X-Frame-Options">
      <match serverVariable="RESPONSE_X-Frame-Options" pattern="^$" ignoreCase="true" />
      <action type="Rewrite" value="DENY" />
    </rule>
  </outboundRules>
</rewrite>
```

Listing: BL115-0928_I01_02.config

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders" -name . -value @{name="X-Frame-Options"; value="DENY"}
```

Listing: BL115-0928_I02_01.ps1

C01 - Manual Check Example

To verify X-Frame-Options has been set, browse to and open the `web.config` file for the configured site/application/content:

```
<configuration>
<system.webServer>
...
<httpProtocol>
  <customHeaders>
    <add name="X-Frame-Options" value="DENY" />
  </customHeaders>
</httpProtocol>
...
</system.webServer>
```

Listing: BL115-0928_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfiguration -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders/add[@name='X-Frame-Options']"
```

Listing: BL115-0928_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Based on former IIS 8.x measure M383928; rule requests now *DENY*; added an exemption for the other values; rewrote mainly *Implementation* section for better understanding or adding features.

BL115-0800

EVAL until 2021-02-28

Asset Manager

C	I	A
123	123	123

Configure MIME-Handling Security

Rule

Apply the `X-Content-Type-Options` HTTP header with a value of `nosniff` upon every web resource which is not part of the initial web application. This especially includes all uploads by users or other services.

Description

Every resource is served with a corresponding MIME type. This entry describes how the web browser of the client should treat the served content. Some web browsers feature their own MIME-detection. Such a technique is called MIME-sniffing and sometimes there is a mismatch between the web browser's MIME detection and the actual MIME type as given by the web server.

Usually, the web browser will use its own MIME prediction in such cases.

Rationale

It can get critical once an attacker is able to upload malicious content which is then served to the client. For instance, an attacker might trick an image uploader to upload an HTML file which is then served with the corresponding MIME type for JPEG pictures. However, the web browser will detect the HTML file and render it instead of displaying an error. Thus, an attacker might use such a technique as platform for phishing or other harmful attacks.

I01 - Manual Implementation Example

To set the `X-Content-Type-Options` HTTP header on your IIS server you need to add the following configuration lines to the `web.config` file within the root directory of the corresponding website:

```
<configuration>
<system.webServer>
  ...
  <httpProtocol>
    <customHeaders>
      <add name="X-Content-Type-Options" value="nosniff" />
    </customHeaders>
  </httpProtocol>
  ...
</system.webServer>
```

Listing: BL115-0800_I01_01.config

The `customHeaders` directive is applicable within the `ApplicationHost.config` file for the whole IIS server, or within the `web.config` file of a website or even within a specific folder.

It is recommended to set the HTTP Header globally within the `Application-Host.config` file for all web resources. However, keep in mind that the directive can be only set either in the `Application-Host.config` file or within the `web.config` file. Having the settings in both files will result in unwanted behavior.

I02 - PowerShell Implementation Example

Enter the following commands in PowerShell to configure:

```
Import-Module WebAdministration
Add-WebConfigurationProperty -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders" -name . -value @{name="X-Content-Type-Options";
value="nosniff"}
```

Listing: BL115-0800_I02_01.ps1

C01 - Manual Check Example

To verify X-Content-Type-Options has been set, browse to and open the `web.config` file for the configured site/application/content:

```
<configuration>
<system.webServer>
...
<httpProtocol>
  <customHeaders>
    <add name="X-Content-Type-Options" value="nosniff" />
  </customHeaders>
</httpProtocol>
...
</system.webServer>
```

Listing: BL115-0800_C01_01.config

C02 - PowerShell Check Example

To verify using PowerShell enter the following commands:

```
Import-Module WebAdministration
Get-WebConfiguration -pspath 'MACHINE/WEBROOT/APPHOST' -filter
"system.webServer/httpProtocol/customHeaders/add[@name='X-Content-Type-Options']"
```

Listing: BL115-0800_C02_01.ps1

Version History (Latest Entry)

v1.0 (2020-10-30): created (EVAL until 2021-02-28)

Based on former IIS 8.x measure M383800; rewrote mainly *Implementation* section for better understanding or adding features.

Definitions

Asset Manager (AM)

Asset Managers are individuals who hold the overall technical responsibility for IT Assets (e.g., IT systems, applications, IT services, networks). They serve as the primary technical point of contacts for their IT Assets and are accountable for, among others, their installation, maintenance, and implementation of all security technical requirements.

All IT Assets shall have an Asset Manager assigned.

Asset Managers can delegate, for example to a Support Organization, the responsibility of the actions associated with the role but the accountability always remains with the Asset Managers, even when the asset is operated by third-parties.

Depending on the type of IT asset, other names may be used, such as *IT System Manager*, *Application Manager*, *IT Service Manager*, *Cloud Asset Manager*, *Network Manager*, or *IT Operations Manager*.

Glossary

ACP

Abbreviation of Asset Classification and Protection.

Siemens' process to systematically identify critical assets and ensure the development and implementation of adequate protection concepts. More information can be found at <https://intranet.for.siemens.com/cms/056/en/processes/security/Pages/acp.aspx> and at <https://wiki.siemens.com/display/en/ACP>.

References

- [1] Siemens CYS GOV POL. *Siemens Information Security Policy Framework*.
<https://sfera.siemens.com/policies>
- [2] Siemens ST TO (2019). *Siemens Circular No. 105 "Implementation of Siemens-Internal Regulations in Affiliated Companies"*. <https://srs.siemens.cloud/#/c/ng233c>
- [3] Network Working Group - D. Ross, T. Gondrom (2013). *HTTP Header Field X-Frame-Options, RFC 7034*. <https://www.ietf.org/rfc/rfc7034.txt>